1. TÉCNICAS DE INVESTIGACIÓN EN FUENTES ABIERTAS

La labor del analista va más allá de la mera ejecución de diversas herramientas, sino entender el motivo por el cual utilizamos una u otra herramienta en determinadas circunstancias u operaciones a la que nos enfrentemos. En este punto gana importancia el método y el procedimiento para obtener información más que ejecutar una serie de herramientas sin ningún tipo de control. A lo largo de este tema se va a presentar un inventario de herramientas útiles para generar Inteligencia por medio de las fuentes abiertas, entender los resultados de cada una de ellas y sobre todo a tener un procedimiento para saber que guía seguir ante una investigación sobre un dominio, dirección IP , nombre de persona, correo electrónico o nombre de usuario.

1.1. KIT DE HERRAMIENTAS

En este subapartado se presentan una serie de herramientas útiles para una investigación sobre amenazas utilizando herramientas que obtengan los datos de las fuentes abiertas.

1.1.1. REGISTRO REGIONAL DE INTERNET

El **Registro Regional de Internet (RIR**) es el encargado de supervisar y registrar los recursos de Internet**,** permitiendo identificar los rangos de IP (IPv4 y IPv6) y Números de Sistemas Autónomos (ASN) asignados a una determinada región geográfica. Existen 5 regiones divididos a nivel mundial, los cuales pueden verse distribuidos geográficamente en la Imagen 1.



Imagen 1. RIR divididos por regiones geográficas

A continuación, se enumeran las 5 regiones:

- RIPE. Es el RIR encargado de asignar las direcciones IP a las regiones de Europa, Oriente Medio y Asia Central. Desde su página oficial se dispone de un recurso web que permite consultar información sobre cualquier registro. Dicho recurso es el siguiente: RIPE Database Query (https://apps.db.ripe.net/db-web-ui/query).

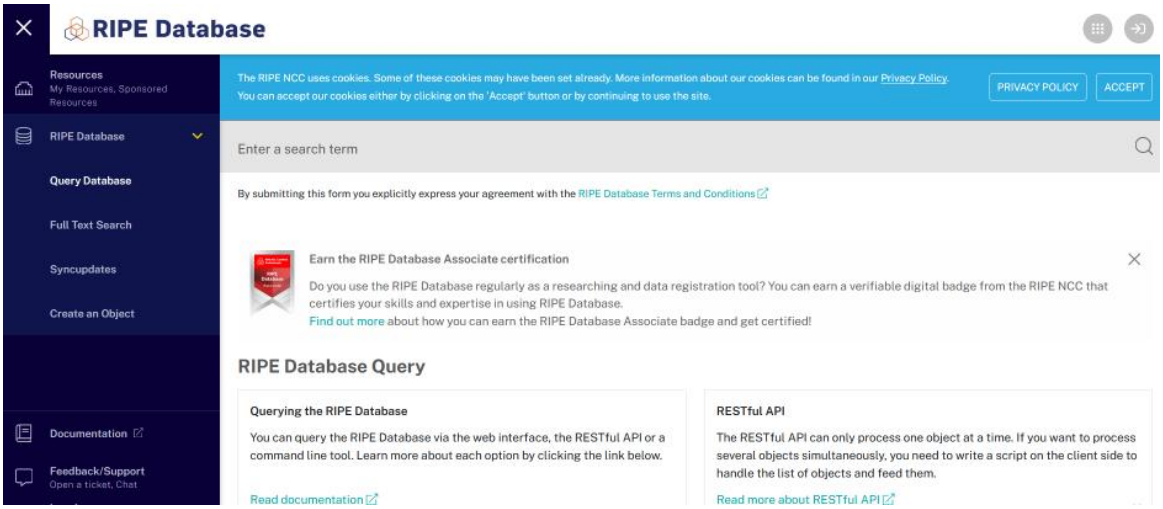


Imagen 2. Sitio oficial de RIPE Database Query

Entre los datos que recopila tenemos: rango IP, nombre del registrador, descripción del registrador, país, administrador, registrador técnico, estado, fecha de creación, fecha de modificación. Proporcionan toda la fuente de datos en abierto con actualizaciones constantes en el siguiente enlace: https://ftp.ripe.net/ripe/dbase/ripe.db.gz.

- AFRINIC. Es el RIR encargado de asignar las direcciones IP para el continente africano. Proporcionan toda la fuente de datos en abierto con actualizaciones constantes en el siguiente enlace: https://ftp.afrinic.net/pub/dbase/afrinic.db.gz.

- ARIN. Es el RIR encargado de asignar las direcciones IP a las regiones de Norteamérica, Canadá, Estados Unidos y parte del Caribe. Proporcionan toda la fuente de datos en abierto con actualizaciones constantes en el siguiente enlace: https://ftp.arin.net/pub/rr/arin.db.gz.

- LACNIC. Es el RIR encargado de asignar las direcciones IP a las regiones de Latinoamérica y la parte del Caribe que no cubre ARIN. Proporcionan toda la fuente de datos en abierto con actualizaciones constantes en el siguiente enlace: https://ftp.lacnic.net/pub/stats/lacnic/delegated-lacnic-extended-latest.

- APNIC. Es el RIR encargado de asignar las direcciones IP a las regiones de Asia y la costa del Pacífico. Proporcionan toda la fuente de datos en abierto con actualizaciones constantes en el siguiente enlace: https://ftp.apnic.net/apnic/whois/.

1.1.2. HUNTER

Hunter es un servicio online que nos permite obtener información sobre correos electrónicos. La herramienta es de pago pero permite disponer de una cuenta gratuita más limitada, logueandose con credenciales de Google. El enlace de acceso a dicho servicio es el siguiente: https://hunter.io.

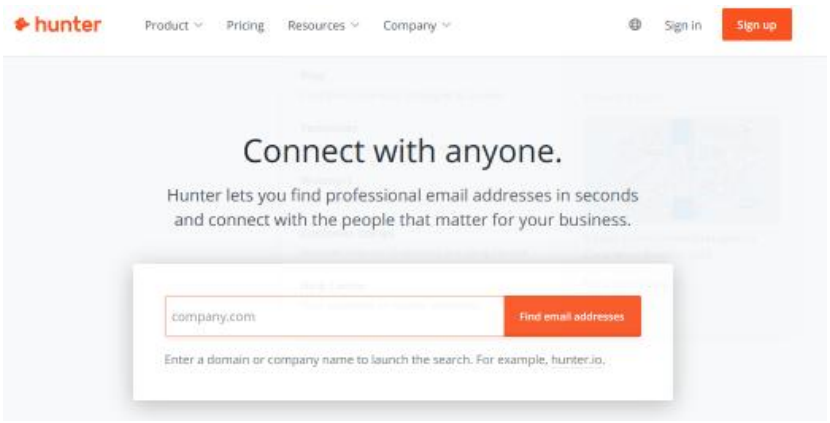


Imagen 3. Sitio principal de hunter

Hunter dispone de una serie de herramientas que permiten obtener información a partir de un dato concreto, por ejemplo, un dominio, un nombre de persona o correo electrónico. Las herramientas mencionadas son las siguientes:

- **Domain Search**. Mediante esta herramienta es posible detectar correos electrónicos y nombres de personas, entre otros datos (ver Imagen 4), a partir de un dominio dado.

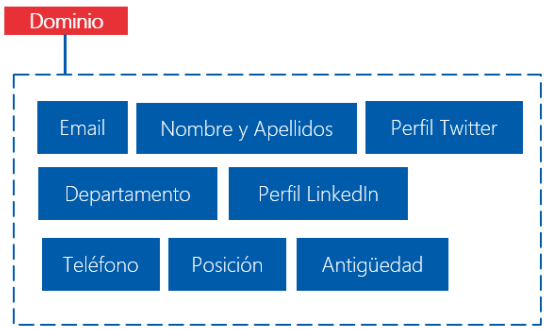


Imagen 4. Ejemplo de datos recolectados por Hunter a partir de un dominio

En este caso vamos a realizar una búsqueda de un objetivo para detectar correos electrónicos asociados. En la Imagen 5 se puede comprobar el resultado de nuestra búsqueda, recibiendo un listado de correos electrónicos, nombres de

persona y perfil social asociados, junto con la fiabilidad de coincidencia de que dicho correo puede ser verídico o no. Por otro lado, en la parte de la derecha podemos observar el presunto formato que puede estar utilizando el servidor de correo del objetivo para crear cada uno de los correos electrónicos.

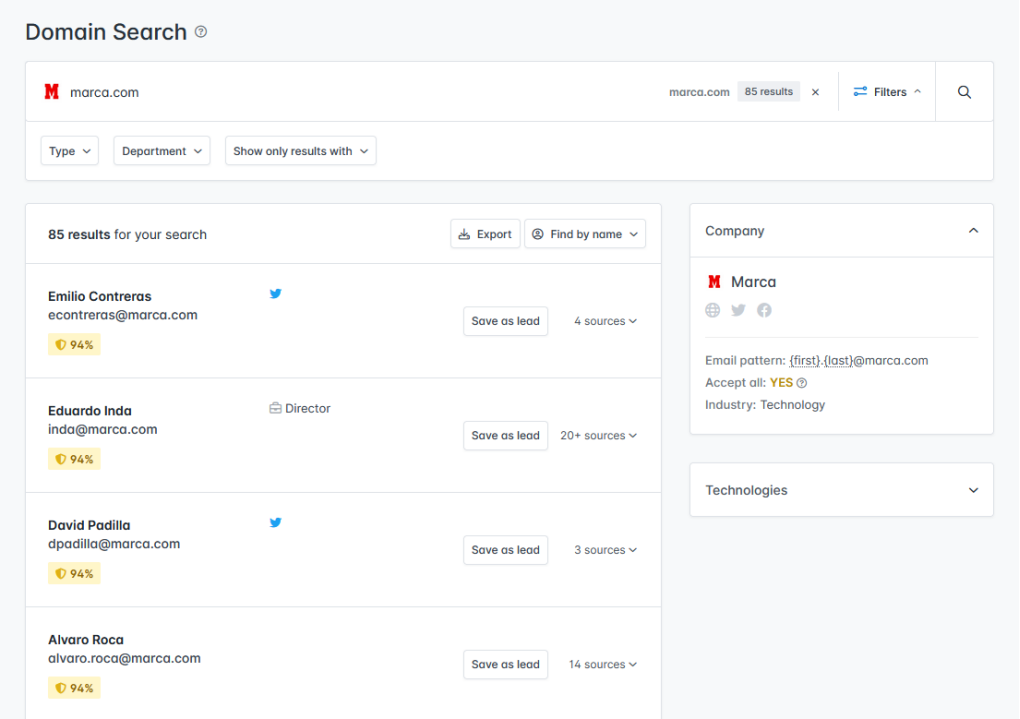


Imagen 5. Resultados generados por Domain Search de Hunter

Si hacemos zoom al primer resultado podemos ver las fuentes donde Hunter lo ha encontrado junto con la fecha asociada (ver Imagen 6).

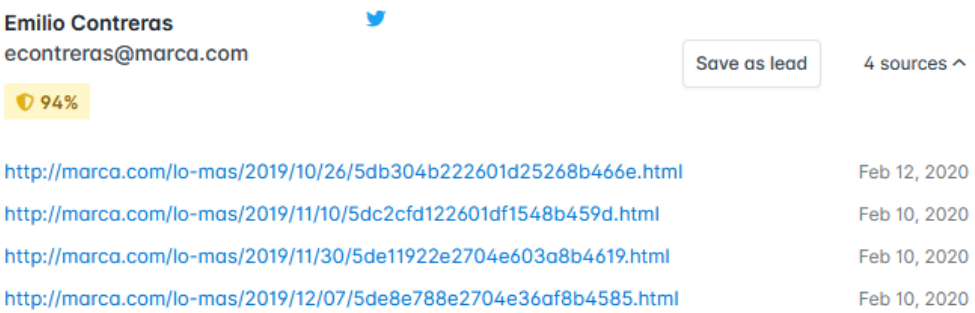


Imagen 6. Resultado individual con Domain Search

- **Email Finder**. Mediante esta herramienta es posible buscar un correo electrónico partiendo del nombre de la persona y de un dominio dado. En la Imagen 7 se puede observar cómo partiendo de un nombre de persona junto con el dominio se puede detectar el correo asociado, además de las fuentes donde lo ha localizado.

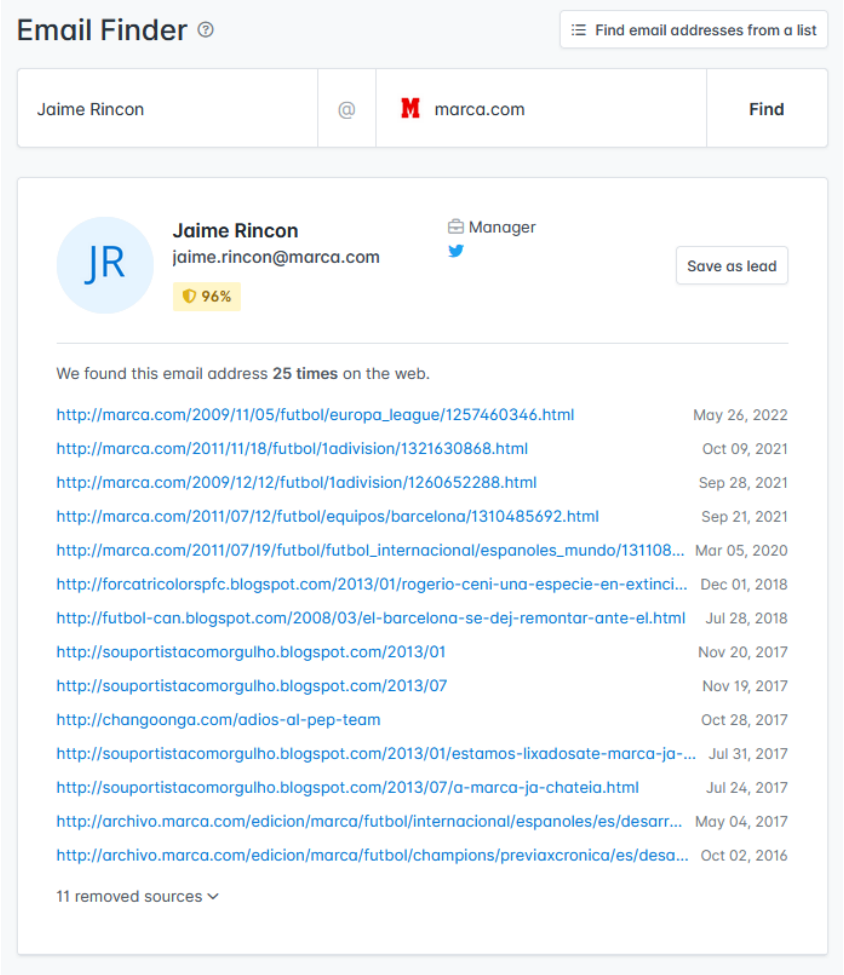


Imagen 7. Resultados de Email Finder de Hunter

- **Email Verifier**. Mediante esta herramienta es posible verificar si un correo electrónico existe dentro del dominio asociado. En la Imagen 8 se puede observar el resultado de esta herramienta partiendo de un correo electrónico dado, indicando las fuentes donde lo ha localizado y realizando una serie de

comprobaciones por medio del formato, el estado del servidor de correo, estado del correo y el tipo.

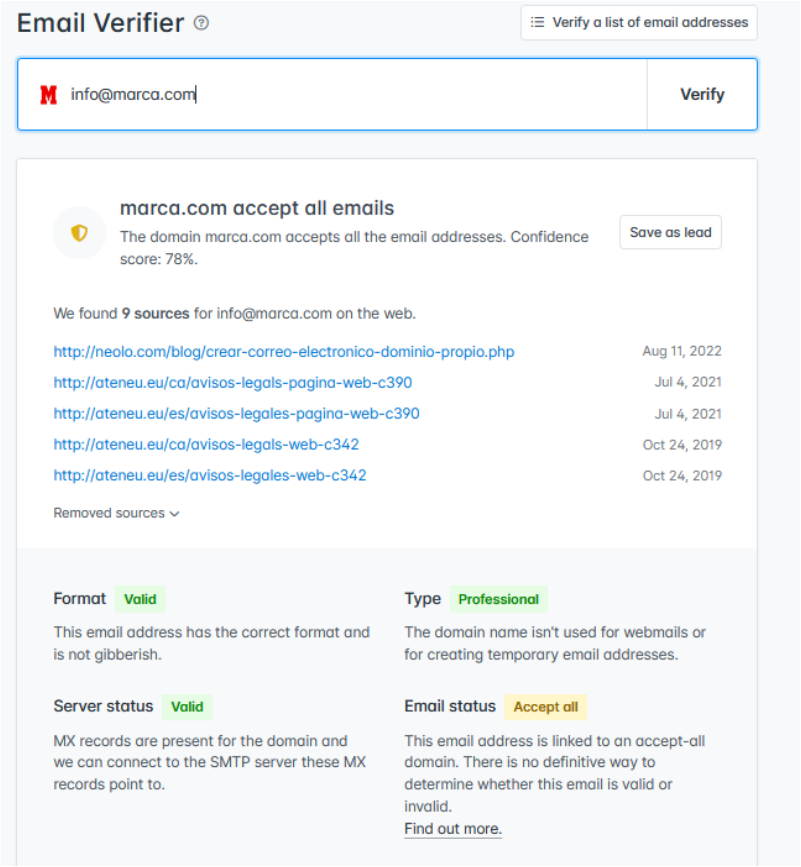


Imagen 8. Resultado de Email Verifier de Hunter

1.1.3. HAVEIBEENPWNED

HaveIbeenPwned es una herramienta web que permite comprobar si un email o un número de teléfono se encuentra presente en alguna fuga de información. La herramienta dispone actualmente con un total de 663 sitios web comprometidos y más de 12.484 millones de cuentas recopiladas (ver Imagen 9). El enlace de acceso a dicho servicio es el siguiente: https://haveibeenpwned.com.

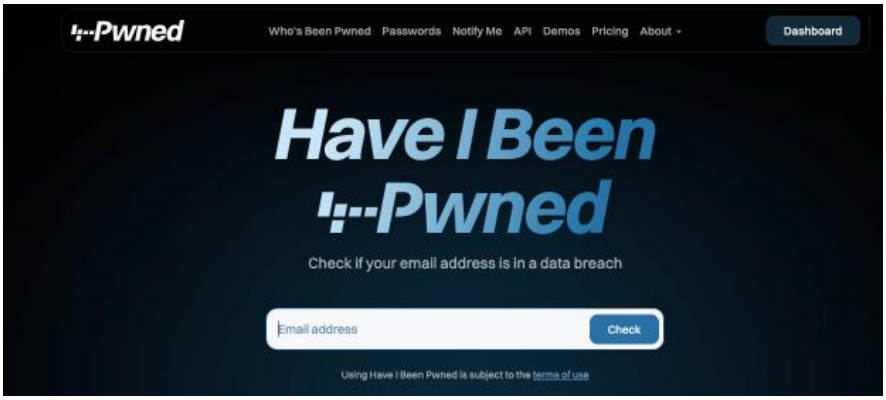


Imagen 9. Sitio web de HaveIbeenPwned

Si realizamos una búsqueda de un correo electrónico o un número de teléfono nos indicara si está presente en alguna fuga de información o no. En el caso de que exista una coincidencia podrá conocerse en que Data Leak se ha producido, descripción de la fuga y que tipo de datos se han filtrado (ver Imagen 10).

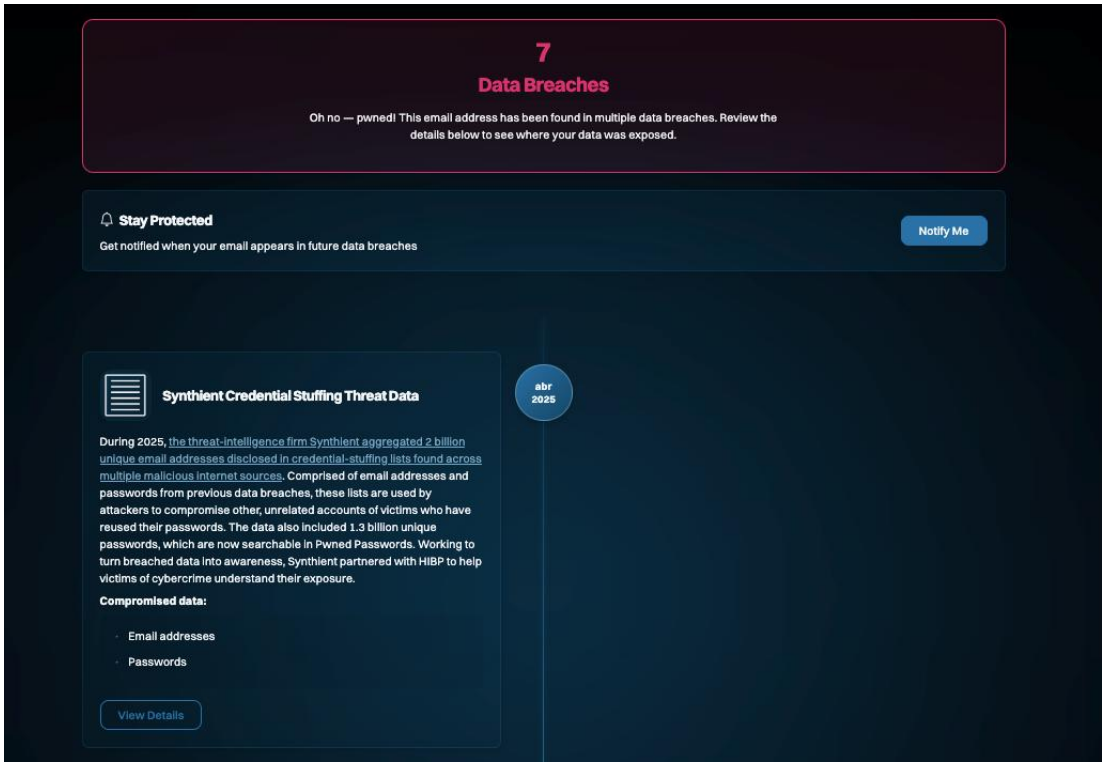


Imagen 10. Resultados de HaveIbeenPwned

Además, HaveIbeenPwned cuenta con una sección con información sobre todos los Data Leaks que se han producido. El enlace del recurso es el siguiente: https://haveibeenpwned.com/PwnedWebsites.

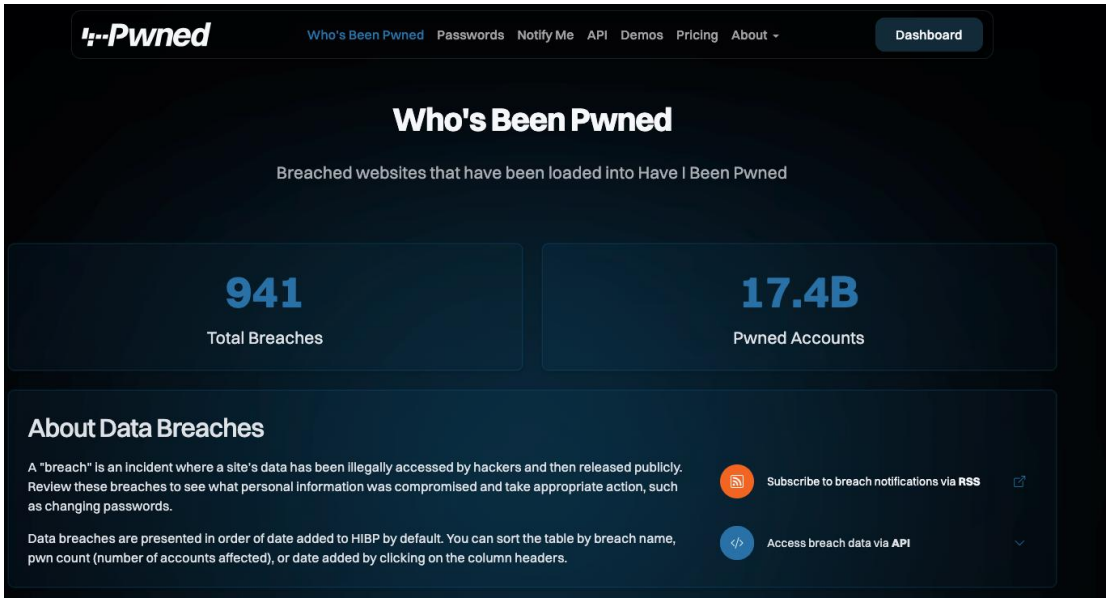


Imagen 11. Listado de Data Leaks filtrados

1.1.4. DEHASHED

Dehashed es un servicio que nos permite obtener información sobre fugas de información a partir de un dominio, username, correo electrónico, dirección IP, número de teléfono y dirección postal como punto de partida. En la Imagen 12 puede verse el sitio web de Dehashed, junto con el número total de activos comprometidos: *14.453 millones de registros*. El enlace de acceso es el siguiente: https://dehashed.com.

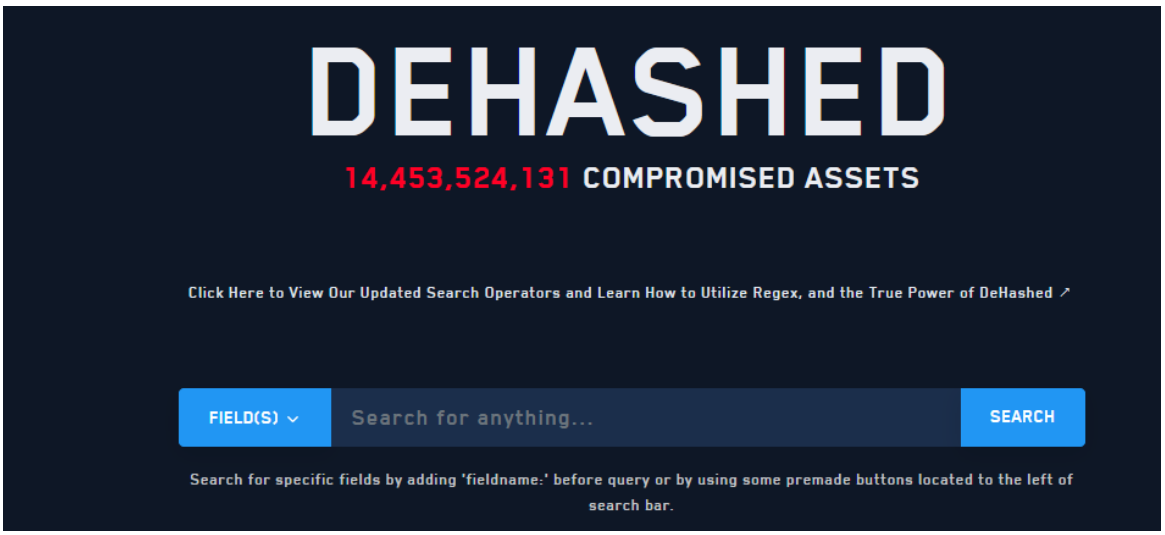


Imagen 12. Sitio web oficial de Dehashed

Es un servicio algo diferente a HaveIbeenPwned, ya que ofrece información de todos los datos de un objetivo que hayan sido filtrados en cada Data Leaks en donde esté presente. Dehashed se trata de un servicio de pago, pero que permite loguearse con una cuenta gratuita y realizar búsquedas en su plataforma. En la Imagen 13 se realiza una búsqueda del dominio de Microsoft, obteniéndose que hay *565.150 resultados* en total. En la parte inferior de la propia imagen, disponemos de diferentes bloques donde aparece información relativa a cada colección de Data Leak detectada y asociada a nuestro objetivo. En el caso de que dispongamos de una cuenta gratuita, veremos exactamente lo mismo que en la Imagen 13 pero no podremos acceder a cada bloque con la información.

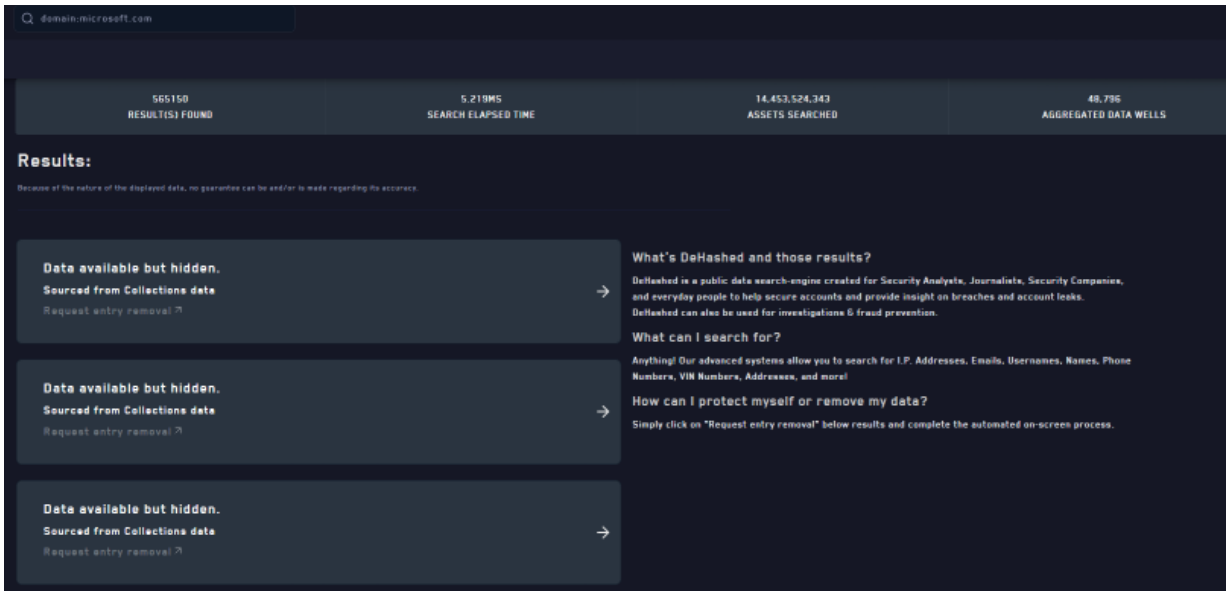


Imagen 13. Resultados de búsqueda con Dehashed

1.1.5. PASTEBIN

Pastebin es un sitio web que permite compartir fácilmente cualquier tipo de mensaje de texto de manera anónima. Actualmente es utilizado para filtrar información de cualquier tipo de dato, los más frecuentes la difusión de pastes sobre Data Leaks o sobre operaciones relacionados con temas de Hacktivismo. La información que es difundida por esta plataforma es bastante volátil, ya que en muchos casos los pastes duran minutos.

En la Imagen 14 pueden verse los últimos pastes publicados en Pastebin.

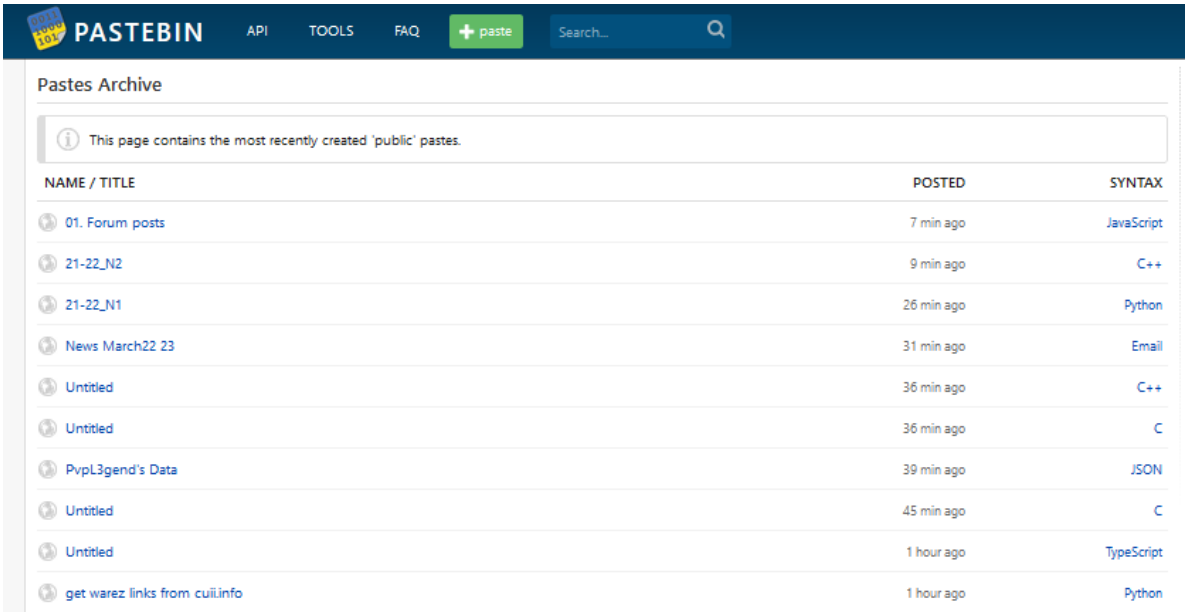


Imagen 14. Sitio web de Pastebin

Jorge Coronado en el blog de Quantika14 escribió un artículo donde explicaba como scrapear y como ir descargando los últimos pastes publicados mediante Python. El script utilizado puede encontrarse en la siguiente ruta: https://github.com/JWScr33d/crawler-downloader-pastebin.

A continuación, se facilitan los enlaces a la herramienta online:

- Buscador de Pastebin: https://pastebin.com/search?q=keyword
- Últimos pastes subidos a Pastebin: https://pastebin.com/archive.

1.1.6. VIRUSTOTAL

VirusTotal es ampliamente conocido por poseer uno de los repositorios de malware más grandes del mundo y ser una de las herramientas de Threat Intelligence más importantes. VirusTotal tiene un módulo de Inteligencia (de pago) en el que cuenta con una comunidad donde consultar cualquier tipo de dato a analizar a modo fuente. A través de esta comunidad de Inteligencia es posible realizar operaciones añadidas con respecto a la versión gratuita, siendo las siguientes:

- Búsqueda de cualquier patrón coincidente con la keyword introducida. En la Imagen 15 puede verse un extracto de 157 resultados de ficheros coincidentes con una palabra clave en particular.
- Descarga de muestras de cualquier tipo de archivo (EXE, APK, DEX, HTML, PDF, PPT, etc).
- Previsualización del contenido del fichero.
- Visualización de los strings asociados al fichero.
- Estadísticas sobre cuando fue subida la muestra o realizado el análisis.

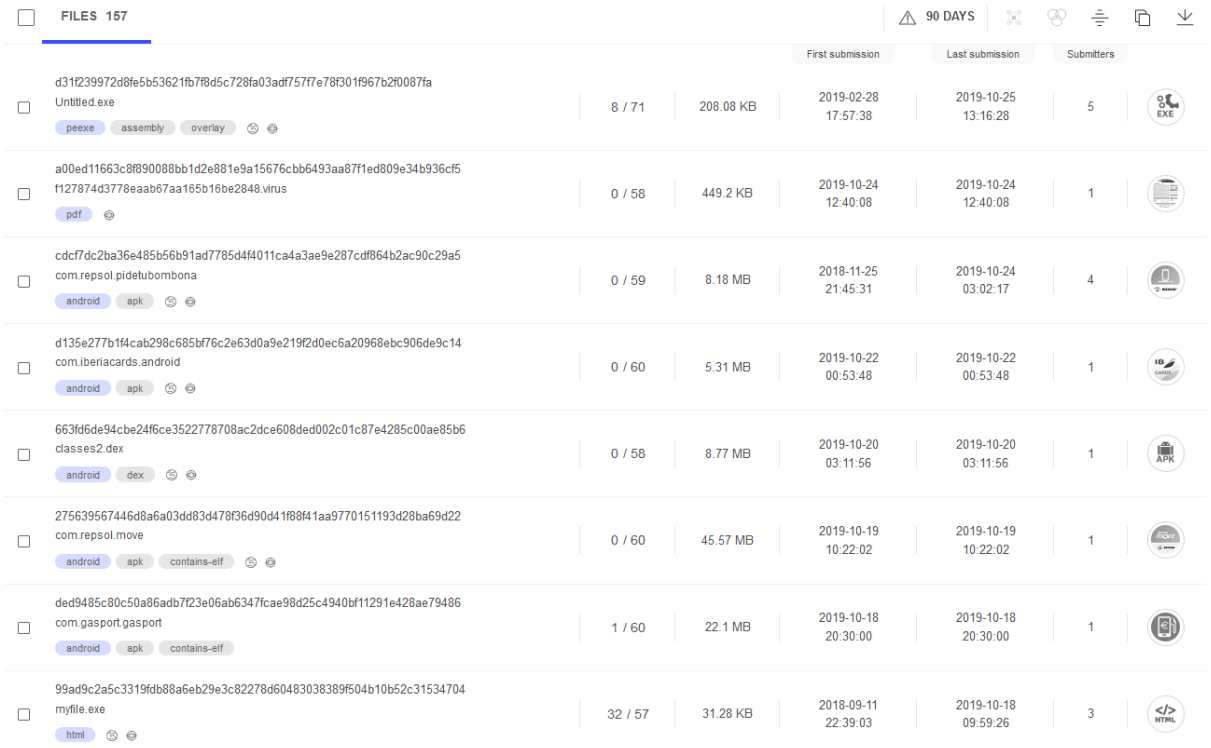


Imagen 15. Resultados de la búsqueda por keyword en VT Intelligence

Acabamos de descubrir lo que ofrece VirusTotal como fuente, pero es posible obtener diferentes tipos de datos más allá del malware. En la Imagen 16 puede verse un diagrama de cómo utilizar VirusTotal para buscar información sobre un dominio. A partir de dicho dominio es posible recopilar datos como la reputación web, el score de seguridad, la dirección IP, subdominios y certificados asociados, URL relacionadas con malware o

muestras representadas mediante un hash. Además, es posible seguir recopilando más datos mediante el descubrimiento de la dirección IP detectada anteriormente, consiguiendo datos como por ejemplo: dominios que resuelvan a la misma dirección IP, ASN, país donde fue registrada la IP, Rango IP, URL relacionadas con malware, muestras de malware (representadas mediante un hash) que evidencien una comunicación con la dirección IP.

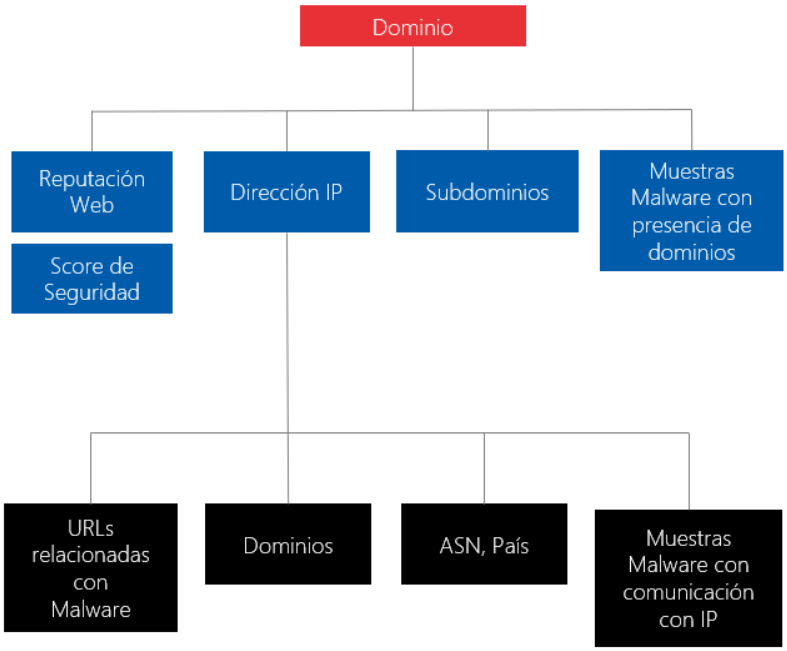


Imagen 16. Datos que pueden ser obtenidos por VT

Con VirusTotal es posible realizar búsquedas sobre un dominio, dirección IP, Hash o URL mediante la cuenta gratuita. Además, permite subir ficheros para ser analizados en busca de malware. Con esto último, hay que tener mucho cuidado y no compartir ficheros confidenciales porque dentro de la base de datos de conocimiento de la que dispone VirusTotal es posible obtener los metadatos, descargar o visualizar el propio documento.

En la Imagen 17 puede verse un ejemplo de los resultados generados por VirusTotal al realizar una búsqueda por un dominio.

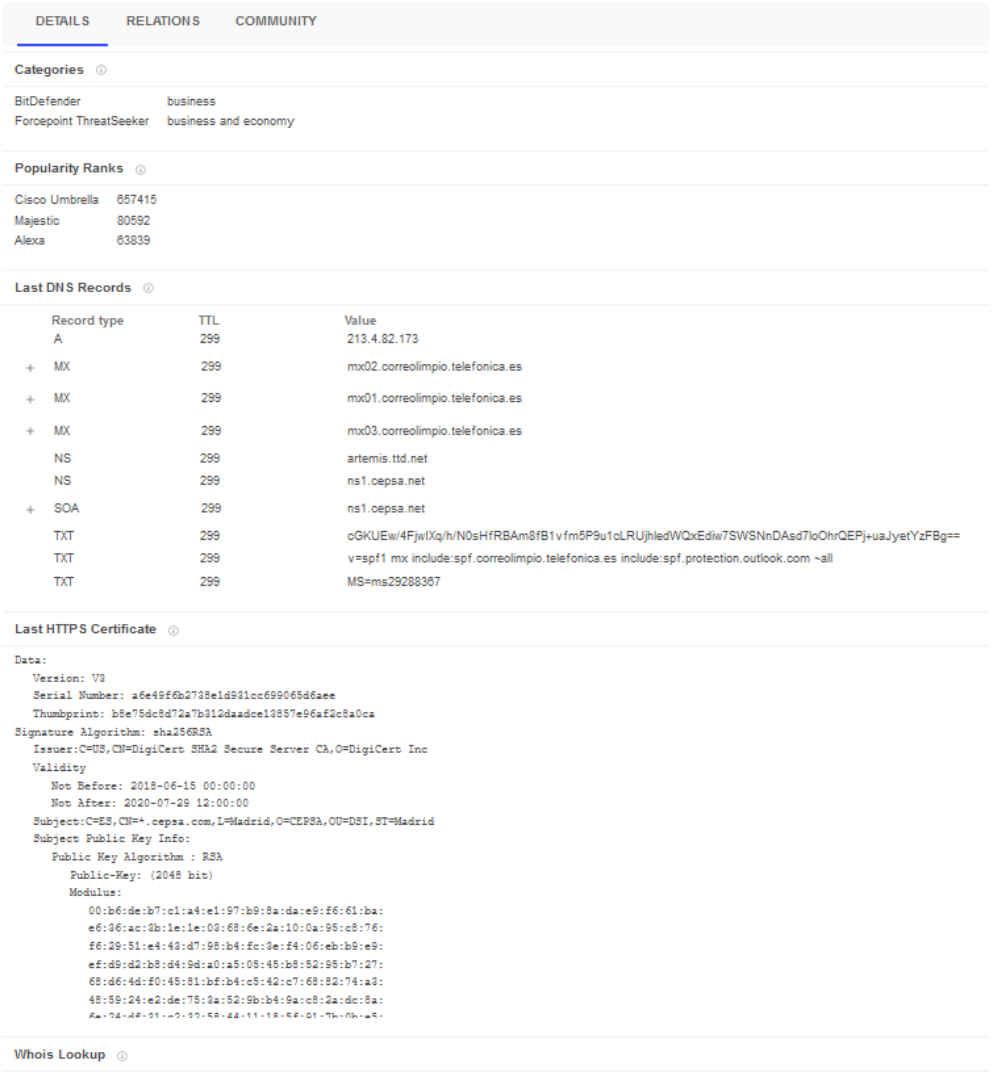


Imagen 17. Ejemplo de resultados de VT al buscar un dominio

En la Imagen 18 ha sido utilizado el módulo Graph de VirusTotal para sacar de manera visual todas las relaciones que puede tener asociado un dominio buscado.

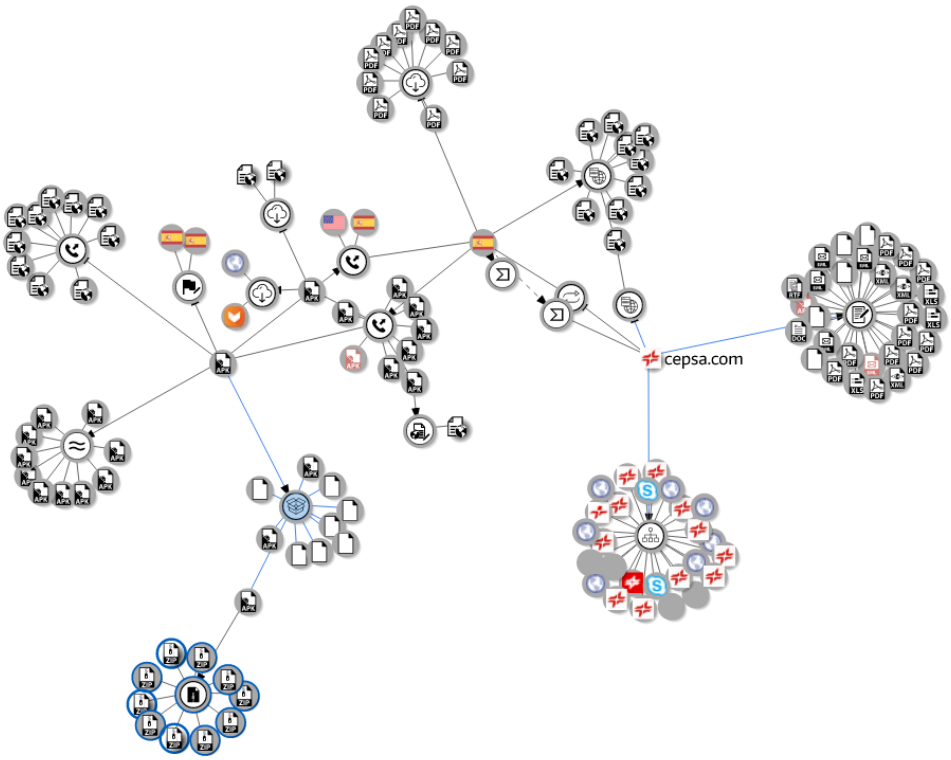


Imagen 18. Analizando un dominio con VT Graph

A continuación, se facilitan los enlaces a la herramienta online:

- Buscador de VT: https://www.virustotal.com/gui/home/search.
- Documentación de la API: https://developers.virustotal.com/reference
- Módulo VT Hunting (únicamente con subscripción de pago): https://www.virustotal.com/gui/hunting
- Modulo VT Graph: https://www.virustotal.com/graph/

1.1.7. HYBRID ANALYSIS

Hybrid Analysis es una herramienta gratuita online enfocada al análisis de Malware. En el año 2017 fue comprada por CrowdStrike[1], lo que le permite contar con una base de conocimiento sobre amenazas bastante grande. Las funcionalidades con las que cuenta Hybrid Analysis son las que pueden visualizarse en el menú de la Imagen 19. Permite subir uno o varios ficheros para su análisis, dispone de un buscador donde realizar consultas sobre dominios, direcciones IP, hashes o URLs para ver si tienen relación con algún tipo de malware. Además, permite realizar búsquedas mediante reglas YARA o strings en hexadecimal / ASCII.

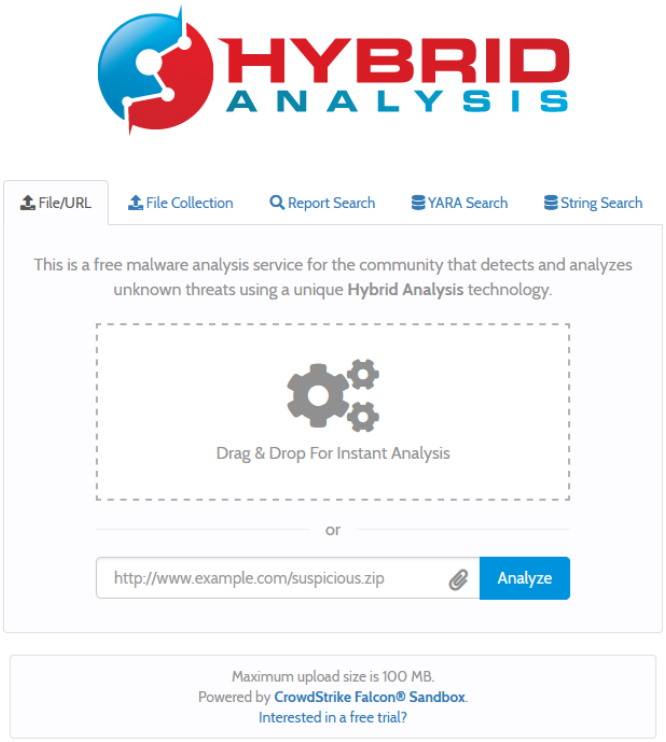


Imagen 19. Sitio web de Hybrid Analysis

En la Imagen 20 puede verse un ejemplo de reglas YARA que pueden ser definidas con Hybrid Analysis, siendo en este caso reglas relacionadas con el grupo Lazarus.

[1] CrowdStrike es una de las protecciones para Endpoint más importantes del mercado, el cual integra antivirus, detección y respuesta junto a Threat Hunting. Contiene una de las bases de datos sobre TTP y amenazas bastante importantes.

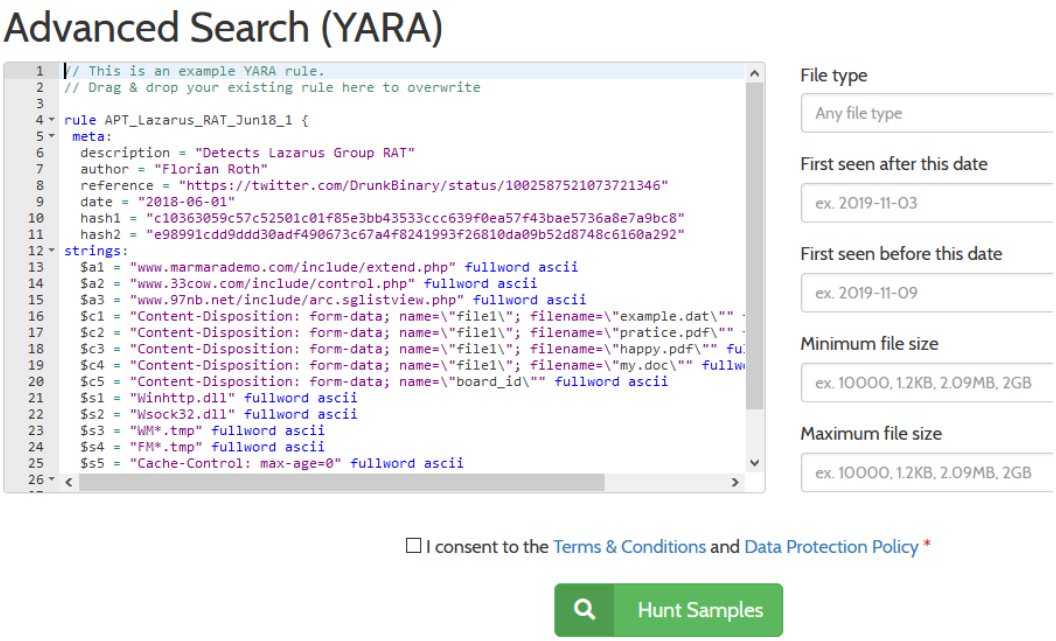


Imagen 20. Definición de reglas YARA en Hybrid Analysis

En la Imagen 21 pueden verse los resultados generados por la regla YARA definida en la Imagen 138.

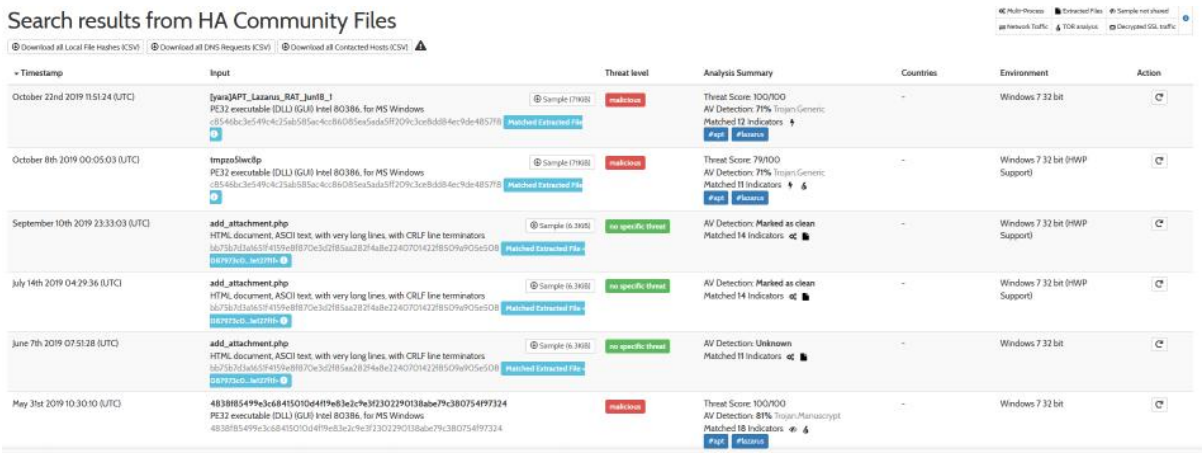


Imagen 21. Resultados generados por la definición de las reglas YARA de la Imagen 20

A continuación, se facilitan los enlaces a la herramienta online:

- Sitio Oficial de Hybrid Analysis: https://hybrid-analysis.com/.
- Buscador con reglas YARA: https://hybrid-analysis.com/yara-search.

- Colección de últimas muestras analizadas: https://hybrid-analysis.com/file-collections.
- Últimas URL enviadas al Sandbox: https://hybrid-analysis.com/submissions/sandbox/urls.
- Últimos ficheros enviados: https://hybrid-analysis.com/submissions/sandbox/files.
- Documentación de la API: https://hybrid-analysis.com/docs/api/v2.

1.1.8. ANY RUN

ANY RUN es una herramienta para analizar muestras de malware mediante análisis dinámico. Dispone de una versión gratuita que permite subir una muestra, elegir el sistema operativo donde cargar esta, detectar que procesos son ejecutados y descubrir que conexiones entrantes/salientes son establecidas.

En la versión gratuita es posible interactuar con el sistema operativo donde se haya subido la muestra durante 60 segundos más otros 4 minutos adicionales y el tamaño máximo permitido para la muestra es de 16 MB. La versión gratuita no permite interactuar con la API pero en la versión de pago si, incluso exportar los resultados en JSON y en formato legible para MISP.

A continuación, se facilitan los enlaces a la herramienta online:

- Sitio Oficial de ANY RUN: https://any.run.
- Herramienta ANY RUN (Ver imagen 22): https://app.any.run/.
- Últimas muestras públicas enviadas (Ver Imagen 23): https://app.any.run/submissions.
- Documentación de la API: https://any.run/api-documentation/.



Imagen 22. Sitio oficial de ANY RUN



Imagen 23. Últimas muestras públicas enviadas

En la Imagen 24 puede verse un ejemplo de una muestra analizada. En la parte central puede visualizarse un video mostrando cómo se comporta el sistema una vez se ha ejecutado la muestra. En la parte inferior pueden apreciarse las peticiones HTTP, conexiones establecidas, peticiones DNS y amenazas detectadas dentro de la muestra. En la parte derecha se ven todos los procesos ejecutados.

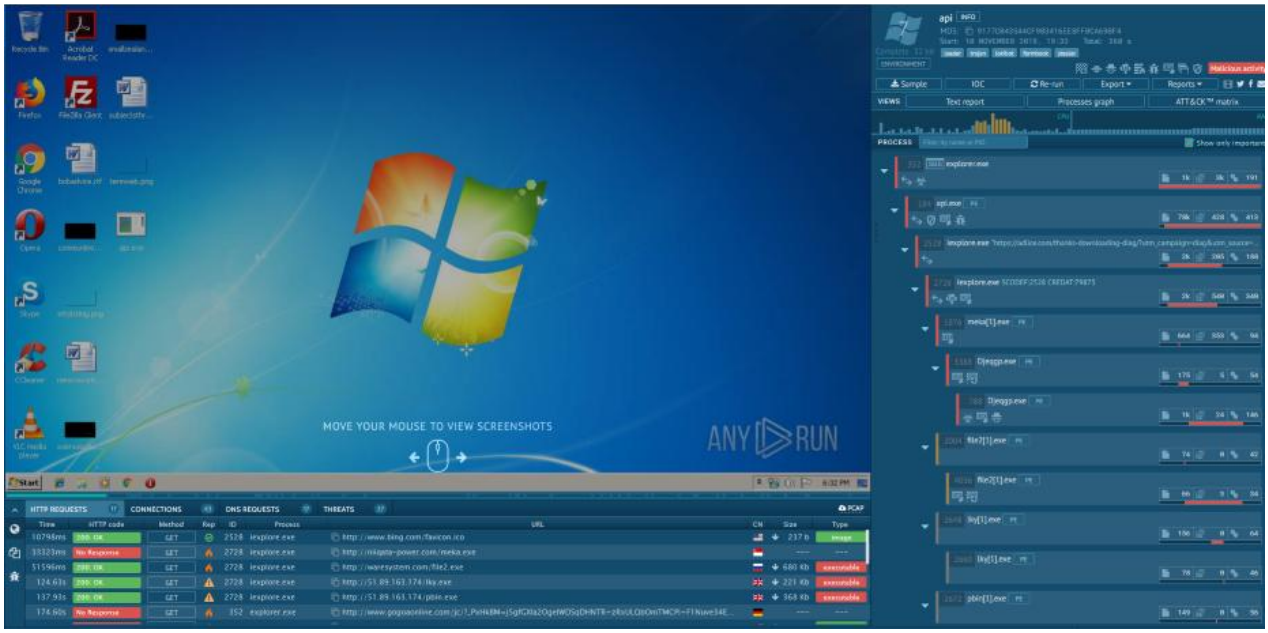


Imagen 24. Ejecución de una muestra de malware

Si accedemos a la opción de ATT&CK podremos ver los TTPs obtenidos de MITRE y que están relacionados con la muestra (ver Imagen 25). En el caso de que accedamos a la opción IOC, podremos ver un listado de IoC detectados en la muestra (ver Imagen 26).

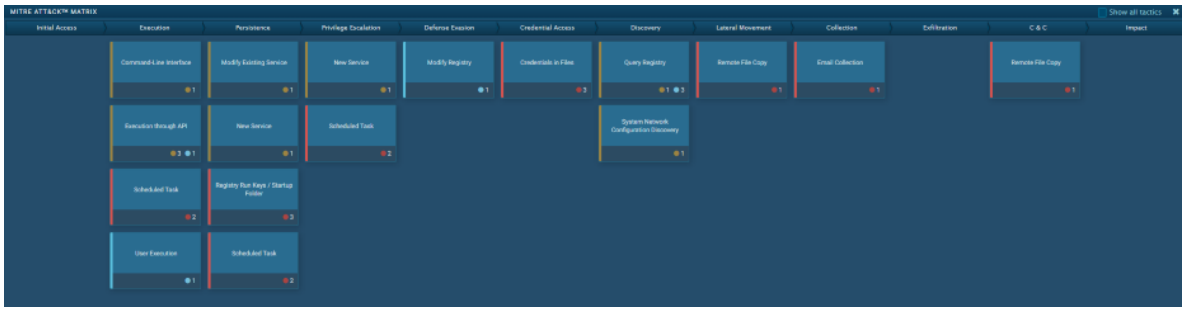


Imagen 25. TTPs relacionados con la muestra

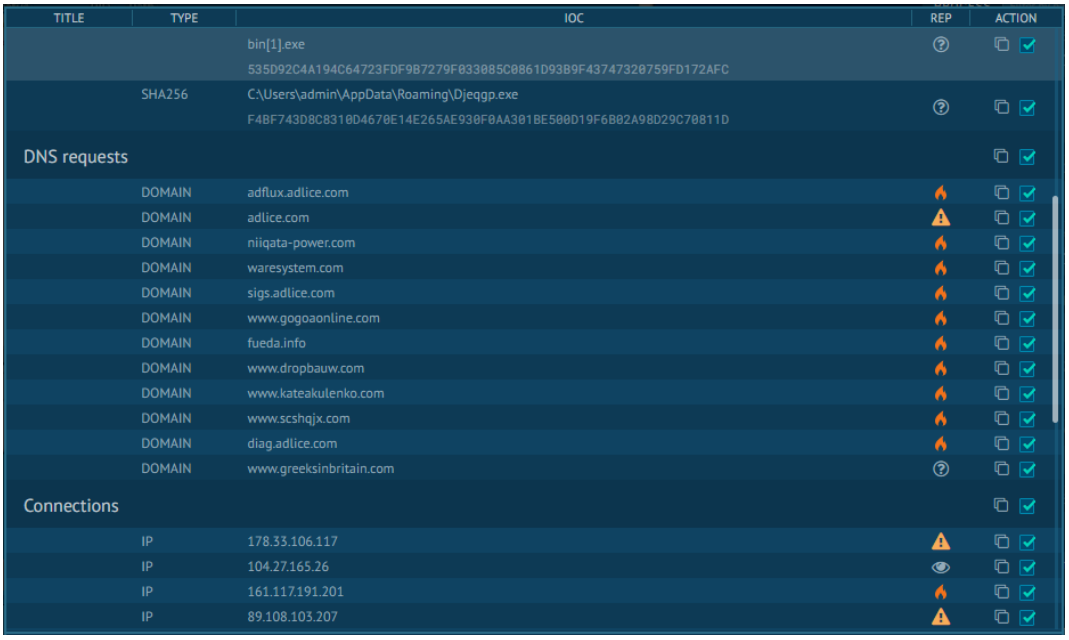


Imagen 26. Direcciones IP, dominios y subdominios detectados en la muestra

1.1.9. THREATMINER

ThreatMiner es una plataforma online que recopila diferentes IoCs de otras herramientas con el fin de disponer de una única interfaz para realizar las investigaciones sobre amenazas. ThreatMiner enriquece su base de datos sobre amenazas mediante fuentes externas, siendo las siguientes: CIRCL, VirusTotal, Hybrid Analysis, AlienVault OTX, Ipinfo, Robtex, VirusShare o Maltego.

Además, dispone también de la integración de las herramientas de código abierto APTNotes e IOCParser. Tal como puede verse en la Imagen 27 tras acceder a la web oficial (https://www.threatminer.org), cuenta con 25 millones de muestras, 50 millones de dominios, 48 millones de hosts, 978 informes de APTNotes.



Imagen 27. Sitio oficial de ThreatMiner

La herramienta permite realizar búsquedas sobre dominios, direcciones IP, URL, hashes, emails, notas recopiladas con APTNotes, SSL, User-Agent, familias de antivirus, registro, strings. A continuación son mostradas algunas de las opciones mencionadas:

- Buscar términos por APTNotes: https://www.threatminer.org/reports.php?q=lazarus
- Buscar por dominio: https://www.threatminer.org/domain.php?q=google.com
- Buscar por IP: https://www.threatminer.org/host.php?q=216.58.213.110
- Buscar por hash: https://www.threatminer.org/sample.php?q=e6ff1bf0821f00384cdd25efb9b1cc09
- Buscar por email: https://www.threatminer.org/email.php?q=***@***
- Buscar por AV: https://www.threatminer.org/av.php?q=Trojan.Enfal
- Buscar por mutex string: https://www.threatminer.org/mutex.php?q=UVhVXmJpX2Ax
- Buscar por User-Agent: https://www.threatminer.org/ua.php?q=Python-urllib
- Resto de queries: https://www.threatminer.org/features.php

Dispone de una API (puede consultarse en el siguiente enlace: https://www.threatminer.org/api.php) que permite la integración con otras plataformas para analizar amenazas como MISP, Splunk (SIEM), Rapid7 InsightConnect, IBM Resilient (Plataforma de gestión de incidentes).

1.1.10. ALIENVAULT OTX

OTX proporciona acceso gratuitamente a una comunidad global sobre amenazas, donde cualquier profesional pueda investigar y compartir activamente los últimos datos, tendencias y técnicas sobre las amenazas emergentes a nivel mundial. En la actualidad OTX cuenta con un total de 250.000 pulsos, que son un conjunto de colecciones de información sobre amenazas.

Características básicas:

- Dispone en la actualidad de 53 millones de registros sobre diversos IoCs (CIDR, CVE, Dominio, Email, IPv4, IPv6, FileHash MD5, FileHash SHA1, FileHash SHA-256, Hostname, Mutex, URL, reglas YARA, FilePath).
- Dispone de información sobre un total de 346 adversarios.
- Permite buscar información sobre amenazas relacionadas en un total de 19 industrias.
- Dispone de un repositorio sobre familias de malware, contando en la actualidad con 27.000.
- Permite la integración con agentes de AlienVault OSSIM, AlienVault USM, Bro, Suricata.
- Dispone de una API que permite la comunicación mediante Java, Python, Goland y TAXII.
- OTX permite crear y compartir resúmenes sobre amenazas que denominan Pulse. Dentro de estos es posible encontrar indicadores de compromisos relacionados, una vista del software objetivo y otros detalles relacionado con la amenaza en cuestión.
- OTX permite subir archivos para ser analizados estática y dinámicamente por el sandbox interno de AlienVault con el fin de detectar la presencia de alguna

amenaza. Además, a través de OTX es posible enviar una URLs para comprobar si tiene artefactos relacionados con otra amenaza.

- Los tipos de ficheros permitidos para su análisis son: cualquier ejecutable de Windows PE (exe, dll, sys), ejecutables de Linux (ELF), archivos ofimáticos (doc, docx, ppt, ppt, pps, pptx, ppsx, xls, xlsx, rtf, pub, pdf), paquetes de Microsoft Installer (MSI), JAR, ZIP, HTA), Windows Shortcut (lnk), Windows Script File (wsf), JavaScript, Visual Basic (vbs, vbe), Shockwave Flash (swf), batch file (bat), shell script (sh), PowerShell (ps), Scalable Vector Graphics (svg), MIME RFC 822 (eml), Python (py) y Perl (pl).
- Posibilidad de categorizar cada fichero o URL enviada con el TLP deseado, por defecto es catalogado como White.

A continuación, se facilitan enlaces relacionados con AlienVault OTX:

- Sitio Oficial: https://otx.alienvault.com.
- Documentación API: https://otx.alienvault.com/api.
- Repositorio para conexión con Bro: https://github.com/AlienVault-OTX/OTX-Apps-Bro-IDS.
- Repositorio para conexión con TAXII: https://github.com/AlienVault-OTX/OTX-Apps-TAXII.
- Repositorio para conexión con Suricata: https://github.com/AlienVault-OTX/OTX-Suricata.

  Repositorio para conexión mediante Java SDK: https://github.com/AlienVault-OTX/OTX-Java-SDK.
- Repositorio para conexión mediante Python SDK: https://github.com/AlienVault-OTX/OTX-Python-SDK.
- Repositorio para conexión mediante Golang: https://github.com/AlienVault-OTX/OTX-Go-SDK.

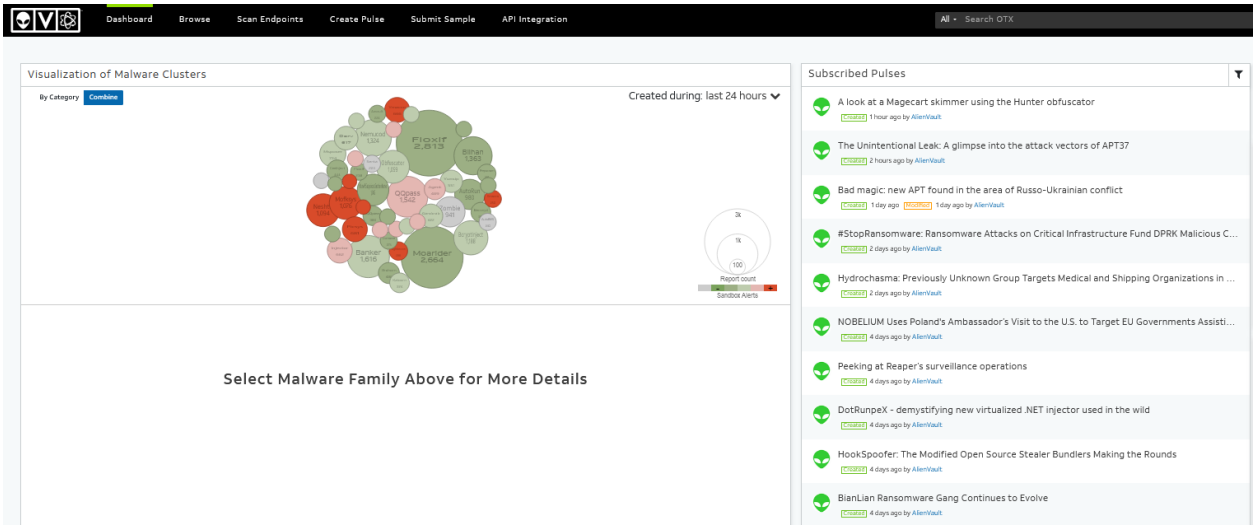


Imagen 28. Sitio oficial de AlienVault OTX

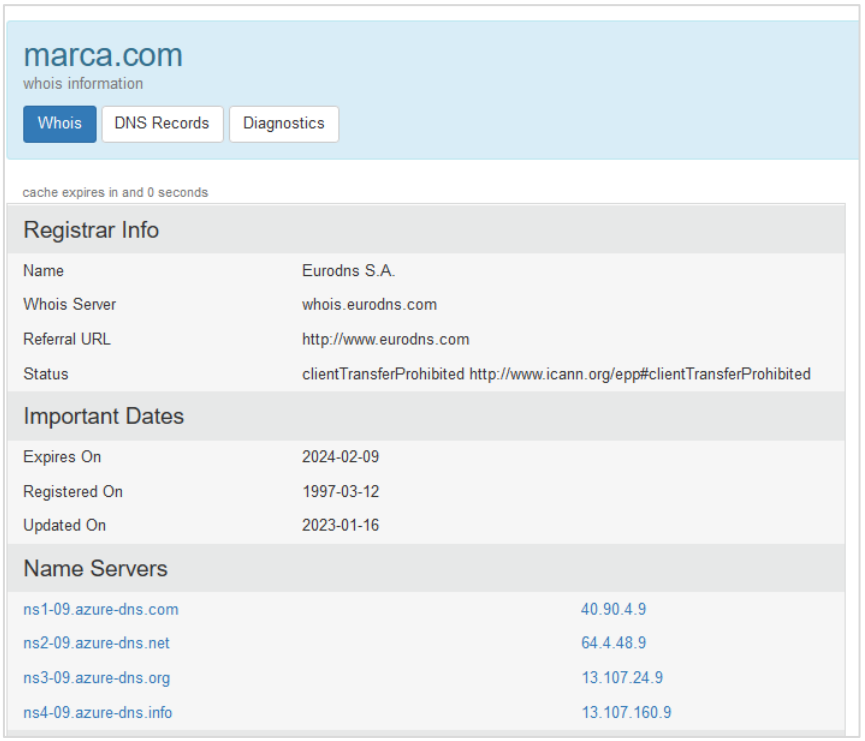
1.1.11. WHOIS

WHOIS permite buscar el nombre y la información de contacto de quien opere un dominio, aunque la información que podamos obtener a grandes rasgos es bastante limitada debido al RGPD. El WHOIS está formado por la siguiente información:

- **Información del registrador**: nombre, referencia por URL, estado
- **Datos sobre fechas asociados**: fecha de registro, expiración y actualización)
- Servidores NS (Registros NS)
- **Información de contacto del registrante**: nombre organización, dirección postal, ciudad, país, teléfono y correo electrónico
- **Información de contacto del administrador**: nombre organización, dirección postal, ciudad, país, teléfono y correo electrónico
- **Información de contacto técnico**: nombre organización, dirección postal, ciudad, país, teléfono y correo electrónico

Existen varias plataformas web que ofrecen información relativa al whois, siendo las más importantes las siguientes:

- **who.is**. Se trata de un sitio web que ofrece servicio dando información relativa a dominios o direcciones IP. Cuenta con una versión gratuita, aunque si se desea hay disponible una versión de pago que permite realizar un seguimiento de los dominios objetivos. El enlace de acceso es el siguiente: https://who.is/. En las imágenes 30 y 31 se realiza una búsqueda de "marca.com" con el objetivo de obtener el Whois asociado al mismo. Entre los datos que se recopilan están: el nombre del registrador, fechas de registro, actualización y expiración, registros NS e información de contacto del administrador, técnico y registrante.



marca.com

whois information

Whois | DNS Records | Diagnostics

cache expires in and 0 seconds

Registrar Info

Name	Eurodns S.A.
Whois Server	whois.eurodns.com
Referral URL	http://www.eurodns.com
Status	clientTransferProhibited http://www.icann.org/epp#clientTransferProhibited

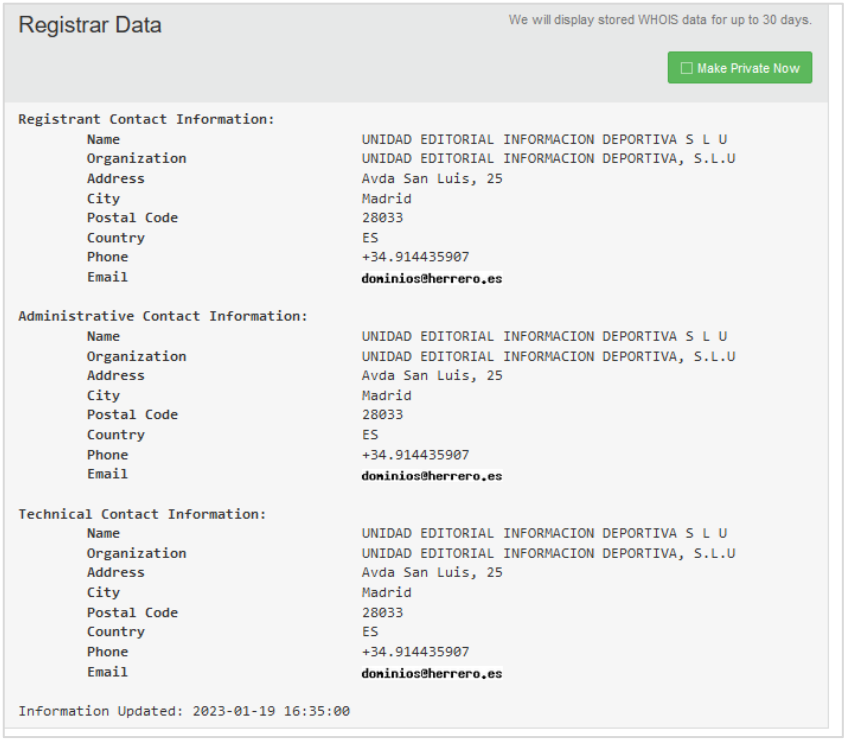
Important Dates

Expires On	2024-02-09
Registered On	1997-03-12
Updated On	2023-01-16

Name Servers

ns1-09.azure-dns.com	40.90.4.9
ns2-09.azure-dns.net	64.4.48.9
ns3-09.azure-dns.org	13.107.24.9
ns4-09.azure-dns.info	13.107.160.9

Imagen 29. Resultados del Whois del objetivo - parte 1



Registrar Data

We will display stored WHOIS data for up to 30 days.

Make Private Now

```
Registrant Contact Information:
        Name                    UNIDAD EDITORIAL INFORMACION DEPORTIVA S L U
        Organization            UNIDAD EDITORIAL INFORMACION DEPORTIVA, S.L.U
        Address                 Avda San Luis, 25
        City                    Madrid
        Postal Code             28033
        Country                 ES
        Phone                   +34.914435907
        Email                   dominios@herrero.es

Administrative Contact Information:
        Name                    UNIDAD EDITORIAL INFORMACION DEPORTIVA S L U
        Organization            UNIDAD EDITORIAL INFORMACION DEPORTIVA, S.L.U
        Address                 Avda San Luis, 25
        City                    Madrid
        Postal Code             28033
        Country                 ES
        Phone                   +34.914435907
        Email                   dominios@herrero.es

Technical Contact Information:
        Name                    UNIDAD EDITORIAL INFORMACION DEPORTIVA S L U
        Organization            UNIDAD EDITORIAL INFORMACION DEPORTIVA, S.L.U
        Address                 Avda San Luis, 25
        City                    Madrid
        Postal Code             28033
        Country                 ES
        Phone                   +34.914435907
        Email                   dominios@herrero.es

Information Updated: 2023-01-19 16:35:00
```

Imagen 30. Resultados del Whois del objetivo - parte 2

- **DomainTools**. Se trata de una herramienta comercial que ofrece servicio sobre información de dominios y direcciones IP y aunque sea de pago permite realizar algunas peticiones de manera gratuita. El enlace de acceso es el siguiente: https://whois.domaintools.com/.

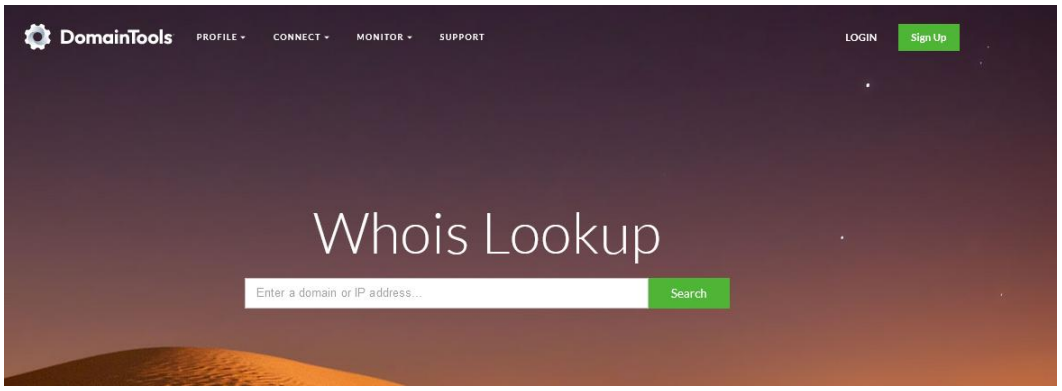


Imagen 31. Sitio web oficial de DomainTools

A continuación, se realiza una búsqueda del dominio "marca.es" para obtener información relativa al dominio mediante DomainTools. En la Imagen 33 puede consultarse los registros NS asociados al dominio, la dirección IP, el ASN y un screenshot del sitio web. Al tratarse de un dominio .es, la información que se puede recuperar por este tipo de herramientas es mínima.

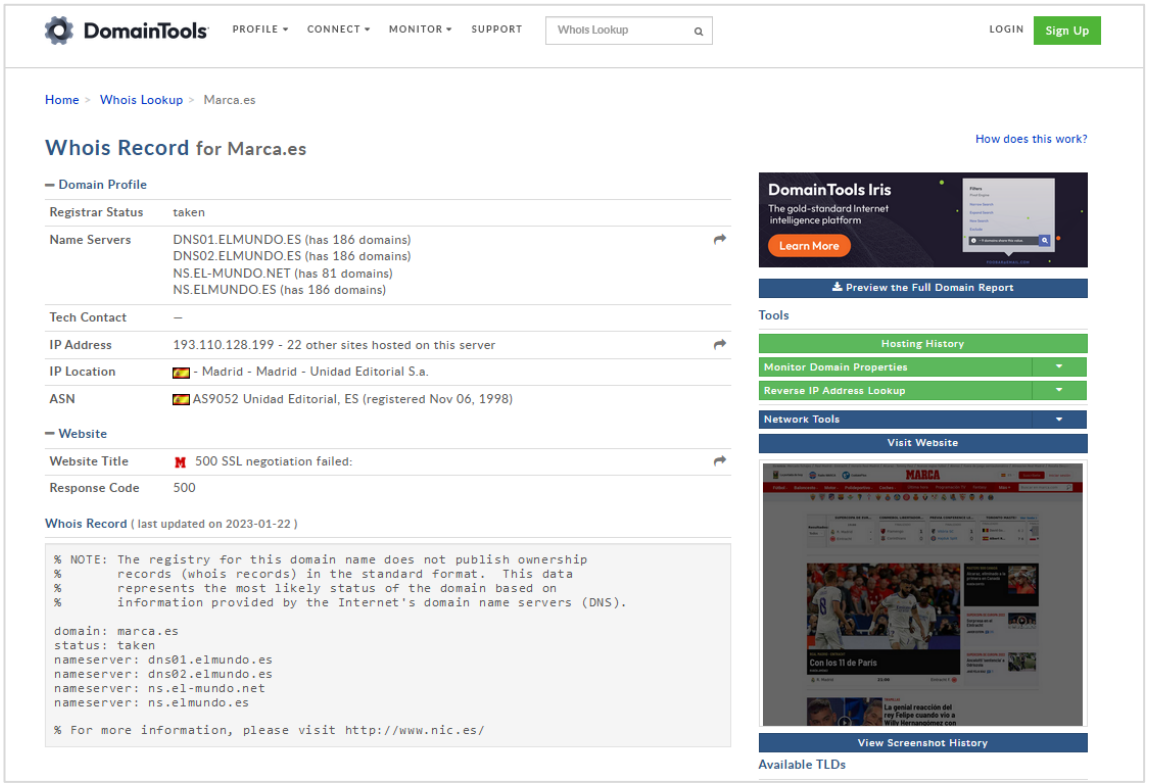


Imagen 32. Resultados del objetivo con DomainTools

- **Dominios .es**. Se trata de la unidad responsable de la gestión del registro de nombres de dominio de Internet bajo el código de país ".es" y están integrados en la Entidad Pública Empresarial de Red.es del Gobierno de España. El propio "dominios.es" dispone de un buscador gratuito donde poder consultar información sobre dominios españoles bajo el TLD ".es". El enlace de acceso es el siguiente: https://www.dominios.es/es.

Accediendo al sitio web oficial, se realiza una búsqueda del dominio de "marca.es", tal como se puede apreciar en la Imagen 34. Acto seguido "dominio.es" indica los dominios que están registrados, detectando que nuestro dominio objetivo (marca.es) está ocupado (ver Imagen 35).



Imagen 33. Búsqueda del dominio objetivo en dominios.es



Imagen 34. Resultados de la búsqueda del dominio objetivo

Si se accede a consultar los datos asociados del dominio objetivo (marca.es) podremos obtener información asociada al propio dominio, como el titular de este, el agente registrador, fechas de alta y expiración, servidores NS con su dirección IP asociada y los contactos administrativo y técnico. En la Imagen 36 se puede ver lo comentado.



Información de Dominio

Volver

Los datos de contacto de este dominio están ocultos. Si desea comunicarse con el Titular y el PCA pulse aquí

DATOS DEL TITULAR

Nombre del Dominio	marca.es
Estado	Activado
Identificador	UEID2-ESNIC-F4
Titular	UNIDAD EDITORIAL INFORMACIÓN DEPORTIVA,S.L.U
Fecha de Alta	20-07-2001
Fecha de Caducidad	20-07-2023
Agente Registrador	EURODNS S.A.

PERSONA DE CONTACTO ADMINISTRATIVO

Identificador	F95A19-ESNIC-F5
Nombre	PATRICIA DOMINGO

PERSONA DE CONTACTO TECNICO

Identificador	F95A18-ESNIC-F5
Nombre	ALEX PALOMO

PERSONA DE CONTACTO DE FACTURACION

SERVIDORES DNS

Nombre Servidor	IP
dns01.elmundo.es	193.110.128.50 2001:67c:2294:1000::f050
dns02.elmundo.es	193.110.128.51
ns.elmundo.es	193.110.128.51 2001:67c:2294:1000::f051
ns.el-mundo.net	

Imagen 35. Resultados asociados al dominio objetivo con dominios.es

1.1.12. HACKER TARGET

Hacker Target está compuesto por un conjunto de servicios en forma de herramientas de diversa índole con el objetivo de ofrecer un descubrimiento de la superficie de ataque y las vulnerabilidades que pueda estar asociado a un cliente. Hacker Target ofrece servicios tanto de pago como una parte gratuita de sus herramientas. El enlace del sitio oficial es el siguiente: https://hackertarget.com/.

Antes de comenzar a enumerar las herramientas, es necesario conocer que tipos de registros DNS pueden estar asociados a un dominio. Dichos registros son los que se pueden ver a continuación:

Registro A	Tipo de registro DNS. Vinculan un nombre de host (dominio) a una dirección IP. Ej.: ftp.dominio.com. A 156.25.89.36
Registro NS	Tipo de registro DNS. Son los servidores DNS Autorizados para un dominio/subdominio y quien informará de cualquier petición solicitada al dominio. Ej.: dominio.com. NS ns1.dominio.com.
Registro MX	Tipo de registro DNS. Indica el servidor de correo responsable de distribuir y gestionar los correos relacionados con el dominio. Ej.: dominio.com. MX 10 mx01.dominio.com.
Registro CNAME	Tipo de registro DNS. Especifica las redirecciones desde los subdominios de un dominio hacia otros dominios/subdominios. Ej.: ftp.dominio.com. CNAME dominio.com.
DNS Reverse	Utiliza registro DNS PTR. Resuelve dirección IP hacia un nombre de host (dominio). Similar a Registro A pero a la inversa. Ej.: 44.33.22.11.in-addr.arpa PTR dominio.com.

Hacker Target posee una serie de herramientas muy interesantes relacionados con dominios y direcciones IP, siendo las siguientes:

- **DNS Lookup**. Con esta herramienta se pueden obtener todos los registros DNS asociados a un dominio objetivo. El enlace de acceso es el siguiente: https://hackertarget.com/dns-lookup/. En la Imagen 37 pueden verse los resultados sobre registros DNS asociados a un dominio objetivo (marca.es).

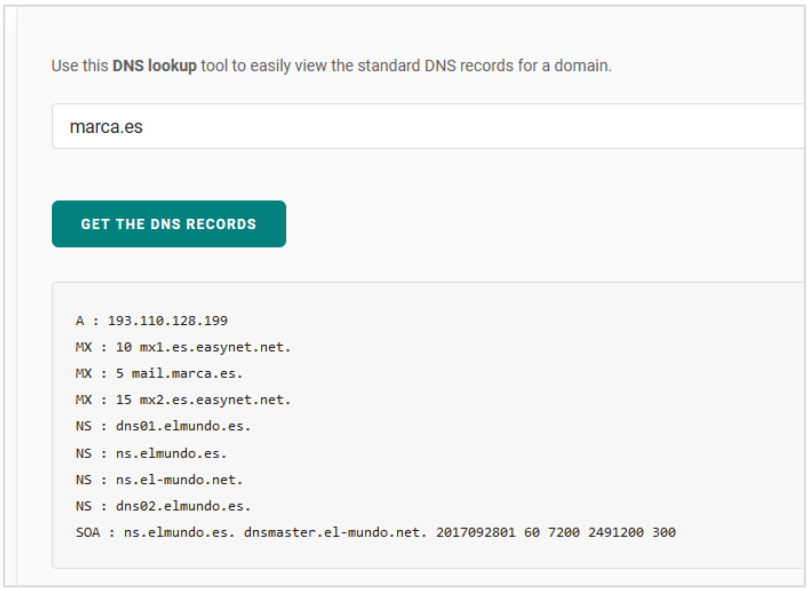


Imagen 36. Resultados de DNS Lookup

- **Reverse IP Lookup**. Con esta herramienta se pueden obtener todos los dominios

que estén apuntando a una dirección IP objetivo. El enlace de acceso es el siguiente: https://hackertarget.com/reverse-ip-lookup/.

En la Imagen 38 pueden consultarse todos los dominios que apuntan a la dirección IP detrás de nuestro dominio objetivo (marca.es).

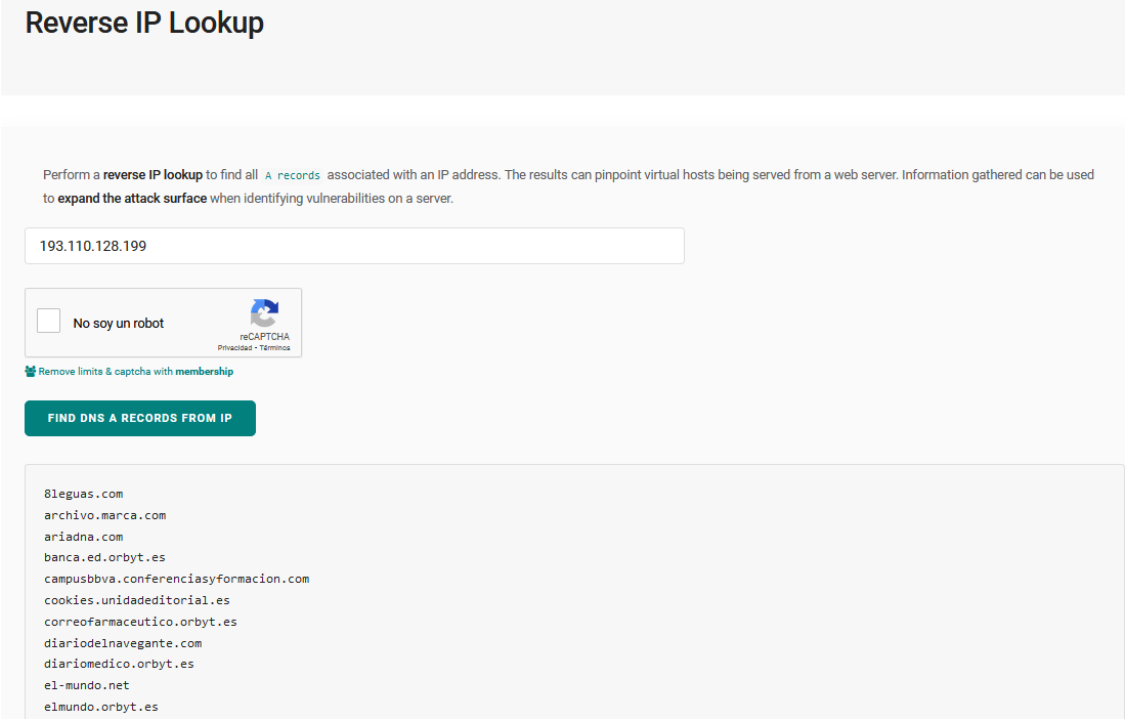


Imagen 37. Listado de dominios obtenidos mediante Reverse IP Lookup

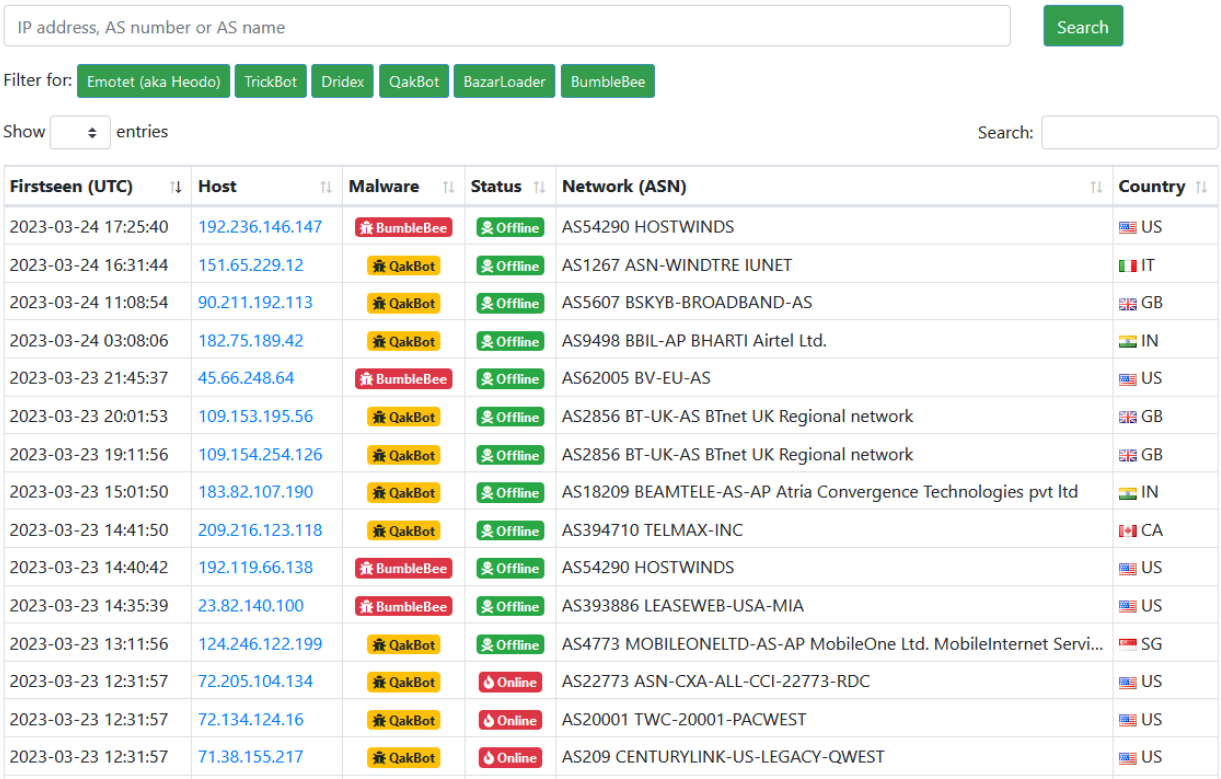
1.1.13. FEODO TRACKER

Feodo Tracker es un Proyecto de abuse.ch con el objetivo de compartir información sobre servidores de Comando y Control (C&C) de botnets asociadas con Dridex, Emotet, TrickBot, QuakBot y BazarLoader. Feodo Tracker rastrea y monitoriza diferentes familias relacionadas con las botnets mencionadas anteriormente con el propósito de identificar nuevas familias consideradas como una variante del malware Feodo. Dicho malware era

un troyano bancario que se utilizaba en diferentes tipos de fraude online hacia el sector bancario, en el que desde el 2010 varias familias de malware evolucionaron de él.

Feodo Tracker dispone de un buscador que permite realizar consultas sobre direcciones IP, ASN o AS, el cual está activo desde el 2010. En enlace de dicho buscador está disponible aquí: https://feodotracker.abuse.ch/browse/.

En la Imagen 39 puede verse el propio buscador donde clasifica la información en cuanto a la fecha de detección de la primera aparición, dirección IP, el tipo de malware, el estado (activo o inactivo), ASN y el país origen de la dirección IP.


IP address, AS number or AS name

Search

Filter for: Emotet (aka Heodo) | TrickBot | Dridex | QakBot | BazarLoader | BumbleBee

Show entries

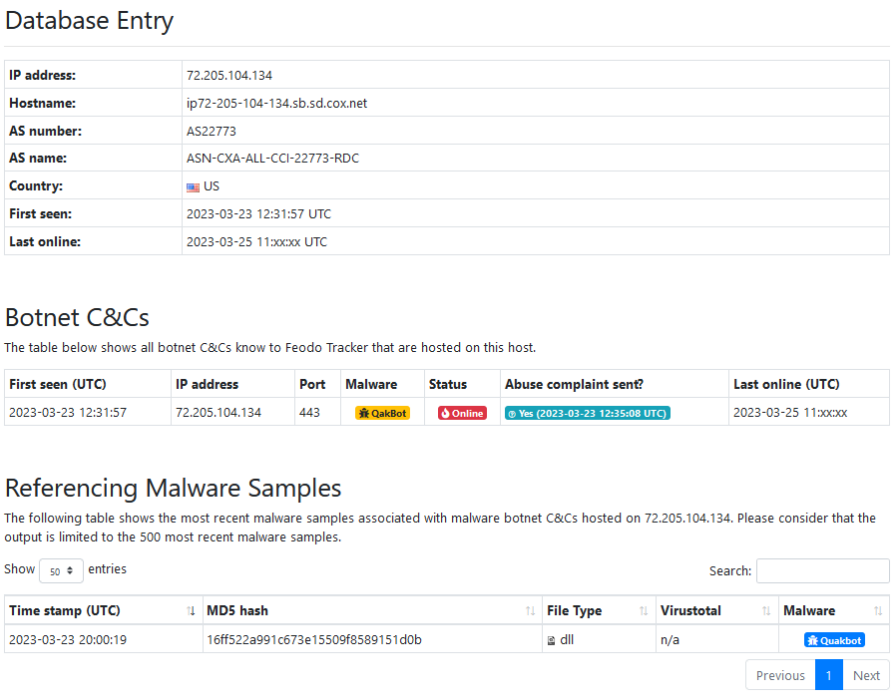
Search:

Firstseen (UTC)	Host	Malware	Status	Network (ASN)	Country
2023-03-24 17:25:40	192.236.146.147	BumbleBee	Offline	AS54290 HOSTWINDS	US
2023-03-24 16:31:44	151.65.229.12	QakBot	Offline	AS1267 ASN-WINDTRE IUNET	IT
2023-03-24 11:08:54	90.211.192.113	QakBot	Offline	AS5607 BSKYB-BROADBAND-AS	GB
2023-03-24 03:08:06	182.75.189.42	QakBot	Offline	AS9498 BBIL-AP BHARTI Airtel Ltd.	IN
2023-03-23 21:45:37	45.66.248.64	BumbleBee	Offline	AS62005 BV-EU-AS	US
2023-03-23 20:01:53	109.153.195.56	QakBot	Offline	AS2856 BT-UK-AS BTnet UK Regional network	GB
2023-03-23 19:11:56	109.154.254.126	QakBot	Offline	AS2856 BT-UK-AS BTnet UK Regional network	GB
2023-03-23 15:01:50	183.82.107.190	QakBot	Offline	AS18209 BEAMTELE-AS-AP Atria Convergence Technologies pvt ltd	IN
2023-03-23 14:41:50	209.216.123.118	QakBot	Offline	AS394710 TELMAX-INC	CA
2023-03-23 14:40:42	192.119.66.138	BumbleBee	Offline	AS54290 HOSTWINDS	US
2023-03-23 14:35:39	23.82.140.100	BumbleBee	Offline	AS393886 LEASEWEB-USA-MIA	US
2023-03-23 13:11:56	124.246.122.199	QakBot	Offline	AS4773 MOBILEONELTD-AS-AP MobileOne Ltd. MobileInternet Servi...	SG
2023-03-23 12:31:57	72.205.104.134	QakBot	Online	AS22773 ASN-CXA-ALL-CCI-22773-RDC	US
2023-03-23 12:31:57	72.134.124.16	QakBot	Online	AS20001 TWC-20001-PACWEST	US
2023-03-23 12:31:57	71.38.155.217	QakBot	Online	AS209 CENTURYLINK-US-LEGACY-QWEST	US

Imagen 38. Buscador de Feodo Tracker

Si accedemos a una de las direcciones IP nos podemos encontrar con diferentes tipos de información, como puede ser el hostname relacionado, el ASN, AS, país, fecha de primera y última vez de detección, familia de malware asociado y hash de un muestra, la cual,

podríamos investigar más a fondo con otras herramientas. En la Imagen 39 puede verse lo comentado.



Database Entry

IP address:	72.205.104.134
Hostname:	ip72-205-104-134.sb.sd.cox.net
AS number:	AS22773
AS name:	ASN-CXA-ALL-CCI-22773-RDC
Country:	US
First seen:	2023-03-23 12:31:57 UTC
Last online:	2023-03-25 11:xx:xx UTC

Botnet C&Cs

The table below shows all botnet C&Cs know to Feodo Tracker that are hosted on this host.

First seen (UTC)	IP address	Port	Malware	Status	Abuse complaint sent?	Last online (UTC)
2023-03-23 12:31:57	72.205.104.134	443	QakBot	Online	Yes (2023-03-23 12:35:08 UTC)	2023-03-25 11:xx:xx

Referencing Malware Samples

The following table shows the most recent malware samples associated with malware botnet C&Cs hosted on 72.205.104.134. Please consider that the output is limited to the 500 most recent malware samples.

Show 50 entries Search:

Time stamp (UTC)	MD5 hash	File Type	Virustotal	Malware
2023-03-23 20:00:19	16ff522a991c673e15509f8589151d0b	dll	n/a	Quakbot

Previous 1 Next

Imagen 39. Información de un C&C concreto en Feodo Tracker

Por otro lado, Feodo Tracker cuenta con listas de bloqueo (blocklist) que pueden ser utilizadas para bloquear cualquier acceso de dichos C&C con nuestra infraestructura corporativa. En la Imagen 40 puede verse que Feodo Tracker comparte una serie de blocklist de direcciones IP, IoC y reglas para Suricata asociadas a C2 de botnets. El enlace está disponible aquí: https://feodotracker.abuse.ch/blocklist/.

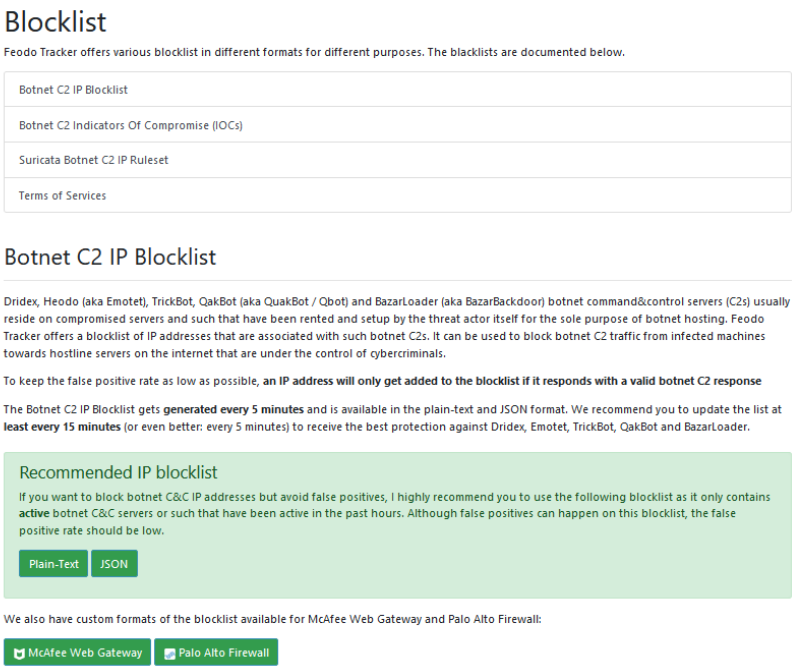


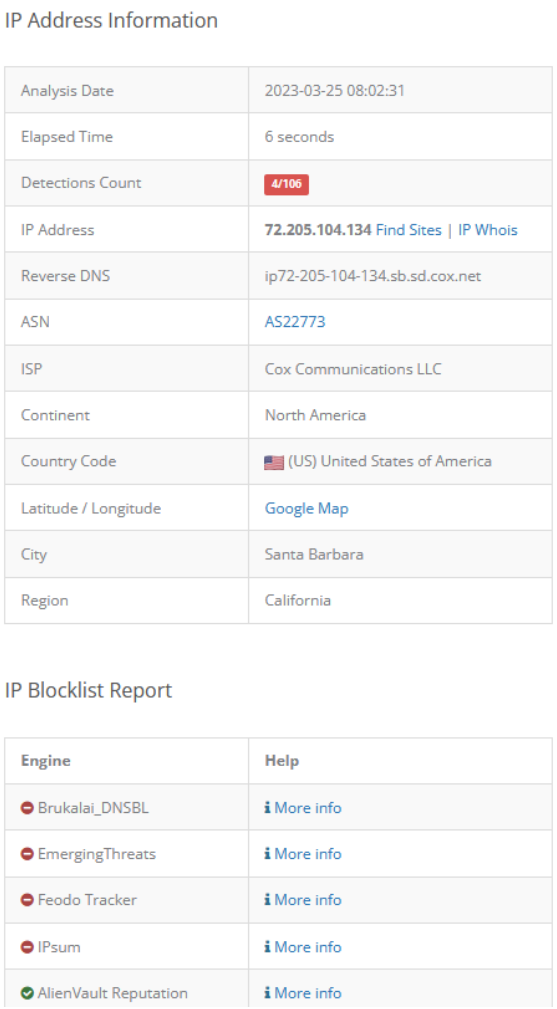
Imagen 40. Blocklist ofrecidas por Feodo Tracker

1.1.14. IP BLACKLIST CHECK

IP Blacklist Check es una herramienta ofrecida por el servicio online IPVOID que permite comprobar si una dirección IP está involucrada en incidentes de malware o actividades de spam. Para cumplir con su objetivo realiza diferentes peticiones hacia distintas DNSBL[2] y servicios de reputación de IP. El enlace de acceso es el siguiente: https://www.ipvoid.com/ip-blacklist-check/.

En la Imagen 41 vemos una consulta realizada a la dirección IP vista en la Imagen 39 relacionada con la botnet QuakBot, donde obtenemos información sobre el ASN, geolocalización, ISP y un conteo de coincidencias con servicios online de blocklist, entre ellos el de Feodo Tracker visto anteriormente.

[2] DNSBL: Lista negra basada en DNS relacionadas con campañas de SPAM



IP Address Information

Analysis Date	2023-03-25 08:02:31
Elapsed Time	6 seconds
Detections Count	4/106
IP Address	**72.205.104.134** Find Sites | IP Whois
Reverse DNS	ip72-205-104-134.sb.sd.cox.net
ASN	AS22773
ISP	Cox Communications LLC
Continent	North America
Country Code	(US) United States of America
Latitude / Longitude	Google Map
City	Santa Barbara
Region	California

IP Blocklist Report

Engine	Help
Brukalai_DNSBL	More info
EmergingThreats	More info
Feodo Tracker	More info
IPsum	More info
AlienVault Reputation	More info

Imagen 41. Información sobre una IP relacionada con un C2 consultado desde IP Blacklist Check

1.1.15. BLACKLIST - MXTOOLBOX

Blacklist es una herramienta ofrecida por el servicio online MXToolbox que permite analizar si una dirección IP está relacionada con campañas de spam, consultando un total de 100 blacklist sobre DNSBL. El enlace de acceso es el siguiente: https://mxtoolbox.com/blacklists.aspx

En la Imagen 42 vemos una consulta realizada a la dirección IP 71.38.155[.]217, donde únicamente localizamos en la blacklist donde está presente, siendo en este caso SORBS y Spamhaus.

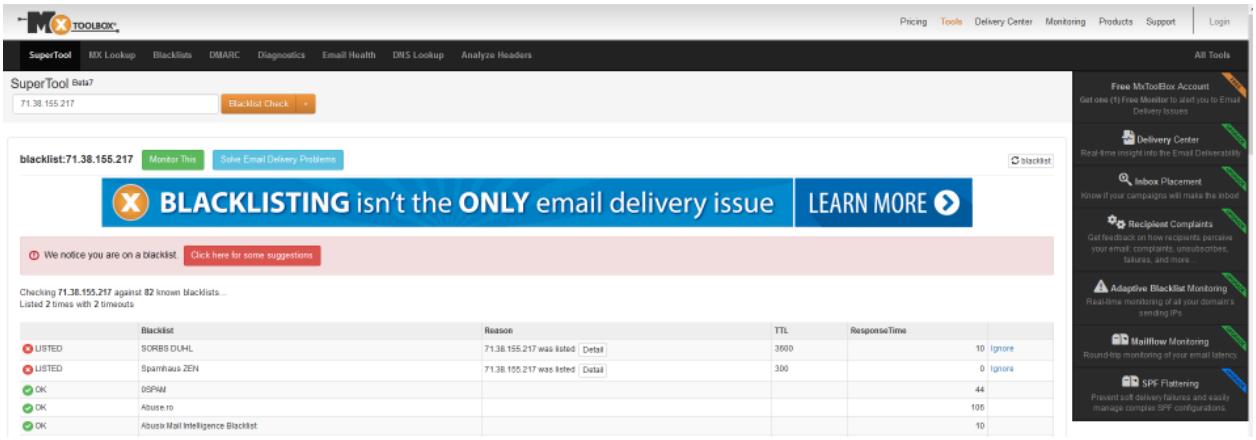


Imagen 42. Resultados de búsqueda de una IP en Blacklist de MXToolbox

1.1.16. ABUSEIPDB

AbuseIPDB es un servicio gratuito que permite comprobar si una dirección IP está relacionada con algún tipo de actividad maliciosa con el objetivo de añadirla en listas de bloqueo. El enlace de acceso es el siguiente: https://www.abuseipdb.com.

En la Imagen 43 vemos una consulta realizada a la dirección IP vista en la Imagen 39 relacionada con la botnet QuakBot, donde obtenemos el porcentaje de aparición dentro de la base de datos de AbuseIPDB (siendo un 3%), el ISP, país y ciudad asociados a la IP, hostname y una coincidencia con un informe adjunto donde se añade un comentario indicando que la dirección IP ha sido añadida dentro de la base de datos de ThreatFox IOC de Abuse.ch. Esto último hace referencia a una base de datos pública sobre Indicadores de Compromiso que podéis encontrar aquí: https://threatfox.abuse.ch/browse/.

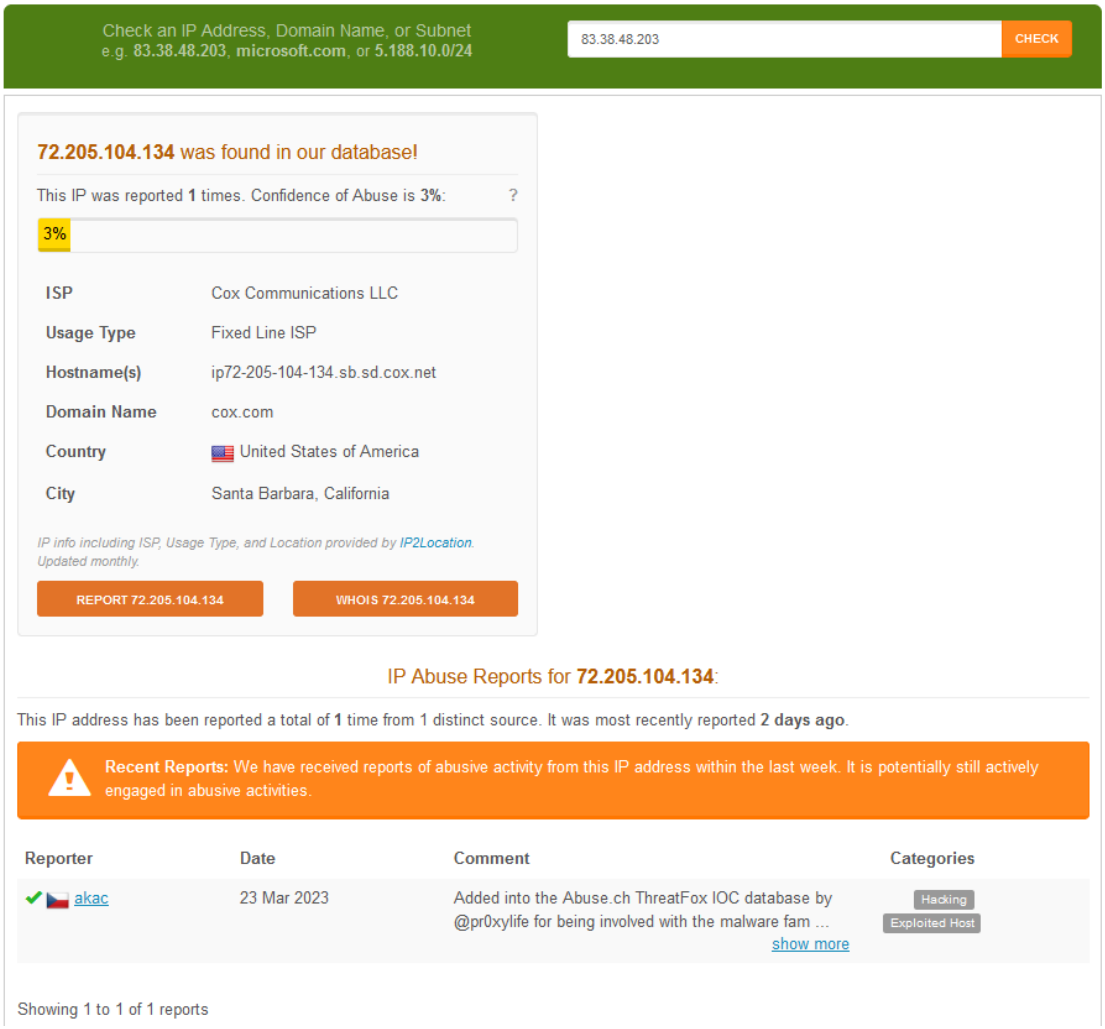


Imagen 43. Resultados de búsqueda sobre una dirección IP maliciosa en AbuseIPDB

1.1.17. WEBMII

Webmii es una herramienta online que permite realizar una búsqueda sobre un nombre de persona a partir del nombre y los apellidos, permitiendo así obtener información relacionada con redes sociales o la presencia del objetivo en cualquier foro, prensa digital, blog, etc. El enlace de acceso es el siguiente: https://webmii.com.

En la Imagen 44 puede verse el sitio oficial de Webmii y en la Imagen 45 los resultados sobre un objetivo marcado (en este caso mi nombre y apellidos), facilitando además un score de la cuenta.



Imagen 44. Sitio web oficial de Webmii

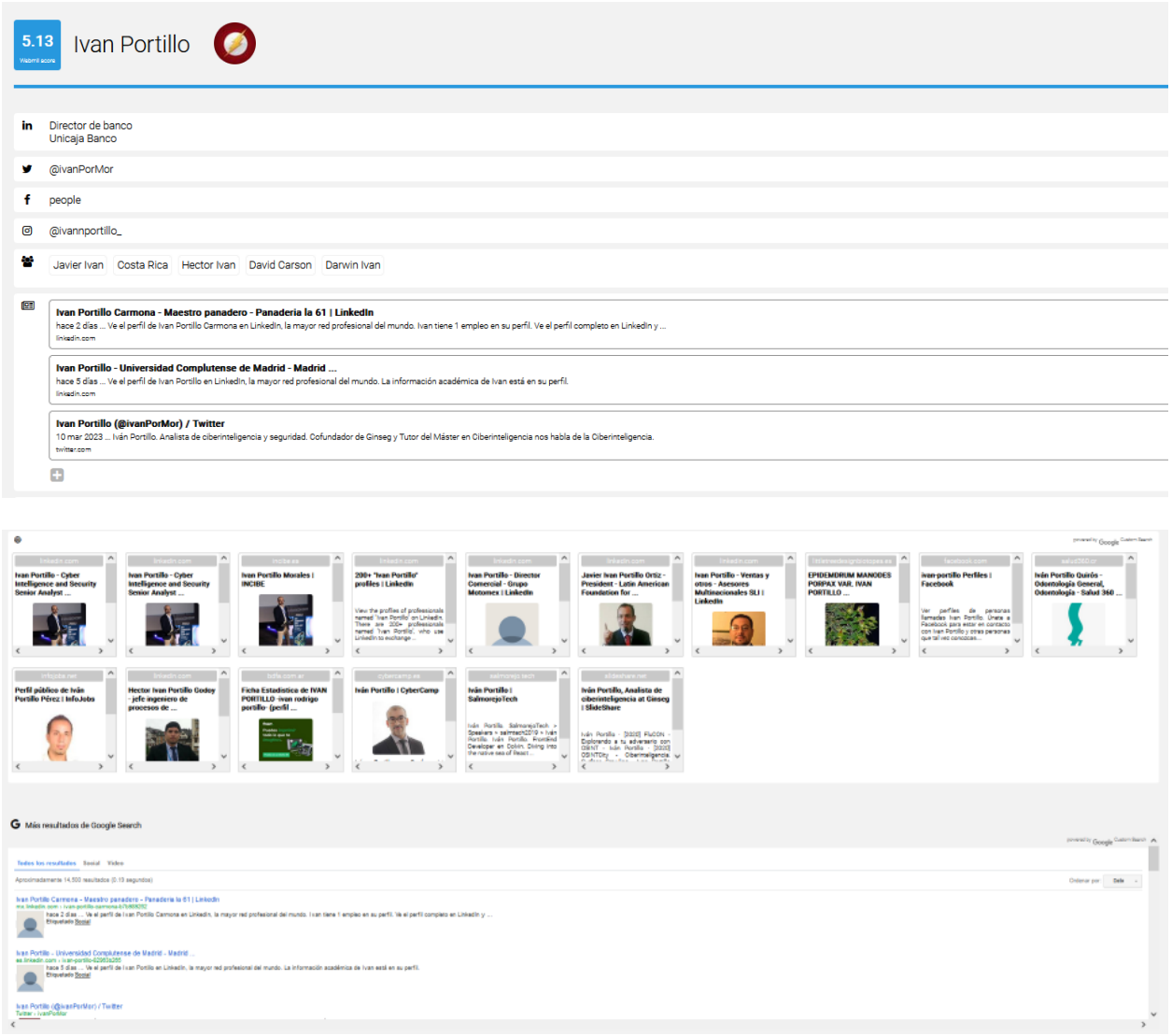


Imagen 45. Resultados de un objetivo con Webmii

1.1.18. INTELLIGENCEX

IntelligenceX ofrece un repositorio donde consultar datos relacionados sobre fugas de información, dominios, correos electrónicos, direcciones IP, usernames, VINs, hashes, números de teléfono, perfiles sociales, etc. Se trata de una herramienta de pago pero que permite acceder de manera gratuita a parte de su contenido. El enlace de acceso es el siguiente: https://intelx.io/

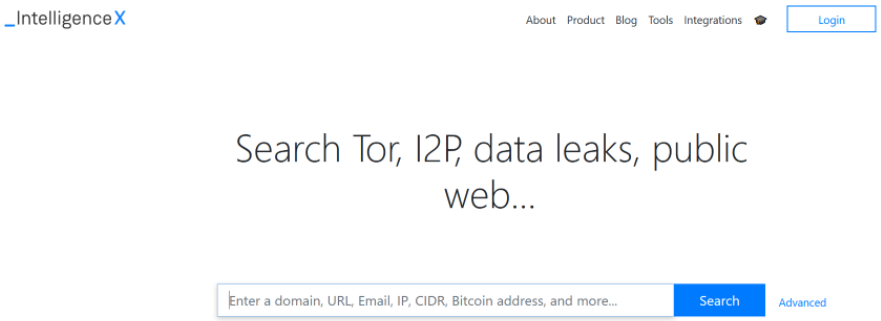


Imagen 46. Sitio web oficial de IntelligenceX

IntelligenceX permite realizar las búsquedas mediante buckets que son conjuntos de datos que tienen una categoría común, siendo posible ejecutar aquellas según necesidad. Estos buckets engloban todo tipo de colecciones, desde sitios pastes y enlaces ".onion" hasta whois de un dominio. En la Imagen 47 puede verse el resto de buckets que permite buscar la herramienta.

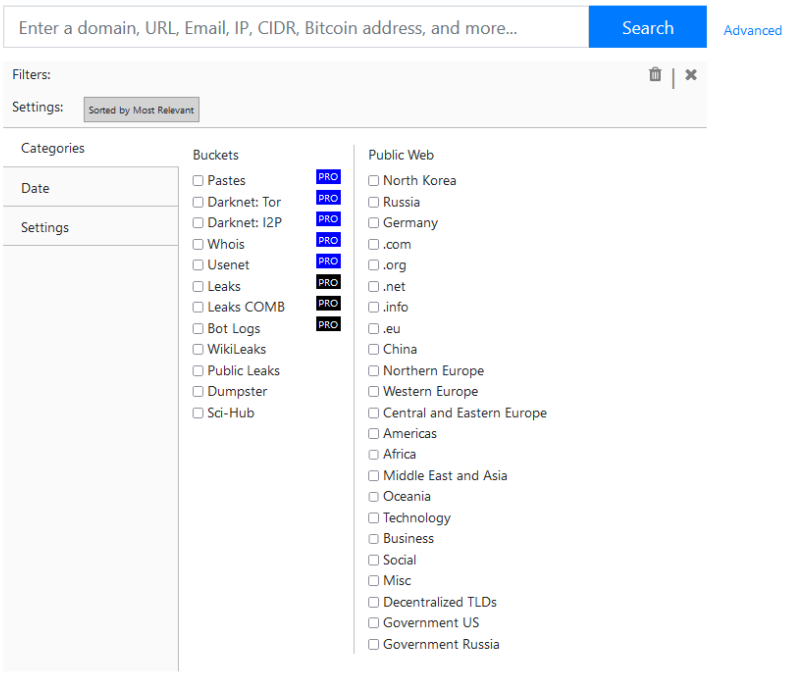


Imagen 47. Filtros de búsqueda de IntelligenceX

Realizando una búsqueda del dominio objetivo (marca.com) obtenemos la volumetría de datos que puede verse en la Imagen 48.

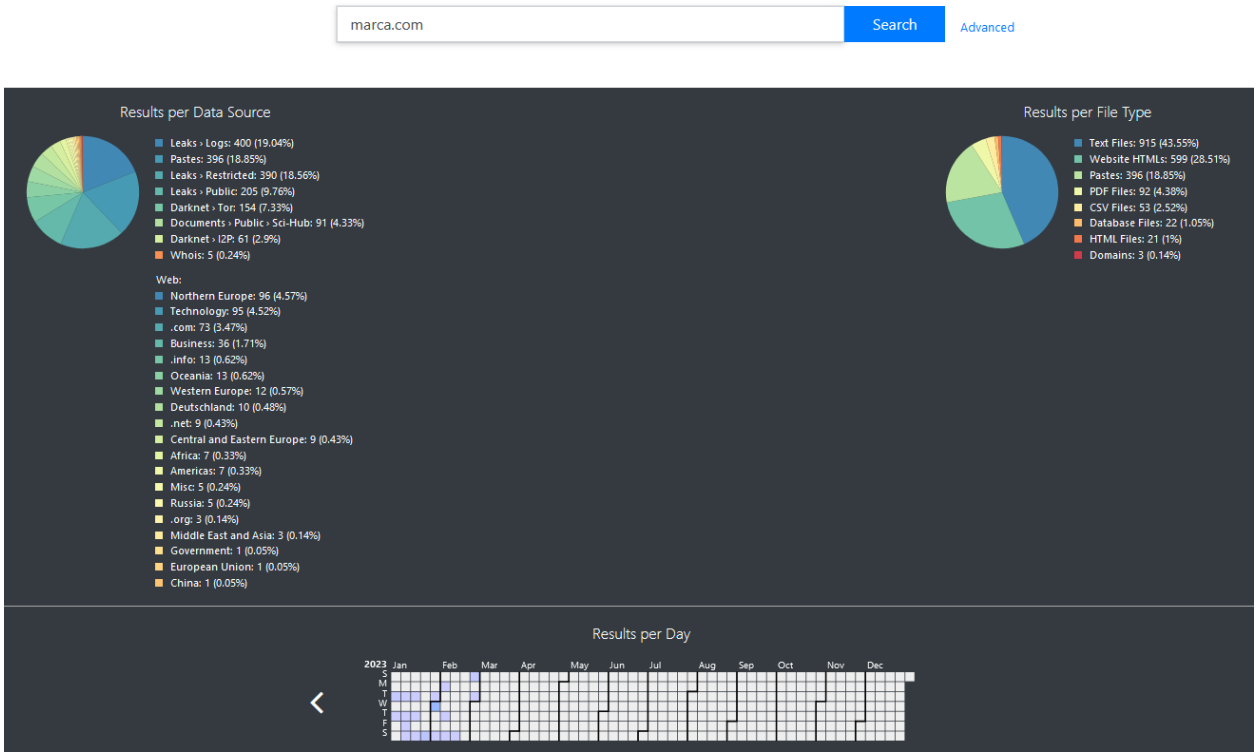


Imagen 48. Volumetría de datos obtenidos del dominio objetivo

1.1.19. THEHARVESTER

TheHarvester es una herramienta de línea de comando que permite recopilar información sobre un objetivo de manera pasiva, usando los motores de búsquedas de Bing, Google, Yahoo, Baidu y Shodan, entre otros. Se pueden obtener correos electrónicos, subdominios, IPs, nombre de perfiles de usuario en redes sociales, URLs de Trello, etc. En la Imagen 49 pueden verse todas las opciones de configuración para la ejecución de la herramienta.

Instalación:
git clone https://github.com/laramies/theHarvester
cd theHarvester
pip3 install -r requirements/base.txt

Ejecución:
python3 theHarvester.py -d marca.com -l 300 -b all



Imagen 49. Opciones de ejecución de TheHarvester

Realizando una búsqueda del dominio objetivo (marca.com) obtenemos diferentes tipos de datos como por ejemplo direcciones IP, dominios, correos electrónicos, hosts, etc. Un ejemplo de ello puede verse en la Imagen 50.

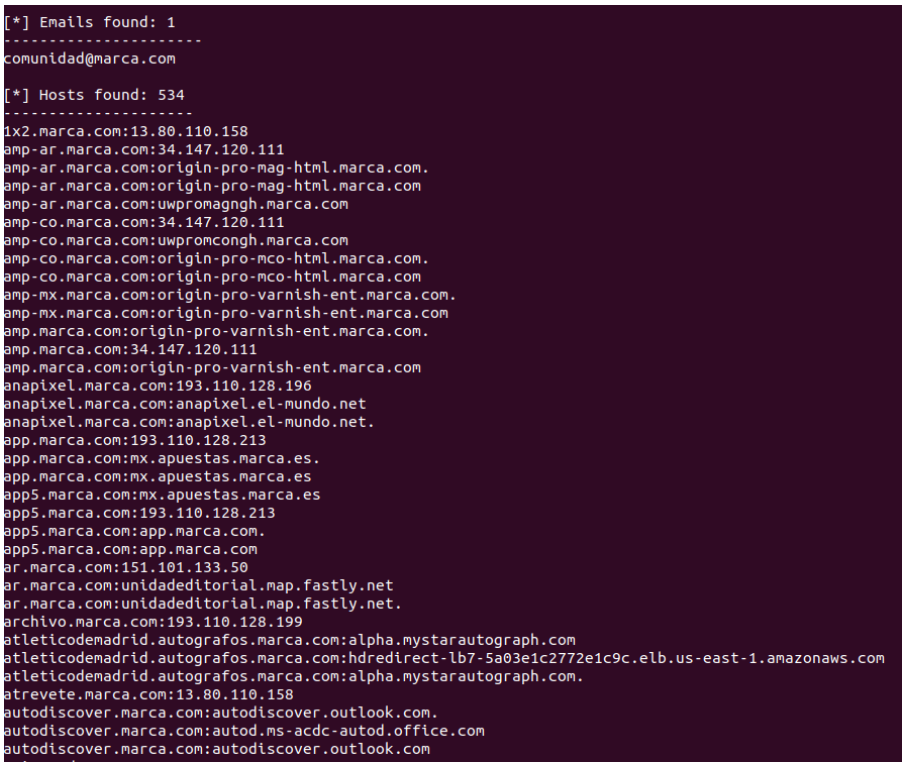


Imagen 50. Resultados de TheHarvester

1.1.20. CROSSLINKED

Crosslinked es una herramienta de línea de comando que permite obtener un listado de correos electrónicos localizados mediante fuentes públicas a partir de un formato de correo electrónico asociado a un dominio.

Instalación:
git clone https://github.com/m8r0wn/crosslinked
cd crosslinked
pip3 install -r requirements.txt

Ejecución:
python3 crosslinked.py -f '{first}.{last}@marca.com' marca

Realizando una búsqueda del dominio objetivo (marca.com) obtenemos un listado de correos electrónicos asociados al dominio. En la Imagen 51 puede verse lo mencionado.

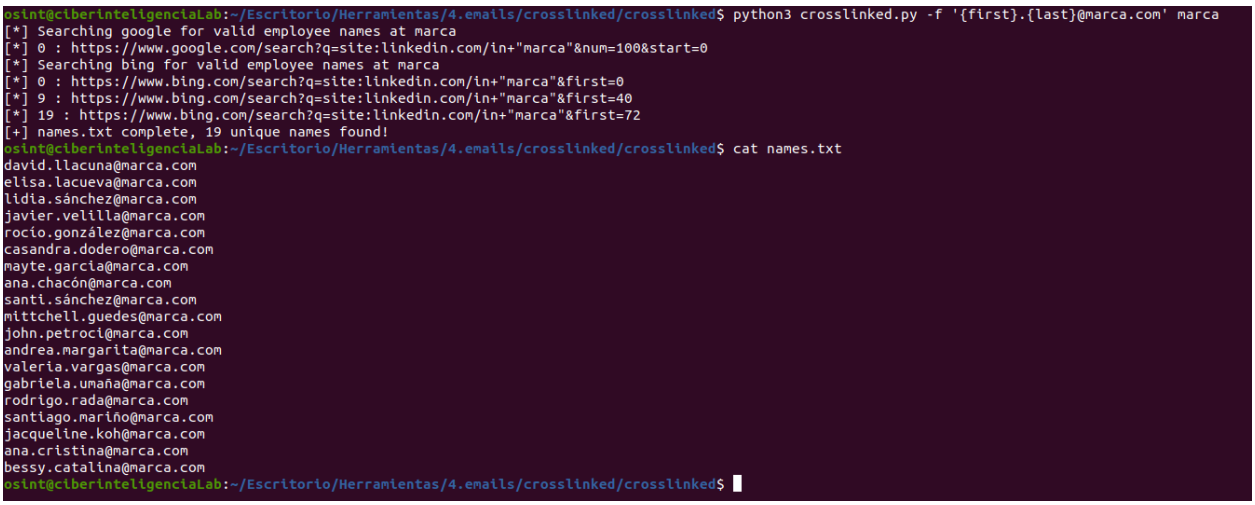


Imagen 51. Resultados de crosslinked

1.1.21. MALTEGO

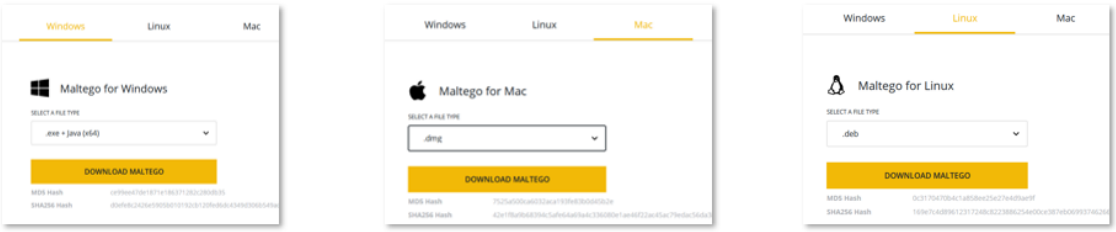
Maltego es una herramienta que recopila información a partir de diferentes fuentes, tanto gratuitas como de pago, mostrándolas en forma de grafos, siendo de gran ayuda en el análisis posterior por los equipos de Inteligencia y forense.

Contiene una serie de módulos de aplicaciones externas que complementan su potencial, además de una sencilla integración con APIs de distintas fuentes de información.



La vista en grafos permite abstraerse de la propia recopilación de la información independientemente de la fuente de donde se busque. Maltego nos ayudará a analizar la información mediante nodos con identidad única y las relaciones existentes con otros nodos de datos.

Maltego está disponible para las plataformas de Windows, Linux y Mac. En cada una de ellas es necesario tener instalado Java. Para la versión de Windows se dispone de una opción para descargar e instalar Maltego y Java juntos. Para Linux habría que descargarlo y ejecutar sudo dpkg -i Maltego.v4.x.deb.



Para poder utilizar la versión gratuita es necesario registrarse en Maltego Community Edition (CE) por medio del siguiente enlace: https://login.maltego.com/registration.

La primera vez que se ejecute Maltego preguntará que versión se desea utilizar, en nuestro caso Maltego CE. Posteriormente, se deberá utilizar la cuenta recién creada y loguearse con la misma.

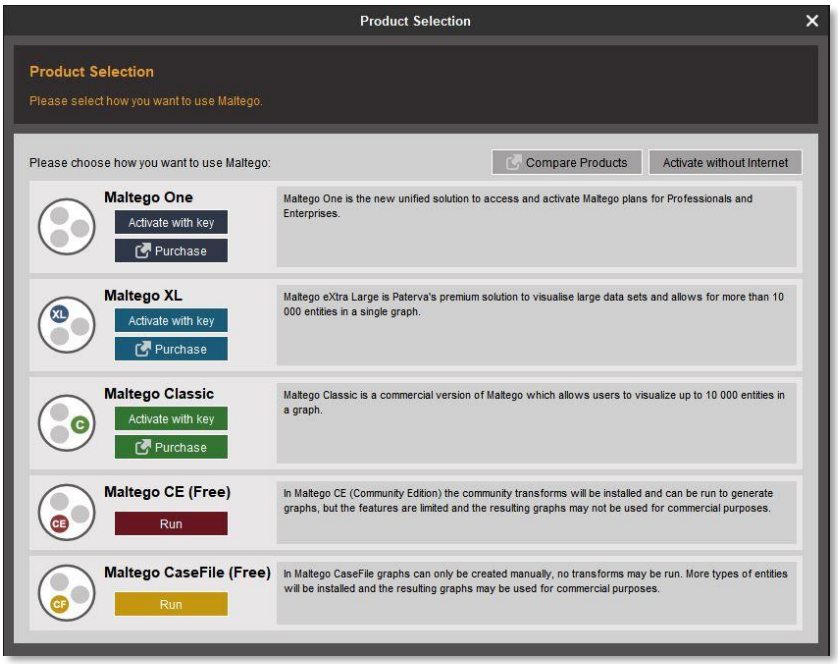
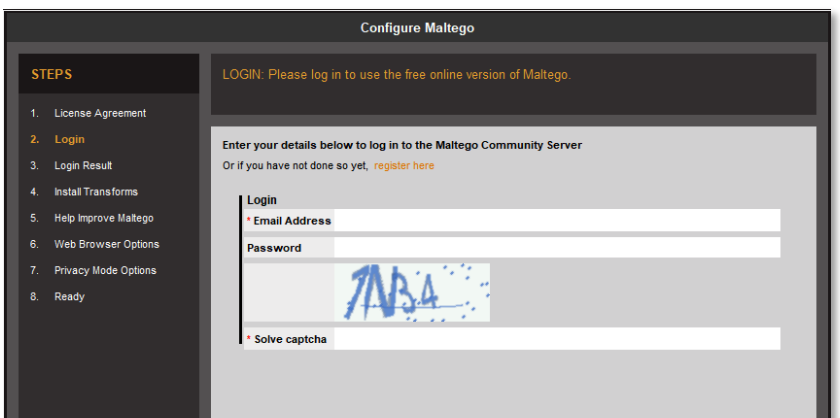


Imagen 53. Elección del producto de Maltego a utilizar



Maltego tiene una serie de transformadas que hacen referencia a un conjunto de operaciones que permiten realizar cualquier tipo de acción con una entidad, consultando diversas fuentes conectadas al propio Maltego. En la Imagen 54 se pueden ver algunas de las fuentes que Maltego tiene preconfiguradas para su uso.

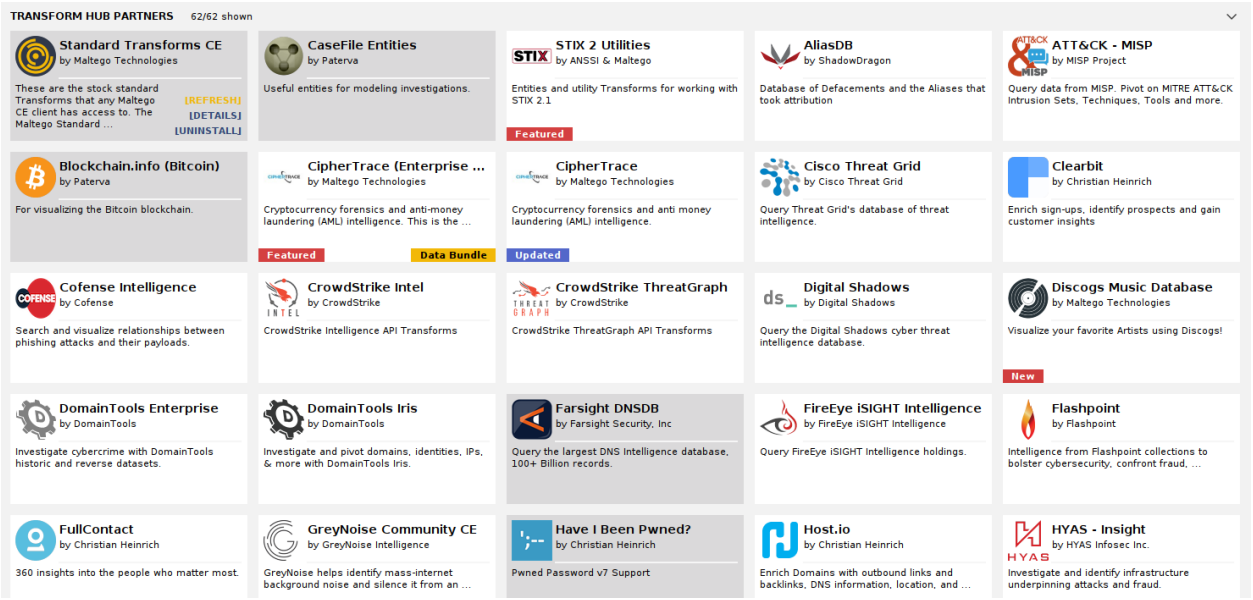


Imagen 54. Transformadas de Maltego

Para poder trabajar con cada fuente será necesario disponer de una API, donde podremos integrarla fácilmente dentro de Maltego para poder consumir los datos recibidos de cada fuente. En la Imagen 55 se puede observar el asistente típico de Maltego para integrar las fuentes, en este caso de Shodan. Por medio de esta integración seremos capaces de acceder a Shodan para consultar diversos datos por medio de sus transformadas.

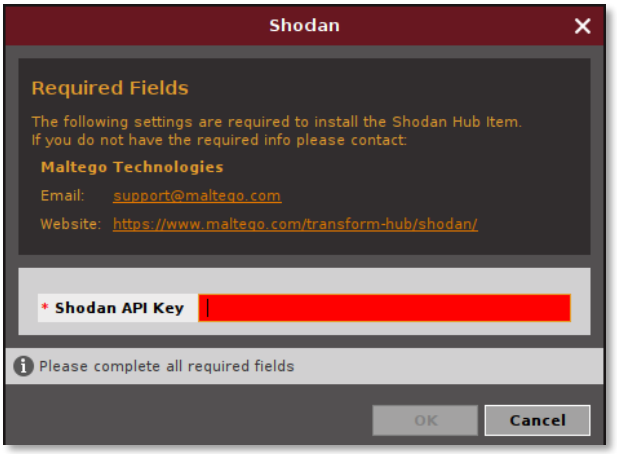


Imagen 55. Integración de Shodan con Maltego mediante su API

La ejecución de las transformadas tiene tres niveles, siendo los siguientes:

- **Nivel superior de transformadas**. En dicho nivel es donde se listan los diferentes elementos instalados dentro del *Transform Hub* a nivel general cuando desplegamos el menú de transformadas. En la Imagen 56 puede verse un resumen de que es cada elemento.

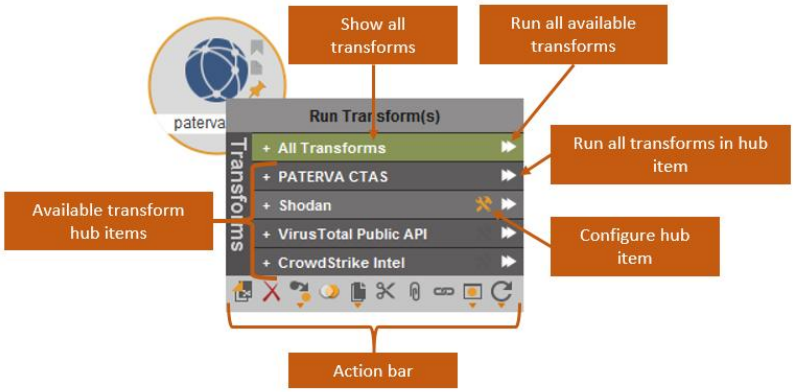


Imagen 56. Nivel superior de transformadas

- **Segundo nivel de transformadas**. Haciendo clic con el botón izquierdo del ratón en un elemento del *Transform Hub* se accede al nivel del conjunto. Dentro de este nivel disponemos de las transformadas a nivel general y agrupadas por categorías de transformadas que realicen tareas similares. En la Imagen 57 puede verse un resumen de que es cada elemento.

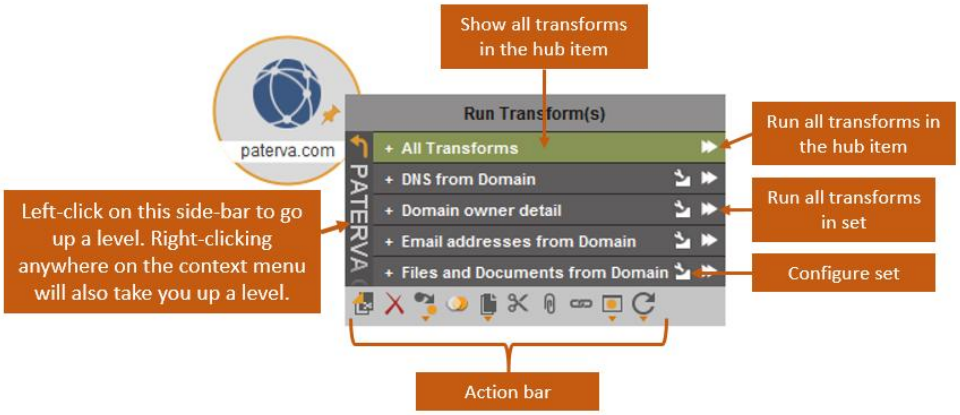


Imagen 57. Segundo nivel de transformadas

- **Último nivel de transformadas**. En este nivel finalmente es donde se ejecutan las transformadas a un nivel mucho más individual utilizando una fuente o una tarea concreta. En la Imagen 58 puede verse un resumen de que es cada elemento.

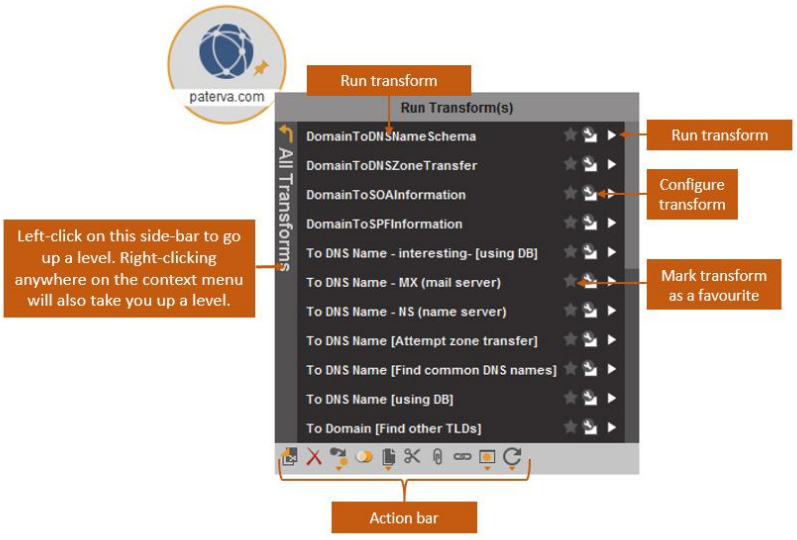


Imagen 58. Último nivel de transformadas

Maltego nos permite investigar diferentes tipos de datos y sus relaciones, las más importantes son las siguientes:

- Criptomonedas (Bitcoins y Ethereum)

- Dispositivos
- Eventos (conversaciones por correo electrónico o teléfono, línea de tiempo, incidente, reuniones)
- Grupos (criminales, instituciones educativas, grupos online o religiosos, organizaciones, movimientos políticos)
- Infraestructura (direcciones IP, rango IP, AS, banners, dominios, ISP, URL, sitios web, certificados SSL)
- Localizaciones (aeropuertos, estaciones de tren, iglesias, ciudad, país, región, escenas de crímenes, prisiones, punto GPS, tiendas)
- Malware (Hashes)
- Personas (correo electrónico, username, documentos, imágenes, nombre de persona, teléfono, etc)
- Redes Sociales (tweet o hashtag, afiliación a Facebook o LinkedIn)
- Tracking (cuenta bancaria, número de vuelo, DNI, número de pasaporte, vehículos)

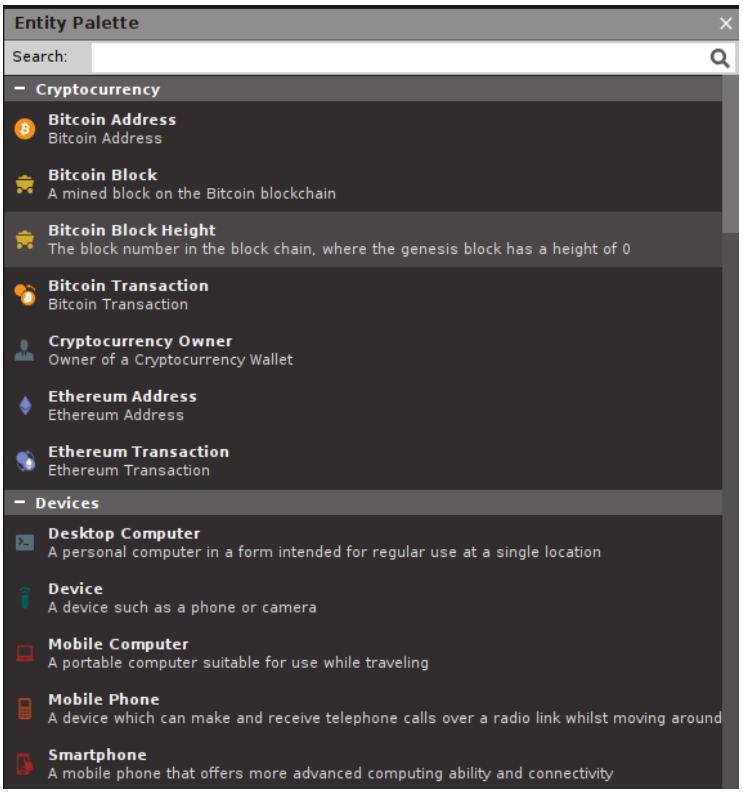


Imagen 59. Paleta de diferentes entidades para poder investigar en Maltego

En la Imagen 60 puede verse un ejemplo generado con Maltego. Además, parte de la investigación realizada en la sección 6.1.5 fue realizada con Maltego.

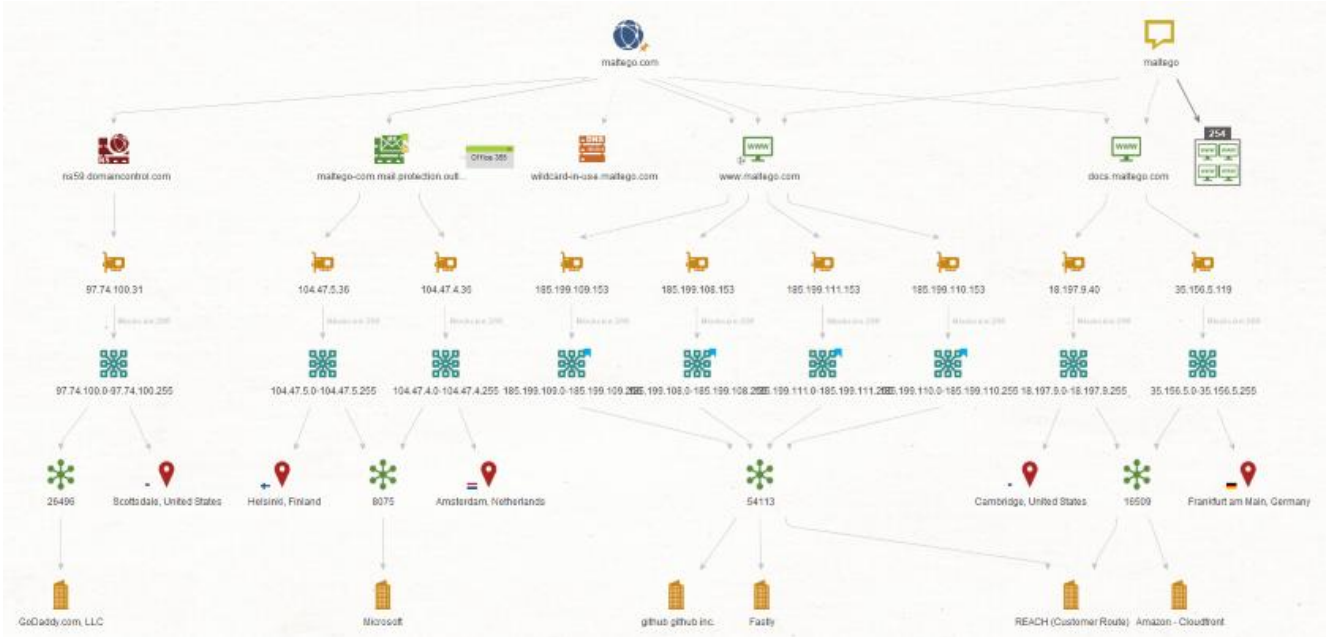


Imagen 60. Representación gráfica de resultados con Maltego

En el siguiente enlace se dispone de toda la documentación oficial de Maltego: https://docs.maltego.com/support/solutions/articles/15000008703.

1.1.22. INSTALOADER

Instaloader es una herramienta de línea de comando que permite recopilar datos asociados a un perfil público de Instagram como por ejemplo imágenes publicadas, mensajes, hashtags, stories, etc.

Instalación:
pip3 install instaloader

Ejecución:
• instaloader "#osint" → Descargar todas las coincidencias con #osint
• instaloader username → Descargar todas las imágenes e información asociada del perfil especificado.
• Instaloader @username → Descargar información sobre los perfiles seguidos por el perfil especificado.

En la Imagen 61 se ejecuta la herramienta para recolectar información sobre el hashtag osint.

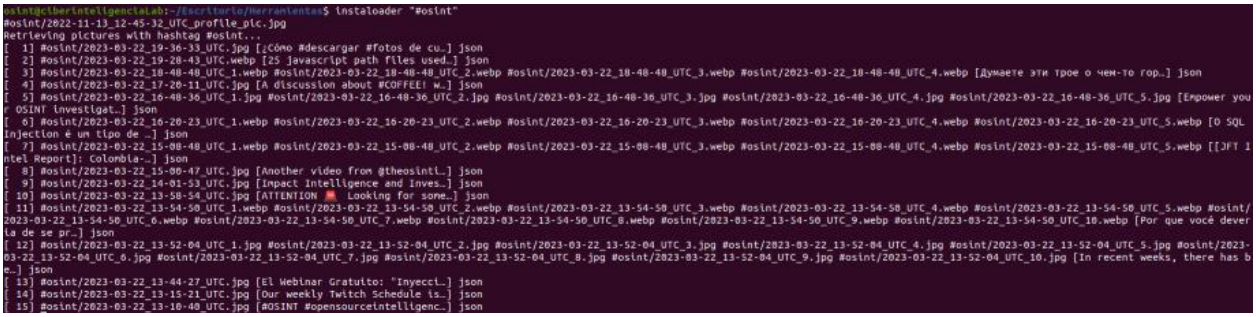


Imagen 61. Ejecución de instaloader

La herramienta descargará una copia de la imagen asociado al mensaje, el texto extraído del mensaje y el JSON original del mensaje, tal como puede observarse en la Imagen 62.

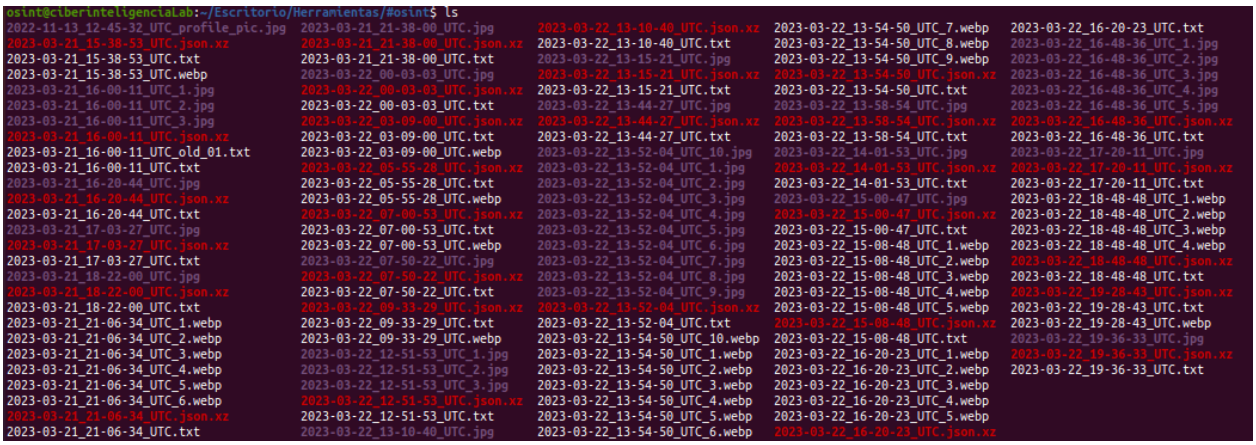


Imagen 62. Directorio de ficheros generados por instaloader

Si deseamos leer el contenido del fichero JSON, tan solo tendremos que descomprimirlo y filtrarlo con el comando "**jq**" para darle un formato legible (ver Imagen 63).



Imagen 63. Visualización de uno de los JSON generado por Instaloader

1.1.23. NAMECHK

Herramienta online que permite realizar búsquedas de un nombre de usuario en todas las redes sociales y comprobar si existen coincidencias. El enlace de acceso a la herramienta es la siguiente: https://namechk.com.

Tal como se puede ver en la Imagen 64, podemos detectar coincidencias de si el usuario ya cuenta con un perfil social en alguna red. Aquellas losetas que estén sombreadas indican que ya existe un perfil social con dicho nombre de usuario, por el contrario las de color verde indican que no existe coincidencia.

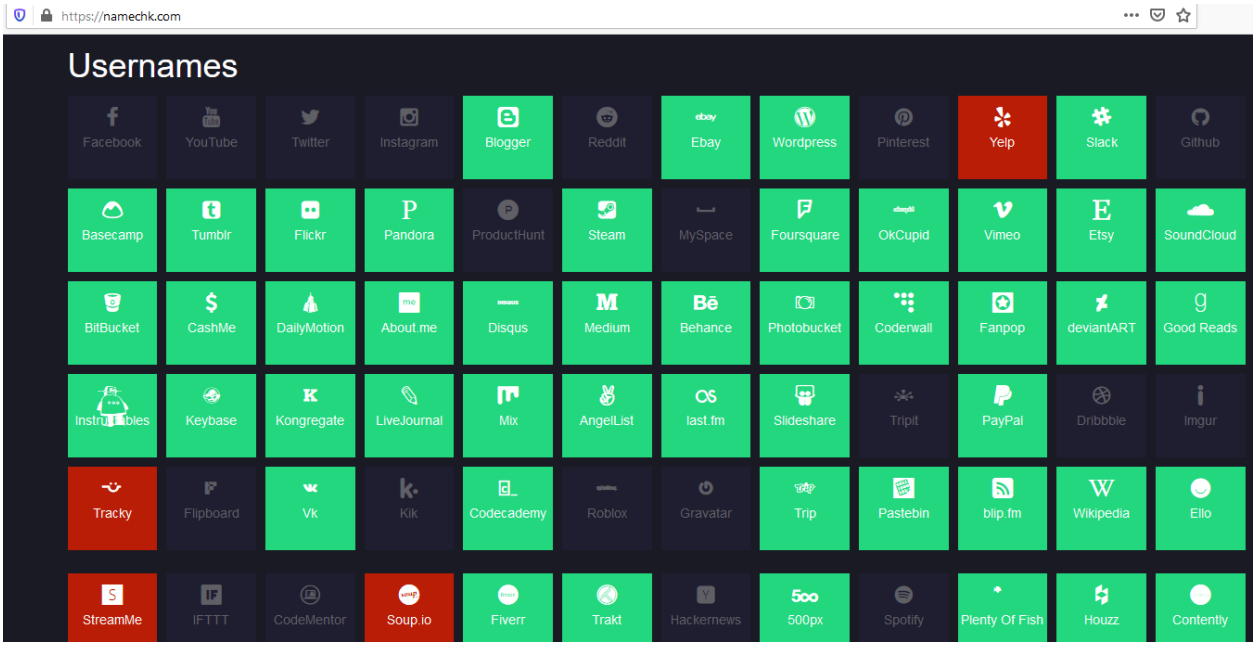


Imagen 64. Resultados ofrecidos por Namechk

1.1.24. OSRFRAMEWORK

Herramienta por línea de comando que permite obtener resultados sobre posibles perfiles sociales según una búsqueda a partir de un username, correo electrónico o nombre de persona. El enlace de acceso es el siguiente: www.github.com/i3visio/osrframework.

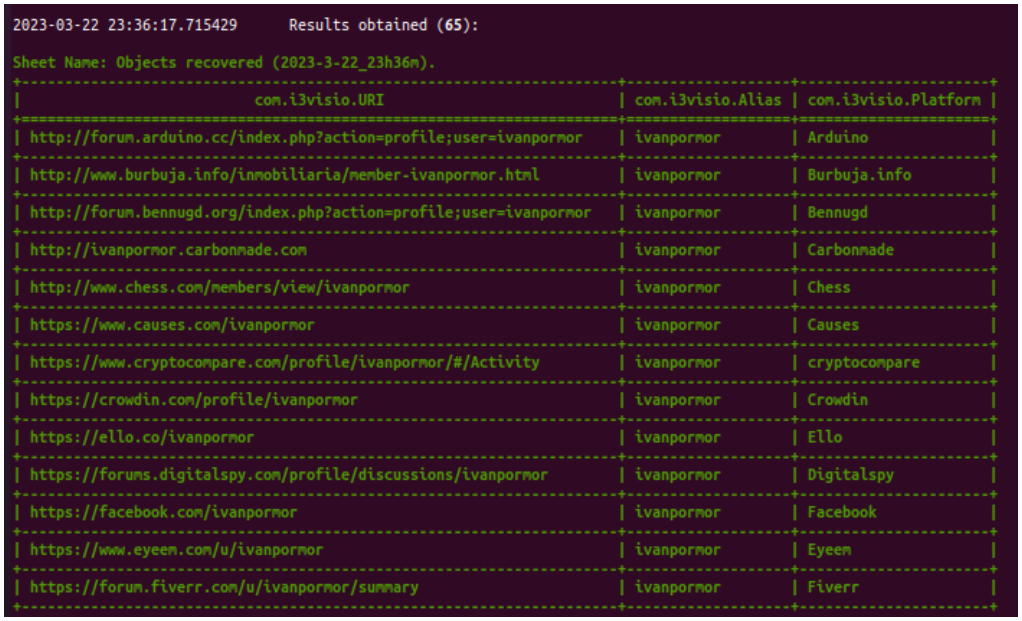
Instalación:
pip3 install osrframework

OSRFramework está compuesto por un conjunto de herramientas siendo las siguientes:

- **Usufy**. Permite verificar la existencia de un username en un total de 306 plataformas.

Comando: usufy -n "username" -p all

En la Imagen 65 pueden visualizarse los resultados generados por la ejecución de la herramienta, donde se ha partido del nombre de usuario "ivanpormor" con el objetivo de detectar la existencia del mismo usuario en otras plataformas sociales.



2023-03-22 23:36:17.715429 Results obtained (65):

Sheet Name: Objects recovered (2023-3-22_23h36m).

com.i3visio.URI	com.i3visio.Alias	com.i3visio.Platform
http://forum.arduino.cc/index.php?action=profile;user=ivanpormor	ivanpormor	Arduino
http://www.burbuja.info/inmobiliaria/member-ivanpormor.html	ivanpormor	Burbuja.info
http://forum.bennugd.org/index.php?action=profile;user=ivanpormor	ivanpormor	Bennugd
http://ivanpormor.carbonmade.com	ivanpormor	Carbonmade
http://www.chess.com/members/view/ivanpormor	ivanpormor	Chess
https://www.causes.com/ivanpormor	ivanpormor	Causes
https://www.cryptocompare.com/profile/ivanpormor/#/Activity	ivanpormor	cryptocompare
https://crowdin.com/profile/ivanpormor	ivanpormor	Crowdin
https://ello.co/ivanpormor	ivanpormor	Ello
https://forums.digitalspy.com/profile/discussions/ivanpormor	ivanpormor	Digitalspy
https://facebook.com/ivanpormor	ivanpormor	Facebook
https://www.eyeem.com/u/ivanpormor	ivanpormor	Eyeem
https://forum.fiverr.com/u/ivanpormor/summary	ivanpormor	Fiverr

Imagen 65. Resultados de usufy

- **Mailfy**. Permite verificar si un correo electrónico está siendo utilizado en las siguientes 5 plataformas sociales (Infojobs, Instagram, Twitter, KeyServerUbuntu y OkCupid) y comprobará si el mismo está presente en alguna fuga de información o exposición en alguna fuente compartida.

Comando: mailfy -m correo

Además, la herramienta permite utilizar un nombre de usuario, realizar una combinatoria con diferentes servidores de correo electrónico y comprobar si existe alguna coincidencia de este en alguna fuga de información o exposición en alguna fuente compartida.

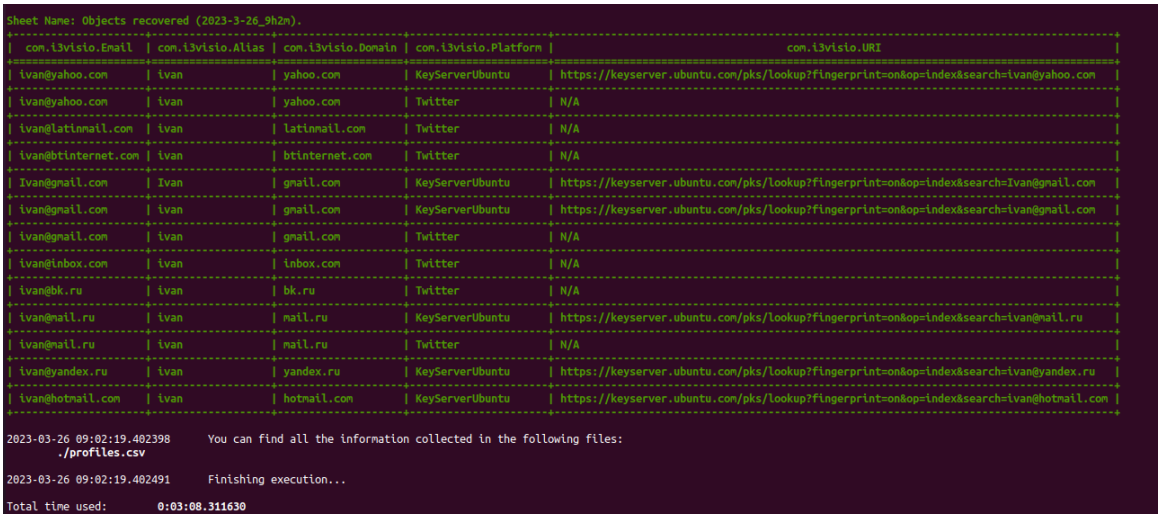
Comando: mailfy -n username -d all

En la Imagen 66 puede verse como la herramienta va realizando combinaciones entre el username facilitado (ivan) y un listado de proveedores de correo, acto seguido comprobará si el correo electrónico existe o no.



Imagen 66. Ejecución de la herramienta mailfy

En la Imagen 67 puede visualizarse el resultado de la ejecución lanzada en la Imagen 69, en el cual, se obtiene un listado de correos electrónicos, la red social donde está asociado el mismo y en algunos casos una URL de referencia.



Sheet Name: Objects recovered (2023-3-26_9h2m).

com.i3visio.Email	com.i3visio.Alias	com.i3visio.Domain	com.i3visio.Platform	com.i3visio.URI
ivan@yahoo.com	ivan	yahoo.com	KeyServerUbuntu	https://keyserver.ubuntu.com/pks/lookup?fingerprint=on&op=index&search=ivan@yahoo.com
ivan@yahoo.com	ivan	yahoo.com	Twitter	N/A
ivan@latinmail.com	ivan	latinmail.com	Twitter	N/A
ivan@btinternet.com	ivan	btinternet.com	Twitter	N/A
Ivan@gmail.com	Ivan	gmail.com	KeyServerUbuntu	https://keyserver.ubuntu.com/pks/lookup?fingerprint=on&op=index&search=Ivan@gmail.com
ivan@gmail.com	ivan	gmail.com	KeyServerUbuntu	https://keyserver.ubuntu.com/pks/lookup?fingerprint=on&op=index&search=ivan@gmail.com
ivan@gmail.com	ivan	gmail.com	Twitter	N/A
ivan@inbox.com	ivan	inbox.com	Twitter	N/A
ivan@bk.ru	ivan	bk.ru	Twitter	N/A
ivan@mail.ru	ivan	mail.ru	KeyServerUbuntu	https://keyserver.ubuntu.com/pks/lookup?fingerprint=on&op=index&search=ivan@mail.ru
ivan@mail.ru	ivan	mail.ru	Twitter	N/A
ivan@yandex.ru	ivan	yandex.ru	KeyServerUbuntu	https://keyserver.ubuntu.com/pks/lookup?fingerprint=on&op=index&search=ivan@yandex.ru
ivan@hotmail.com	ivan	hotmail.com	KeyServerUbuntu	https://keyserver.ubuntu.com/pks/lookup?fingerprint=on&op=index&search=ivan@hotmail.com

2023-03-26 09:02:19.402398 You can find all the information collected in the following files:
./profiles.csv

2023-03-26 09:02:19.402491 Finishing execution...

Total time used: 0:03:08.311630

Imagen 67. Resultados de la herramienta mailfy

- **Searchfy**. Permite verificar la existencia de perfiles en redes sociales a través del nombre completo de una persona.

Comando: searchfy -q “nombre persona”

En la Imagen 68 pueden visualizarse los resultados generados por la ejecución de la herramienta, donde se ha partido del nombre de persona “ivan portillo” con el objetivo de detectar si dicho nombre completo está presente en alguna red social.

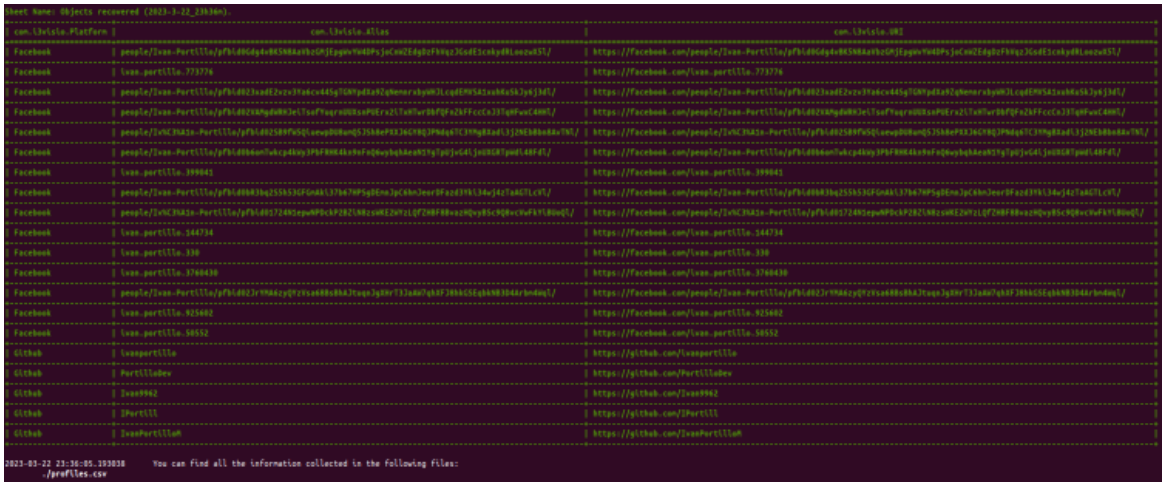


Imagen 68. Resultado de searchfy

- **alias_generator**. Permite generar un listado de posibles nombres de usuario partiendo de una serie de datos que solicita la herramienta.

Comando: alias_generator

En la Imagen 69 puede visualizarse la ejecución de la herramienta, donde nos solicita información sobre el nombre, apellidos, un año de lo que deseemos, ciudad y país.

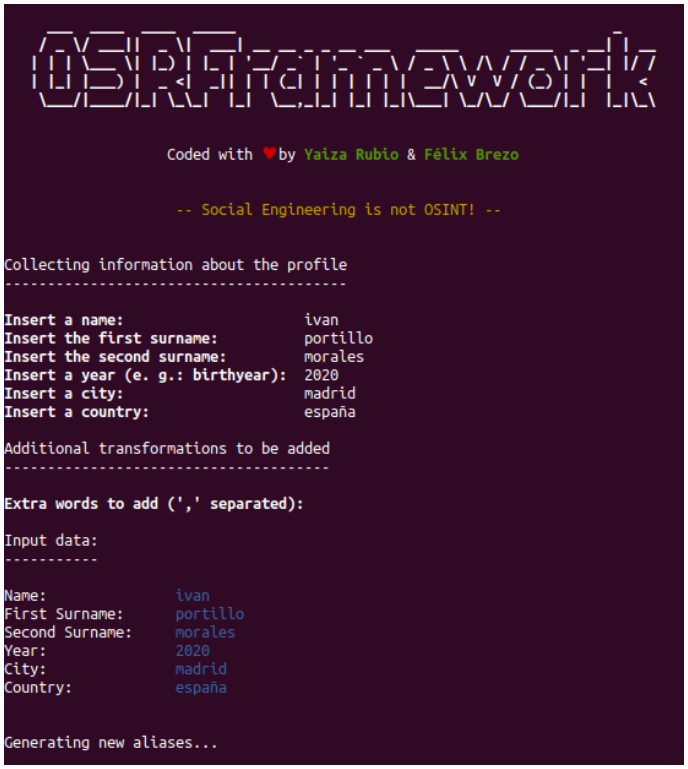


Imagen 69. Ejecución de la herramienta alias_generator

En la Imagen 70 puede verse el listado con un total de 381 nombre de usuarios generados, utilizando una combinatoria entre los datos solicitados.



Imagen 70. Resultados sobre un listado de posibles nombres de usuarios del objetivo con alias_generator

1.1.25.

1.1.26. SOCIAL SEARCHER

Social Searcher es una herramienta online que permite extraer información a partir de un hashtag, menciones, un nombre de usuario o una tendencia de redes sociales, el cual, se nutre de las siguientes fuentes: Twitter, Facebook, Instagram, Reddit, YouTube, VK, Tumblr, Vimeo, Flickr, Daylymotion y sitios web. Se trata de una herramienta de pago pero dispone de una versión gratuita más limitada. El enlace de acceso a Social Searcher es el siguiente: https://www.social-searcher.com/.

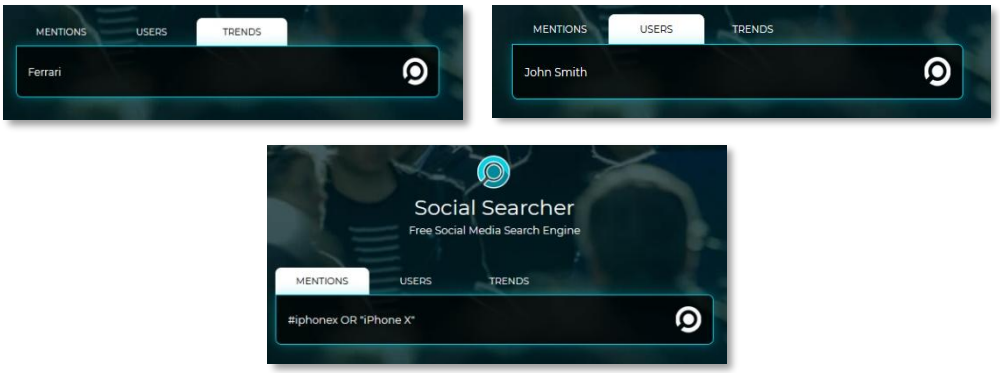


Imagen 71. Sitio oficial de Social Searcher

Realizando una monitorización del hashtag "#ransomware" detectamos las estadísticas que pueden visualizarse en las Imágenes 72, 73 y 74, relacionados con el número total de mensajes por cada red social, hashtags más utilizados, enlaces compartidos y usuarios más populares.



Imagen 72. Resultados de post publicados relacionados con la palabra clave objetivo con Social Searcher

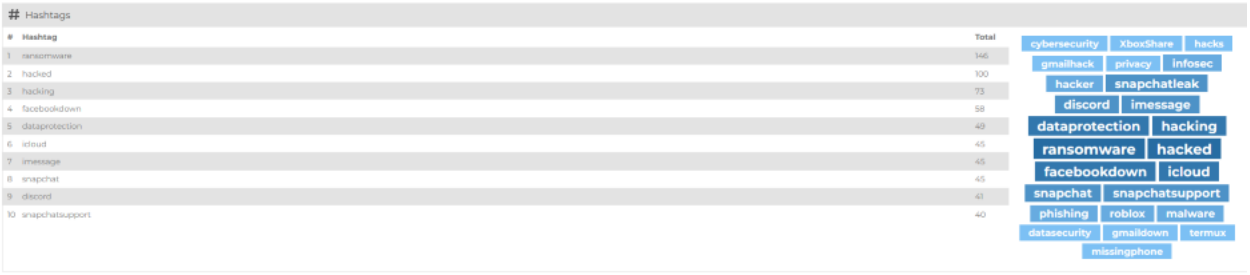


Imagen 73. Resultados de los hashtags detectados en los post sobre la palabra clave objetivo con Social Searcher

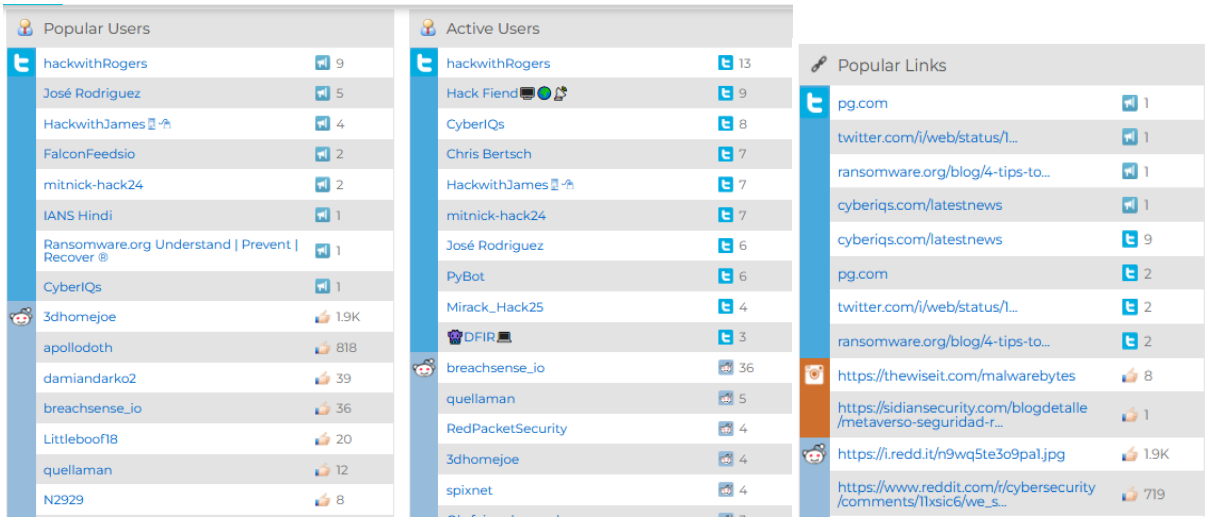


Imagen 74. Links y usuarios más destacados en la monitorización de la palabra clave objetivo con Social Searcher

En la Imagen 75 es posible visualizar cada uno de los mensajes de las distintas redes sociales, pudiendo descargar su contenido con una exportación en CSV por medio del botón “MORE” de la esquina superior derecha.

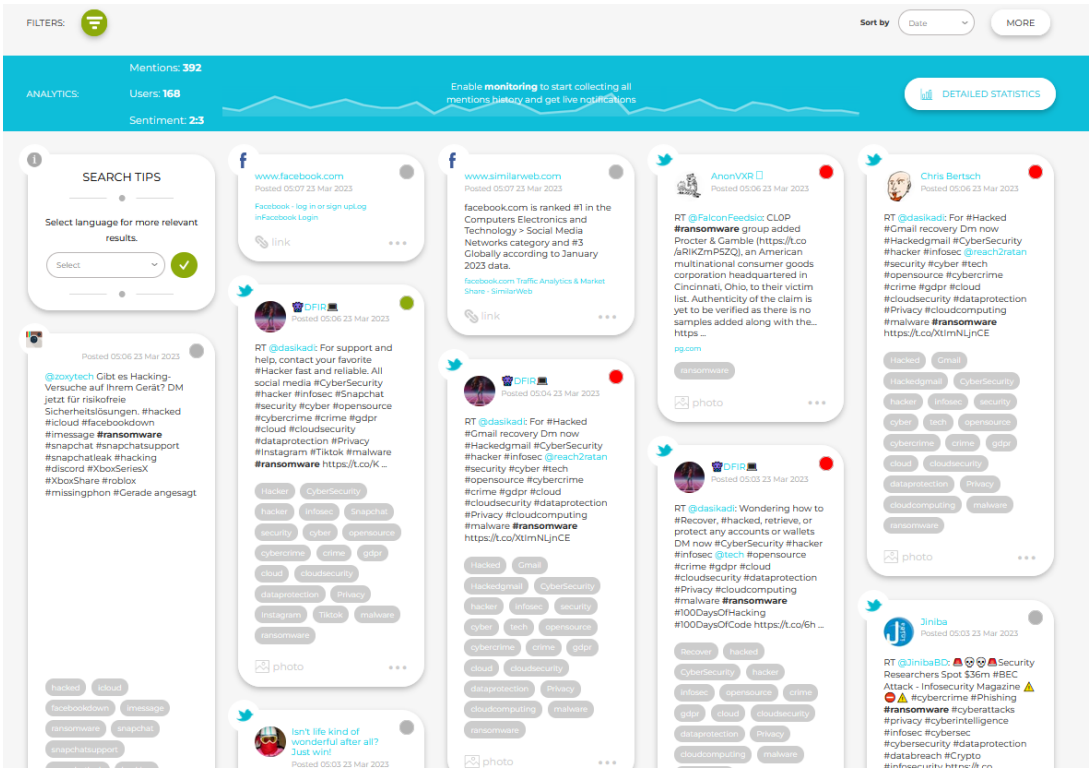


Imagen 75. Vista general de resultados

1.1.27. SOCIAL BEARING

Social Bearing es una herramienta online que permite extraer información de Twitter, partiendo de una palabra clave, un hashtag, un nombre de usuario, una geolocalización, seguidores y seguidos de un perfil en concreto. Se trata de una herramienta gratuita que necesita permiso para acceder a una cuenta de Twitter para poder descargar la información. El enlace de acceso a Social Searcher es el siguiente: https://socialbearing.com/.

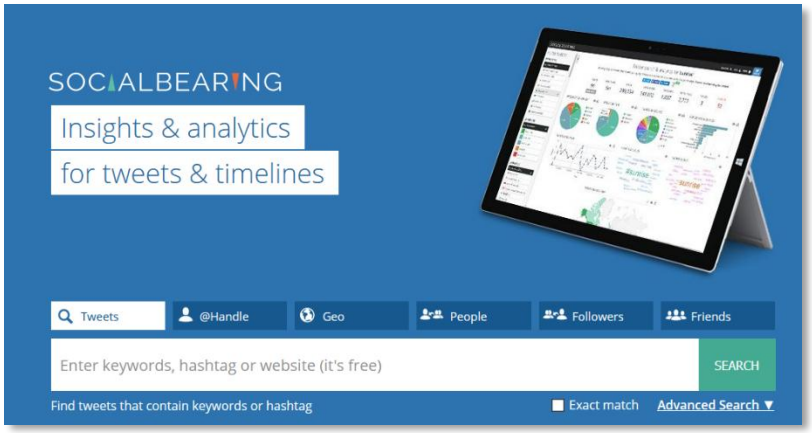
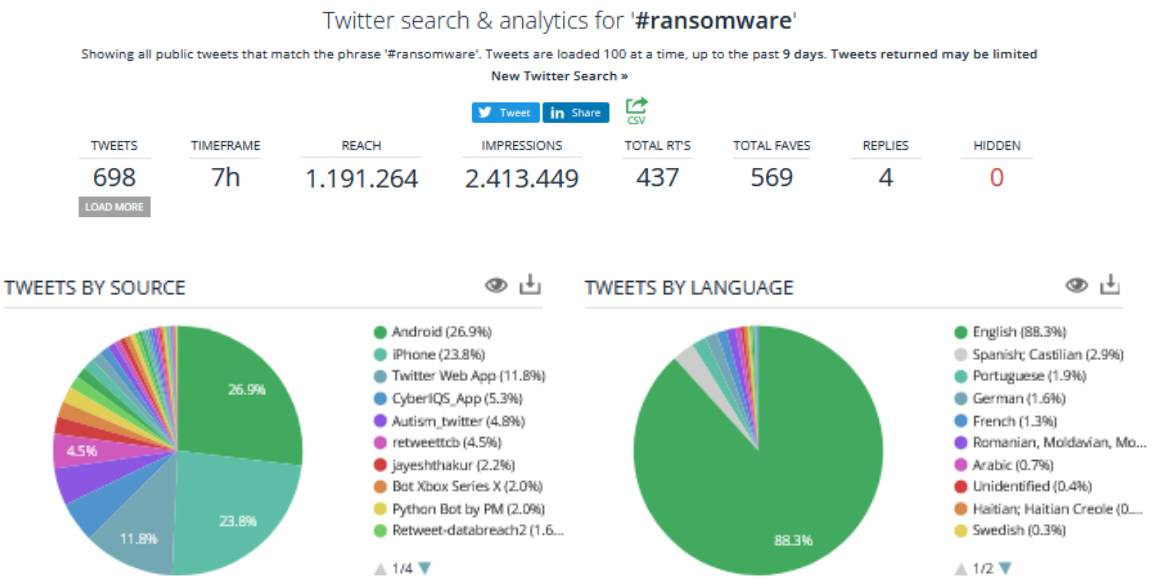


Imagen 76. Sitio oficial de Social Bearing

Realizando una monitorización del hashtag "#ransomware" y extrayendo un total de 698 tweets, detectamos las estadísticas que pueden visualizarse en la Imagen 77, donde es posible obtener los tipos de tweets, el sentimiento, idioma del tweet, top 10 de dominios compartidos, timeline de tweets y nube de palabras a destacar.



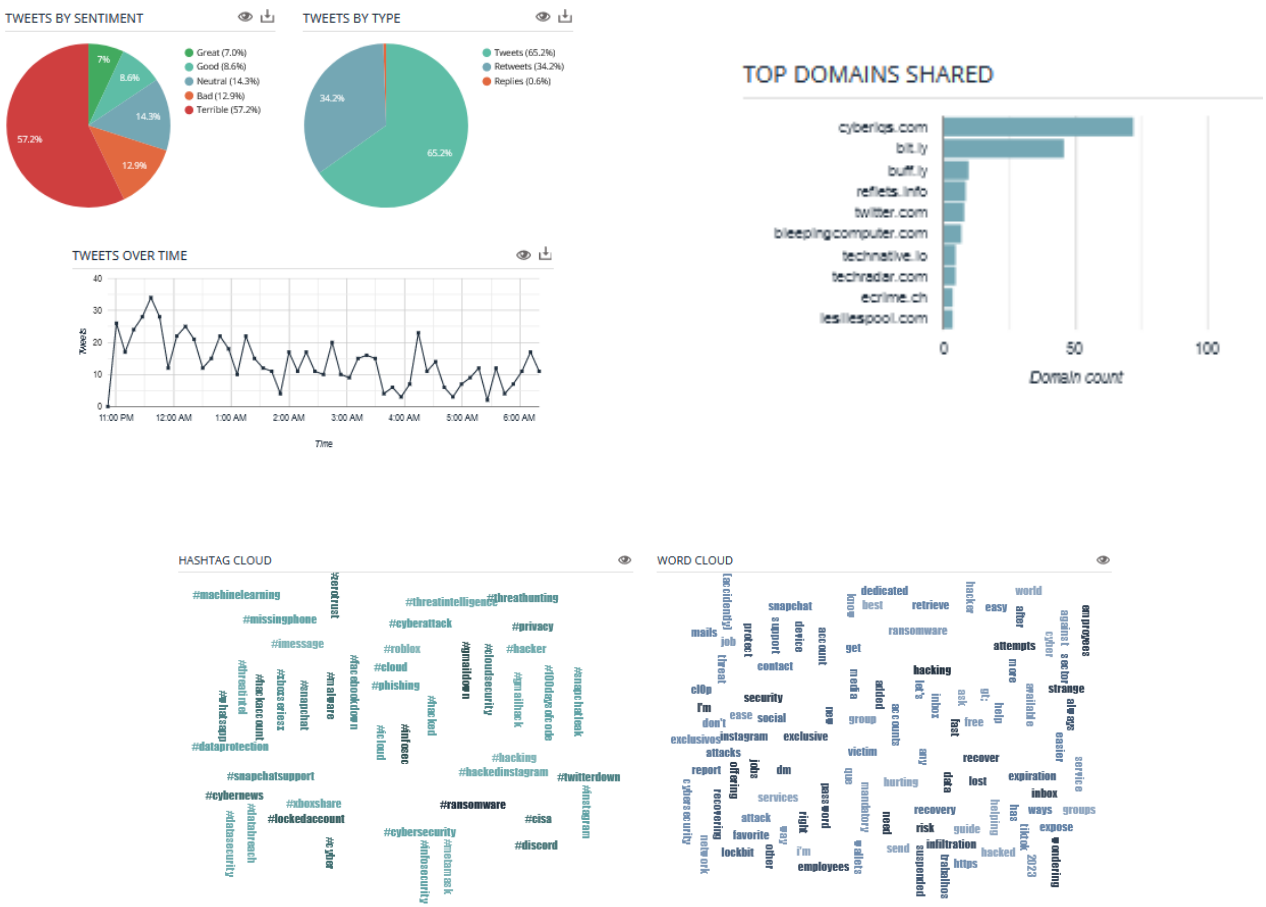


Imagen 77. Resumen a modo estadísticas de los datos recolectados por Social Bearing

En la Imagen 78 puede visualizarse una serie de filtros que pueden ser utilizados para ir al detalle en la monitorización, como por ejemplo filtrar por tipo de tweet (videos, enlaces, menciones, retweets, geolocalización, etc), sentimiento, idioma, top influencers o top contribuidores.

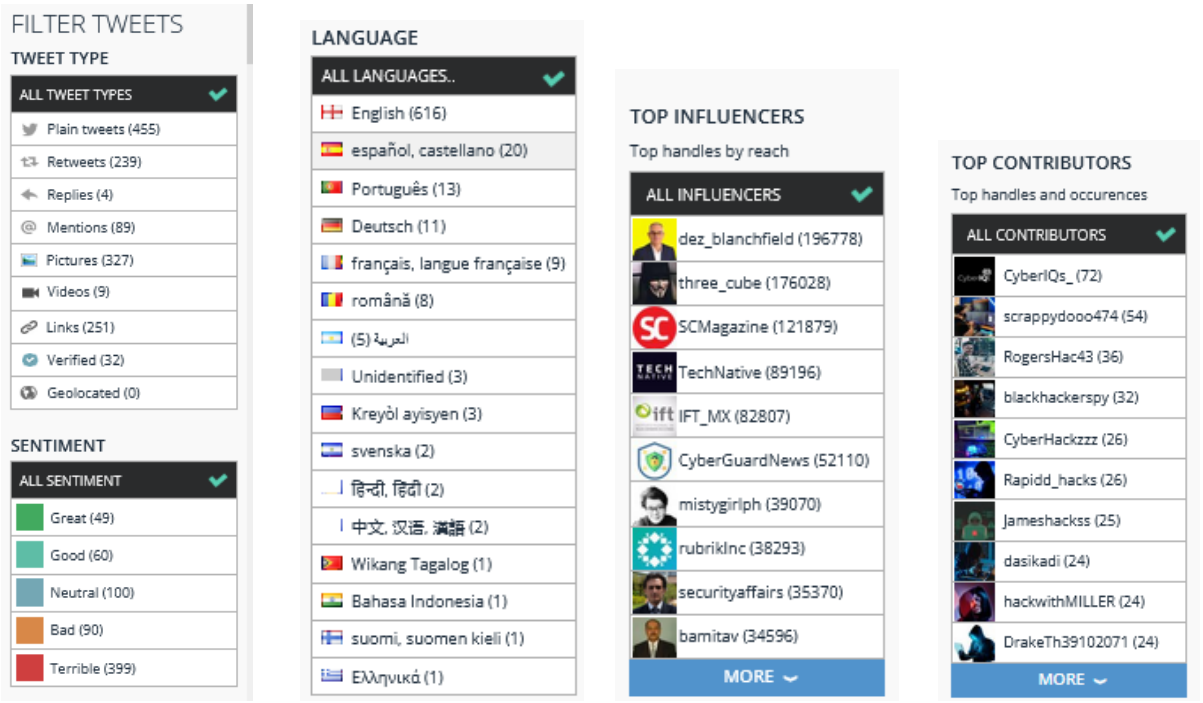


Imagen 78. Diferentes filtros disponibles con Social Bearing sobre una monitorización concreta

En la Imagen 79 es posible visualizar cada uno de los tweets detectados, pudiendo descargar su contenido con una exportación en CSV si se desea.

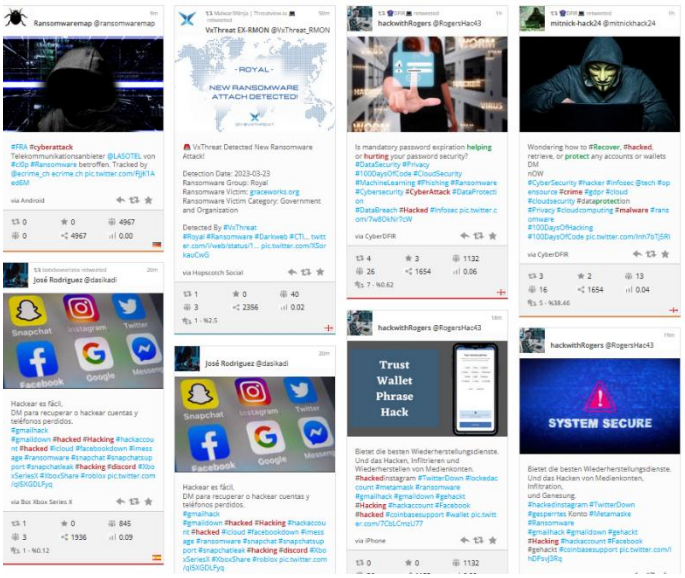


Imagen 79. Vista general de tweets detectados con Social Bearing

1.1.28. EMAIL PERMUTATOR

Email Permutator es una herramienta online que permite realizar una combinatoria entre el nombre, apellidos, username y diferentes proveedores de correos electrónico para obtener un listado de posibles correos electrónicos. El acceso a Email Permutator es el siguiente enlace: http://metricsparrow.com/toolkit/email-permutator/#

En la Imagen 80 puede verse una ejecución de la herramienta, obteniendo un total de 138 correos electrónicos basados en una combinatoria de los parámetros de entrada.

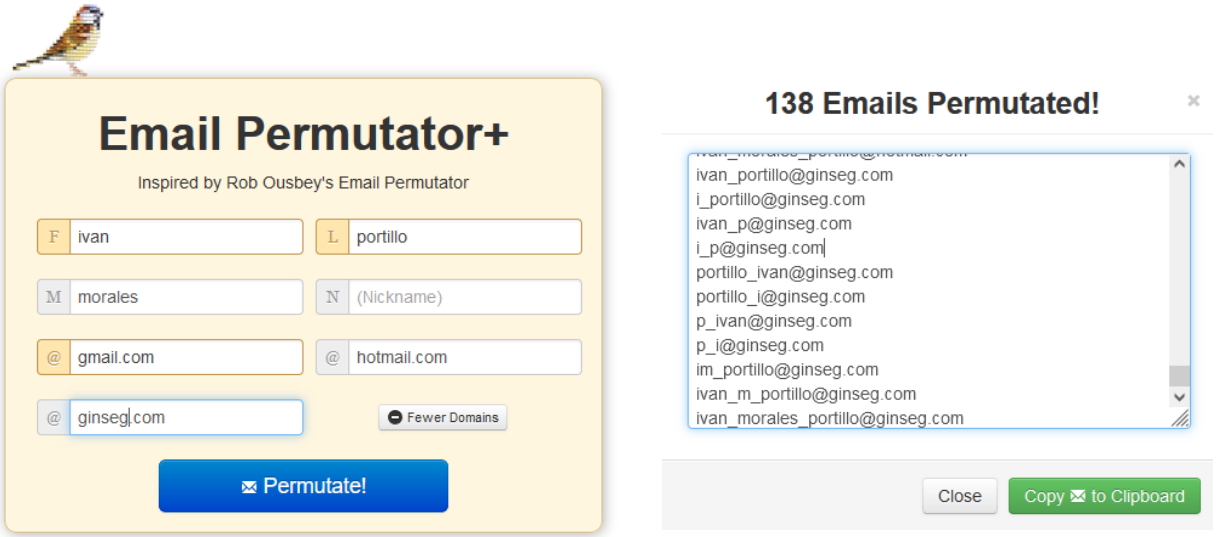


Imagen 80. Listado de correos electrónicos obtenidos con Email Permutator

1.2. PROCEDIMIENTO DE INVESTIGACIÓN DE NOMBRES DE USUARIO

Tal como hemos comentado al principio de este tema es bastante importante contar con una metodología para obtener de una manera guiada toda la información sobre nuestro objetivo. En la Imagen 81 se puede ver en líneas generales un procedimiento para investigar un nombre de usuario o username. En este caso partiendo de un nombre de usuario podríamos realizar las siguiente acciones:

- Comprobar si el nombre de usuario existe en las diversas redes sociales
- Comprobar si utilizando el username junto con proveedores de correo electrónico somos capaces de identificar un correo válido
- Realizar peticiones a los diferentes buscadores mediante dorks para detectar cualquier tipo de información relacionada
- Construir URLs de redes sociales utilizando el username
- Comprobar si el nombre de usuario está presente en alguna fuga de información

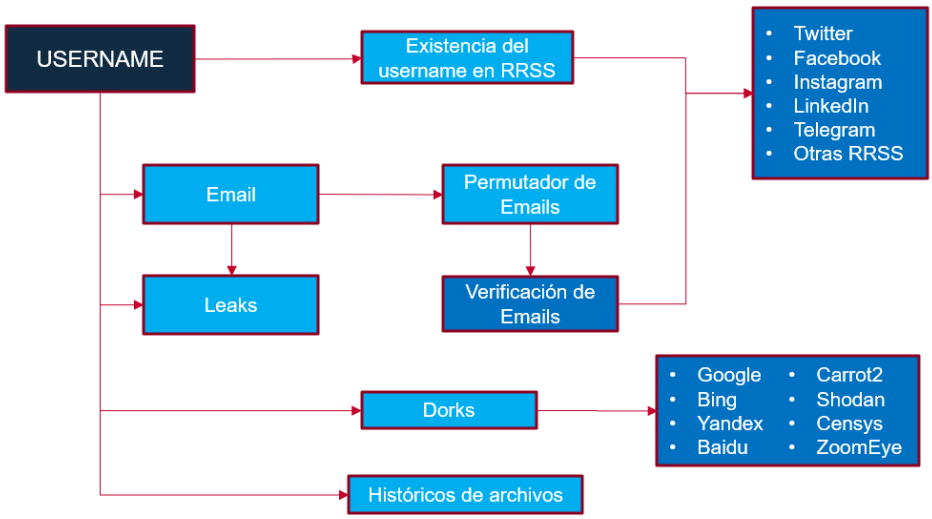


Imagen 81. Diagrama general del procedimiento de investigación de un nombre de usuario

Si hacemos un poco de zoom ahora, podemos comprobar cómo somos capaces de verificar la existencia de un nombre de usuario con herramientas específicas, utilizando para ello recursos para detectarlo tanto de manera individual con cada red social y a nivel

más generalista con multiplataformas sociales. Todo lo comentado puede ser visualizado más gráficamente en la Imagen 82.

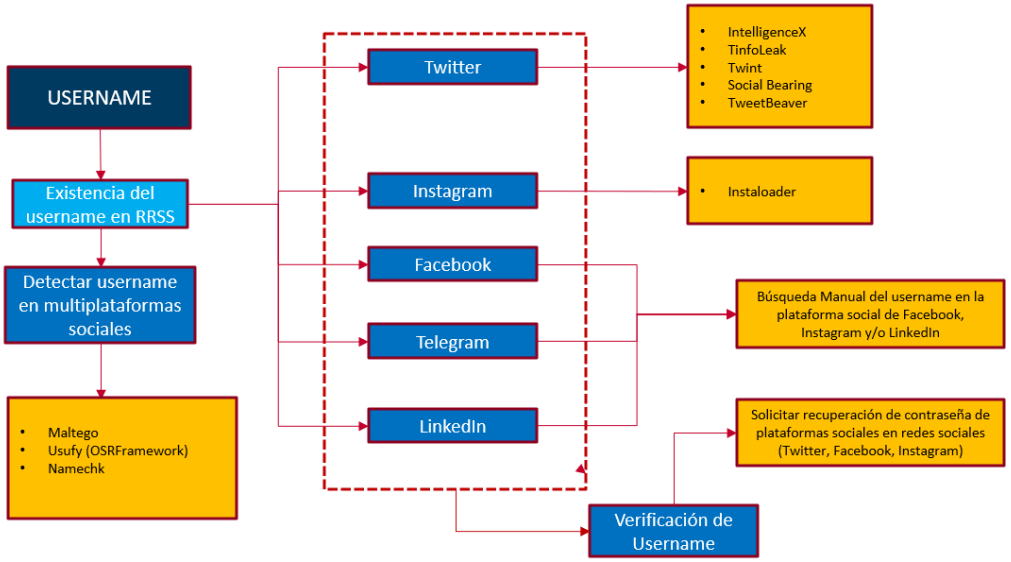


Imagen 82. Procedimiento de investigación de username en detalle 1

En el caso que se quiera utilizar la técnica de recuperación de contraseña (en algunas ocasiones puede permitir detectar algún digito del número de teléfono y del correo electrónico asociados al perfil social), hay que tener presente que en algunas redes sociales es posible que se envíe una notificación sobre que se está solicitando un cambio de contraseña. Esto supondría un riesgo para la investigación ya que le estaríamos dando pistas al objetivo de que le estamos investigando. Una recomendación con este tipo de técnicas (y a nivel general) es ejecutar siempre primero todas las técnicas (ya sea de manera manual o con automatizaciones) con perfiles sociales que estén bajo nuestro poder, de esta forma podremos comprobar si existe algún tipo de riesgo o no. Ahora mismo con la única red social que tenemos altas garantías que eso no ocurra es con Twitter.

Si hacemos otro zoom por otra vía de investigación, podemos realizar una combinatoria del username con diferentes proveedores de correo electrónico o bien con el dominio de nuestro objetivo. En este caso obtendríamos un listado de correos electrónicos sin validar, cosa que sería lo siguiente a realizar: una verificación de estos. En el momento que

tengamos una lista validada de correos electrónicos podríamos investigar si están presentes en algún Data Leak o bien comprobar si el nombre de usuario ha sido filtrado en alguno. Por otro lado, sería posible realizar diferentes consultas en los distintos buscadores para intentar localizar información relevante, al igual que buscar en históricos de archivos web como se ha comentado anteriormente. En la Imagen 83 puede verse lo comentado.

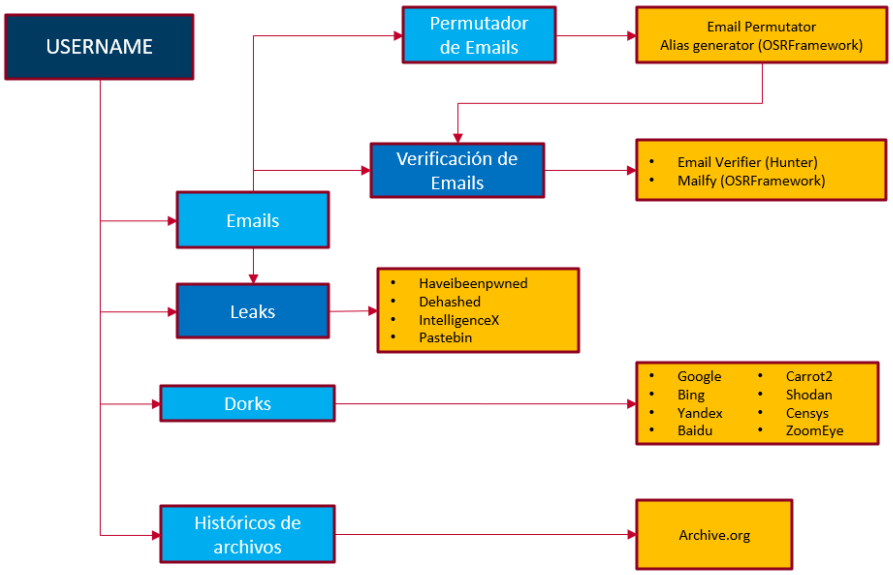


Imagen 83. Procedimiento de investigación de username en detalle 2

1.3. PROCEDIMIENTO DE INVESTIGACIÓN DE NOMBRES DE PERSONAS

Tal como hemos visto en el procedimiento de un nombre de usuario, podemos realizar la misma operativa con un nombre de persona. Dicho procedimiento tiene bastantes similitudes con el procedimiento del nombre de usuario. En la Imagen 84 se puede ver en líneas generales dicho procedimiento, donde en este caso partiremos de un nombre completo para efectuar la investigación. Las diferentes acciones que podemos ejecutar son las siguientes:

- Comprobar si el nombre y apellidos de la persona objetivo están relacionados con un perfil de alguna red social
- Comprobar si realizando una combinatoria del nombre y apellidos junto con proveedores de correo electrónico somos capaces de identificar un correo válido
- Realizar peticiones a los diferentes buscadores mediante dorks para detectar cualquier tipo de información relacionada
- Comprobar si el nombre y apellidos de la persona están presentes en alguna fuga de información

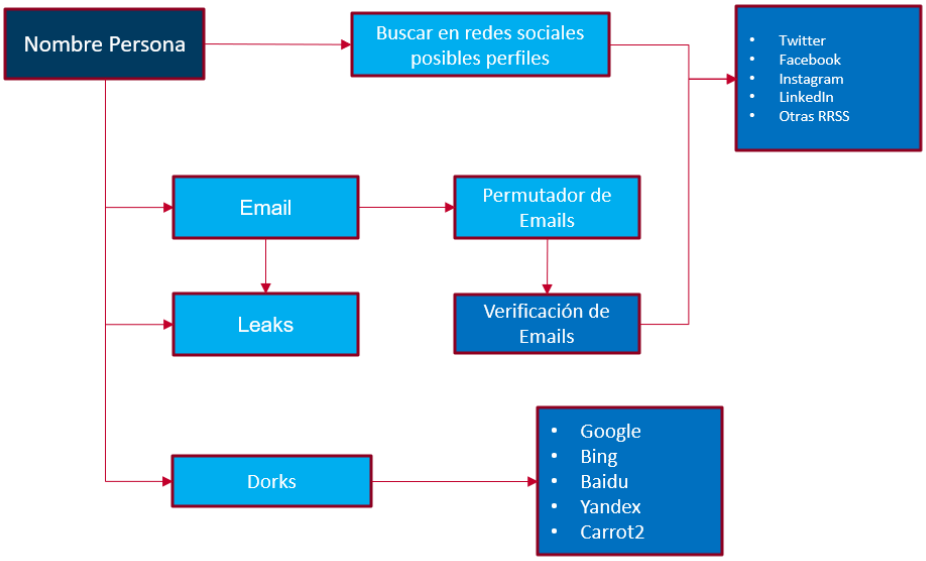


Imagen 84. Procedimiento de investigación de un nombre de persona

Si hacemos un poco de zoom ahora, podemos comprobar cómo somos capaces de verificar la existencia de un nombre de persona con herramientas específicas, utilizando para ello recursos para detectarlo tanto de manera individual con cada red social y a nivel más generalista con multiplataformas sociales. Todo lo comentado puede ser visualizado más gráficamente en la Imagen 85.

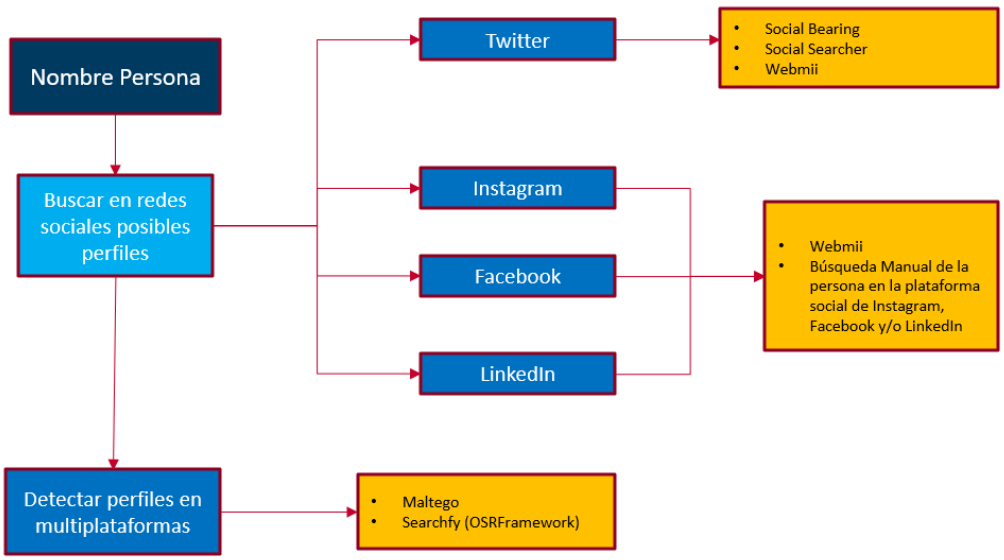


Imagen 85. Procedimiento de investigación de nombre de persona en detalle 1

Si hacemos otro zoom por otra vía de investigación, podemos realizar una combinatoria del nombre de persona con el nombre y apellidos con diferentes proveedores de correo electrónico o bien con el dominio de nuestro objetivo. En este caso obtendríamos un listado de correos electrónicos sin validar, cosa que sería lo siguiente a realizar: una verificación de estos. En el momento que tengamos una lista validada de correos electrónicos podríamos investigar si están presentes en algún Data Leak o bien comprobar si el nombre y apellidos han sido filtrados en alguno. Por otro lado sería posible realizar diferentes consultas en los distintos buscadores para intentar localizar información relevante, al igual que buscar en históricos de archivos como se ha comentado anteriormente. En la Imagen 86 puede verse lo comentado.

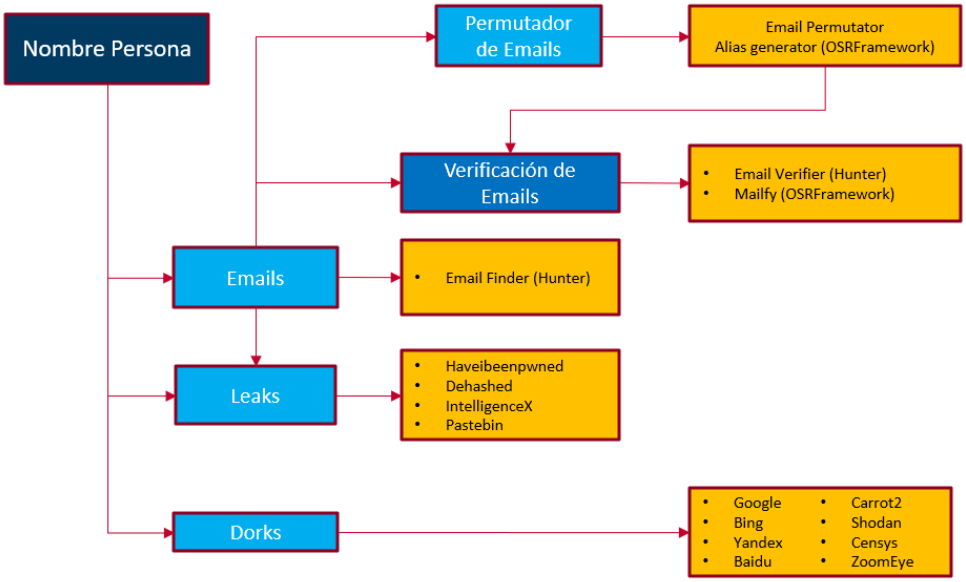


Imagen 86. Procedimiento de investigación de nombre de persona en detalle 2

1.4. PROCEDIMIENTO DE INVESTIGACIÓN DE DOMINIOS

Tal como hemos visto en los procedimientos anteriores, podemos realizar la misma operativa con un dominio. En la Imagen 87 se puede ver en líneas generales dicho procedimiento, donde en este caso partiremos de un dominio para efectuar la investigación. Las diferentes acciones que podemos ejecutar son las siguientes:

- Comprobar la dirección IP detrás del dominio objetivo
- Obtener registros DNS asociados al dominio objetivo
- Obtener el whois del dominio objetivo
- Realizar peticiones a los diferentes buscadores tanto genéricos como especializados mediante dorks para detectar cualquier tipo de información relacionada
- Comprobar si el dominio objetivo tiene muestras o URLs maliciosas asociadas
- Obtener históricos webs del dominio objetivo
- Obtener correos electrónicos relacionados con el dominio objetivo
- Comprobar si el dominio ha sido filtrado en alguna fuga de información

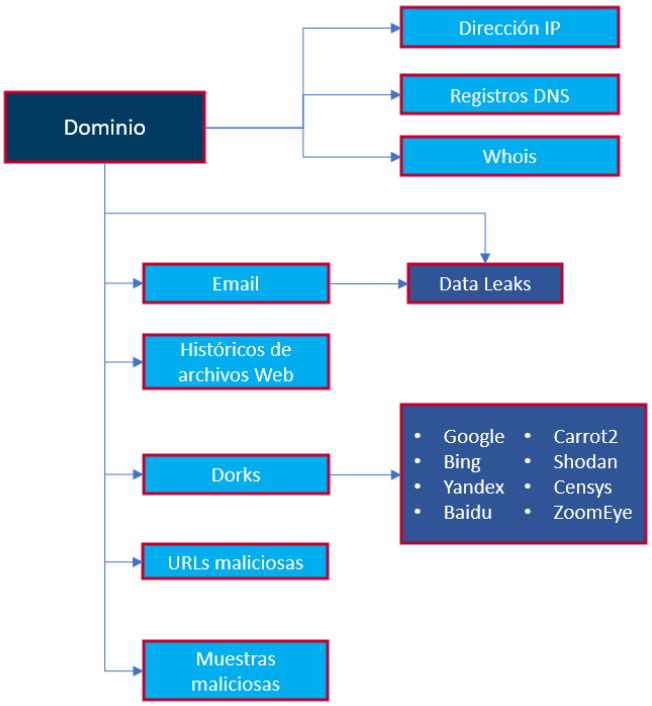


Imagen 87. Procedimiento de investigación de un dominio

Podemos aplicar distintas técnicas para recopilar información relacionados con la dirección IP, los registros DNS, el whois o muestras maliciosas que estén asociados con el dominio objetivo, utilizando para ello herramientas específicas. Todo lo comentado puede ser visualizado más gráficamente en la Imagen 88.

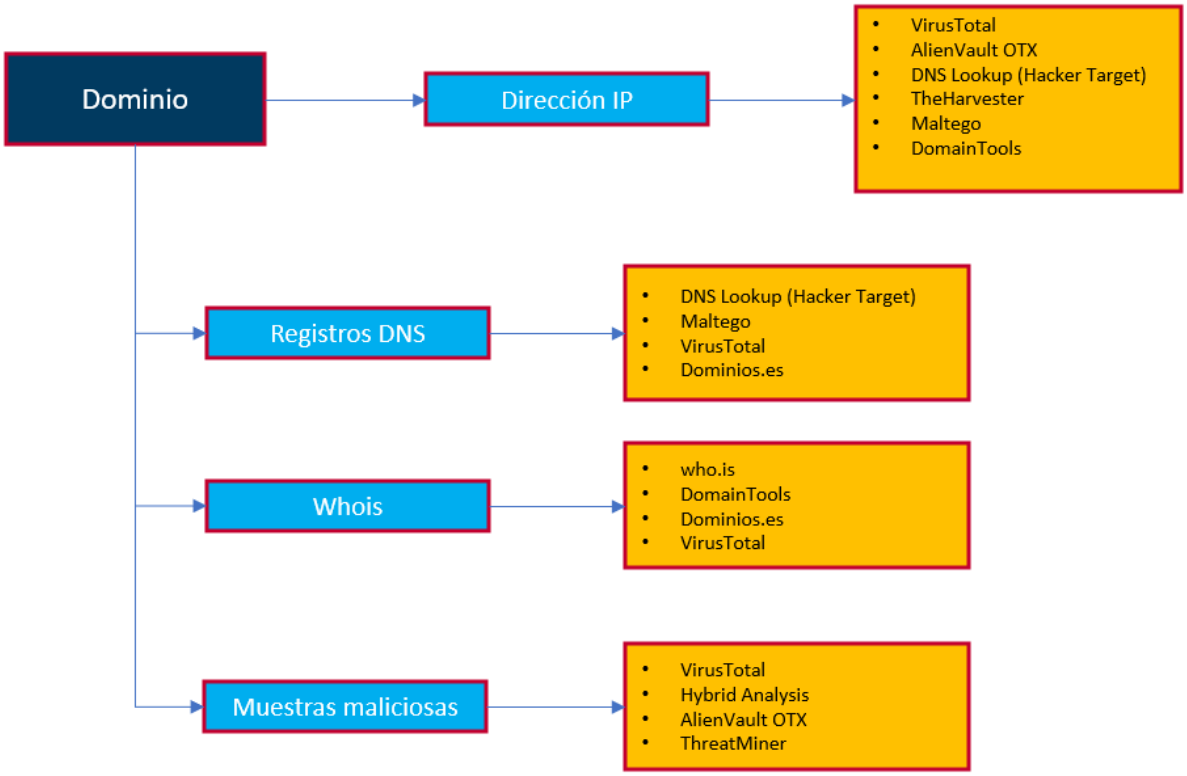


Imagen 88. Procedimiento de investigación de un dominio en detalle 1

Si hacemos otro zoom por el resto de vías de investigación, podemos descubrir que somos capaces de obtener más información partiendo de un dominio, como por ejemplo consultando en buscadores genéricos y/o especializados, obtener diferentes screenshot del dominio en distintos instantes de tiempo, localizar correos electrónicos filtrados en alguna fuente publica o bien en data leaks de cualquier tipo y por último detectar URLs maliciosas empleando herramientas enfocadas en Inteligencia de amenazas. En la Imagen 89 puede verse gráficamente lo comentado.

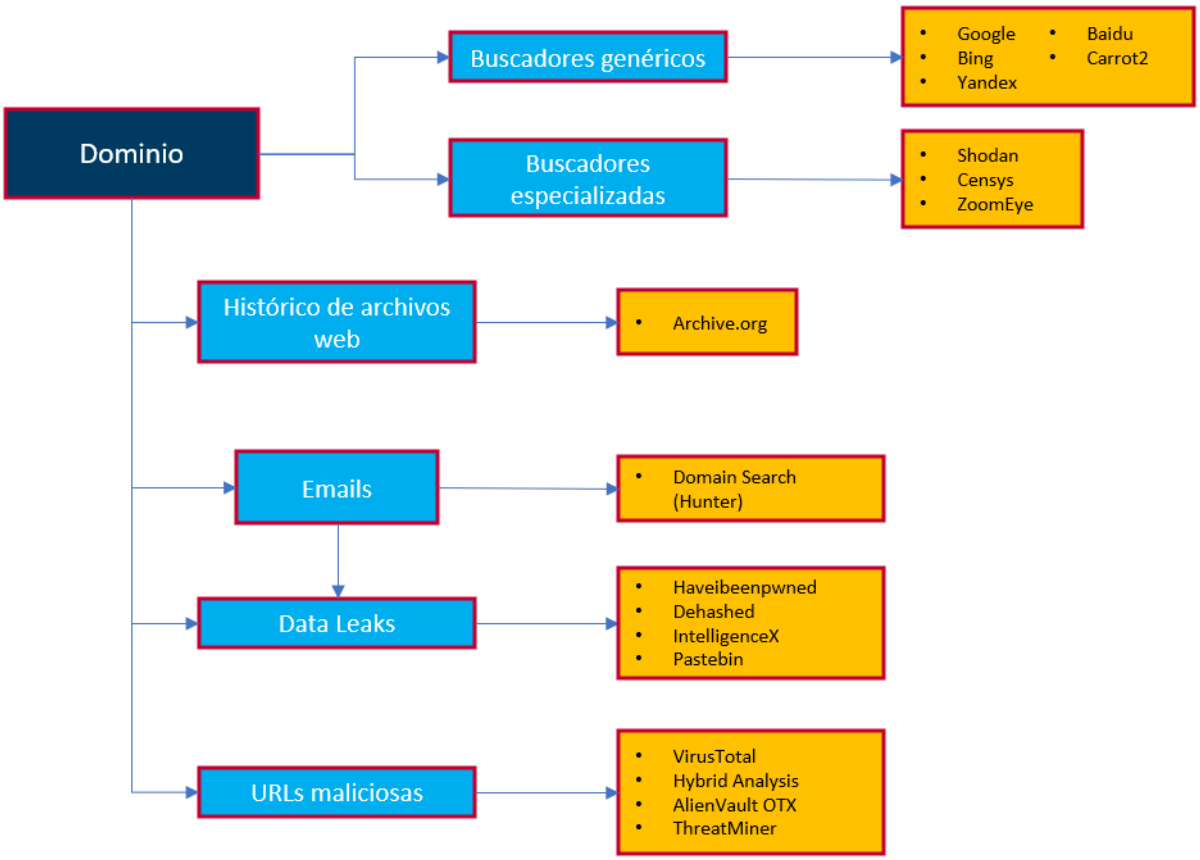


Imagen 89. Procedimiento de investigación de un dominio en detalle 2

1.5. PROCEDIMIENTO DE INVESTIGACIÓN DE CORREOS ELECTRÓNICOS

Tal como hemos visto en los procedimientos anteriores, podemos realizar la misma operativa con un correo electrónico. En la Imagen 90 se puede ver en líneas generales dicho procedimiento, donde en este caso partiremos de un correo electrónico para efectuar la investigación. Las diferentes acciones que podemos ejecutar son las siguientes:

- Comprobar si el correo electrónico está presente en alguna fuga de información
- Obtener el nombre de usuario de alguna red social que este asociado al correo electrónico
- Obtener el nombre de persona con nombre y apellidos asociados al correo electrónico
- Verificar si el correo electrónico es válido

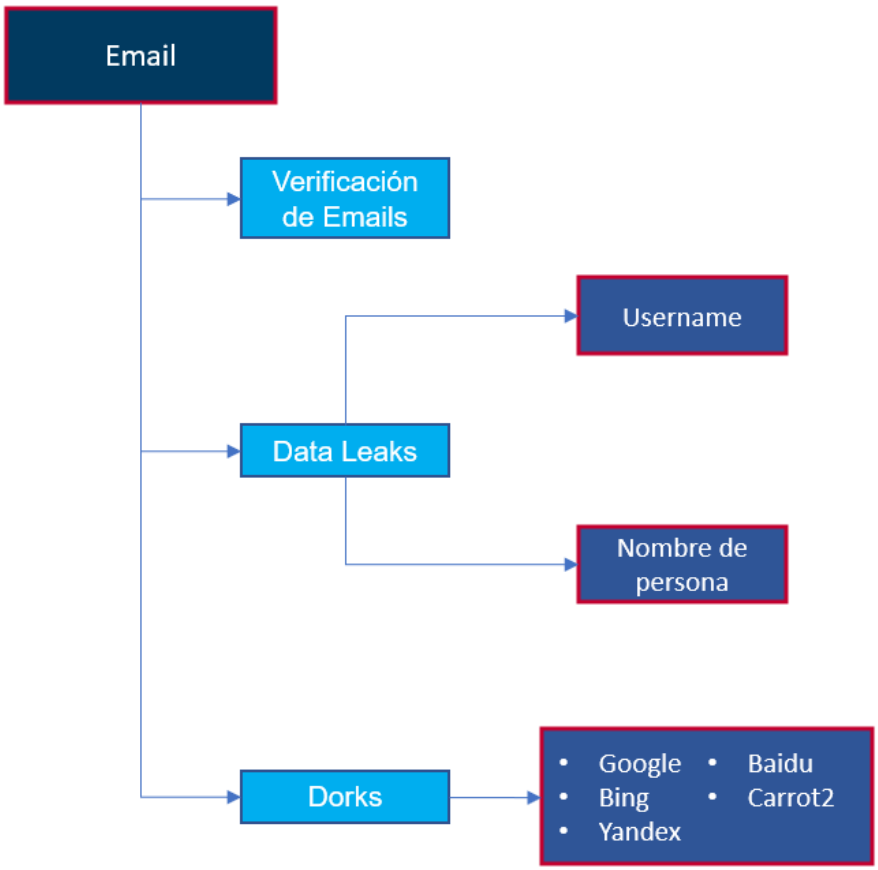


Imagen 90. Procedimiento de investigación de un correo electrónico

Para obtener información relacionado a un correo electrónico disponemos de algunas técnicas para ello, como por ejemplo la validación del propio correo electrónico, realizar consultas en buscadores genéricos, comprobar si hay coincidencias con alguna fuga de información y realizar búsquedas en dichas fugas con el fin de detectar posibles nombres de usuario o de nombres y apellidos. Por último, comprobar si el correo electrónico está relacionado con alguna amenaza consultando herramientas específicas para ello. Todo lo comentado puede ser visualizado más gráficamente en la Imagen 91.

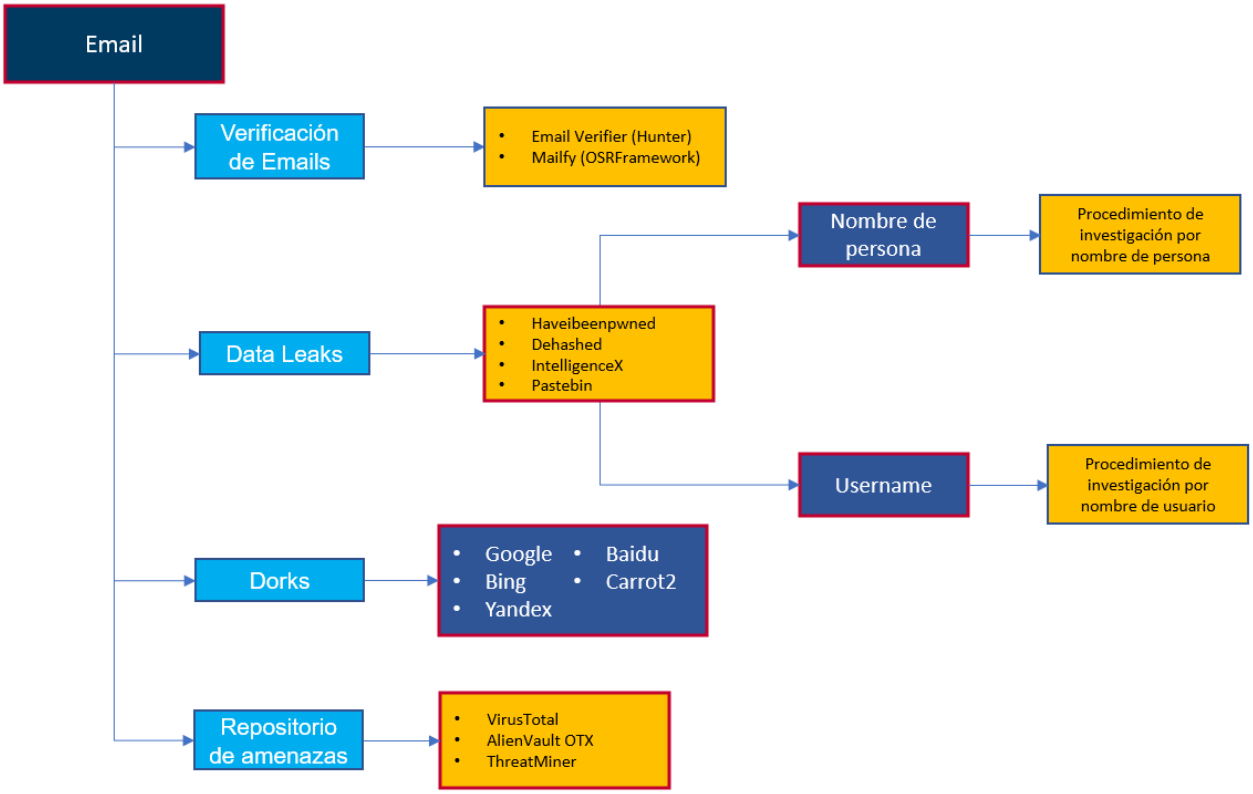


Imagen 91. Procedimiento de investigación de un correo electrónico al detalle

1.6. PROCEDIMIENTO DE INVESTIGACIÓN DE DIRECCIONES IP

Tal como hemos visto en los procedimientos anteriores, podemos realizar la misma operativa con una dirección IP. En la Imagen 92 se puede ver en líneas generales dicho procedimiento, donde en este caso partiremos de una dirección IP para efectuar la investigación. Las diferentes acciones que podemos ejecutar son las siguientes:

- Comprobar los dominios que están apuntando a la dirección IP objetivo
- Obtener el whois de la dirección IP objetivo
- Obtener el Rango IP al que pertenece la dirección IP objetivo
- Realizar peticiones a los diferentes buscadores tanto genéricos como especializados mediante dorks para detectar cualquier tipo de información relacionada
- Comprobar si la dirección IP objetivo tiene muestras maliciosas asociadas o está presente en alguna blacklist
- Comprobar si la dirección IP ha sido filtrada en alguna fuga de información

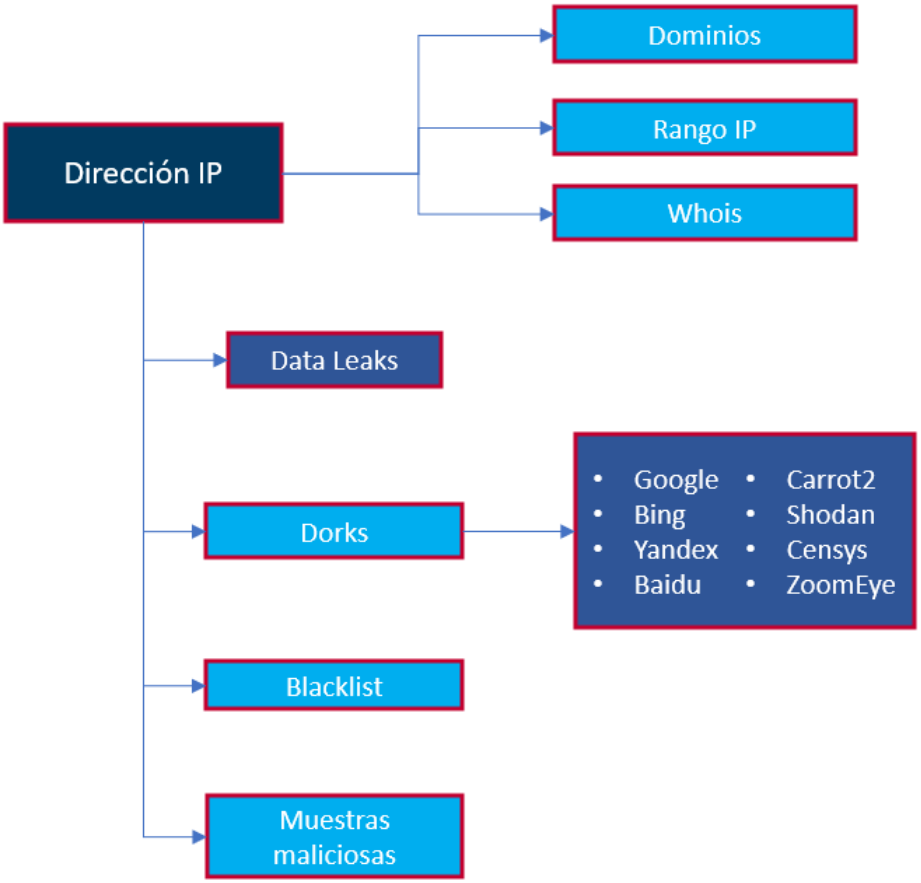


Imagen 92. Procedimiento de investigación de una dirección IP

Para obtener información relacionada a una dirección IP disponemos de una serie de técnicas para ello, como por ejemplo la recolección de dominios que están apuntando a la misma dirección IP objetivo, comprobar a que rango IP pertenece la IP, el whois asociado con los contactos pertinentes y conocer si la dirección IP esta o ha estado relacionada con alguna muestra maliciosa. Todo lo comentado puede ser visualizado más gráficamente en la Imagen 93 con las herramientas específicas para cada tarea.

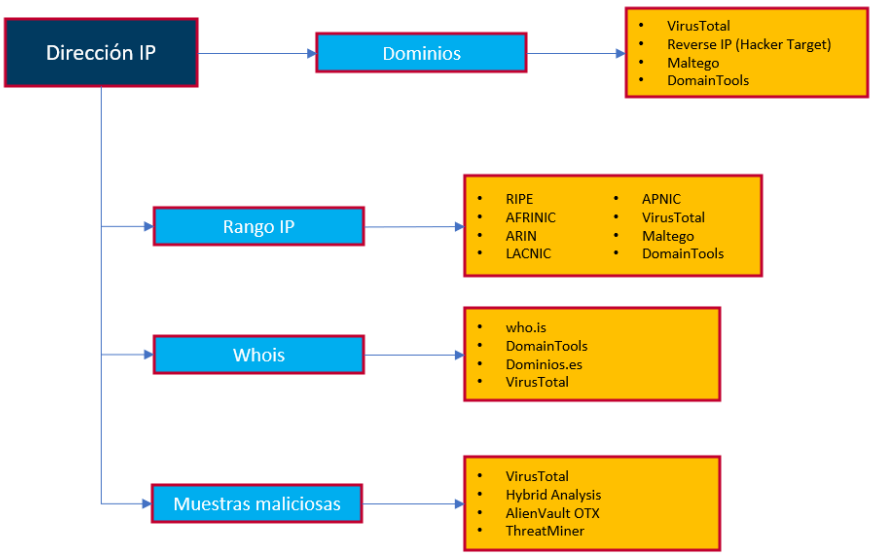


Imagen 93. Procedimiento de investigación de una dirección IP en detalle 1

Si hacemos otro zoom por el resto de vías de investigación, podemos descubrir que somos capaces de obtener más información partiendo de nuestro objetivo, como por ejemplo consultando en buscadores genéricos y/o especializados con el fin de detectar posibles protocolos, puertos, servicios, certificados y un largo etcétera de tecnología asociada a la dirección IP. A parte, es posible comprobar si la propia dirección IP está presente en fugas de información o bien dentro de alguna blocklist relacionada con amenazas concretas. En la Imagen 94 puede verse gráficamente lo comentado.

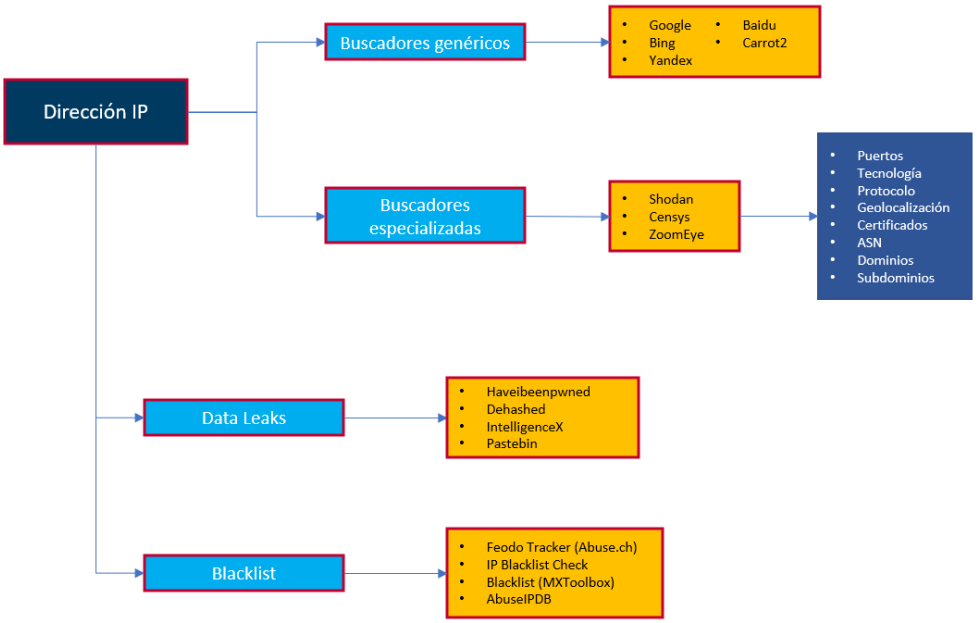


Imagen 94. Procedimiento de investigación de una dirección IP en detalle 2